练习题第一卷

1．不同的信息安全风险评估方法可能得到不同的风险评估结果，所以组织机构应当根据各自的实际情况选择适当的风险评估方法。下面的描述中错误的是（）

A.定量风险分析试图从财务数字上对安全风险进行评估，得出可以量化的风险分析结果，以度量风险的可能性和缺失量

B.定量风险分析相比定性风险分析能得到准确的数值，所以在实际工作中应使用定量风险分析，而不应选择定性风险分析

C.定性风险分析过程中，往往需要凭借分析者的经验和直接进行，所以分析结果和风险评估团队的素质、经验和知识技能密切相关

D.定性风险分析更具主观性，而定量风险分析更具客观性

答案：B

解析：定性分析也是风险评估方法的一种，大部分情况下选择定性分析和定量分析相结合的方式，而不是不选择定性风险分析。

2．根据《关于开展信息安全风险评估工作的意见》的规定，错误的是( )

A.信息安全风险评估分自评估、检查评估两形式，应以检查评估为主，自评估和检查评估相互结合、互为补充

B.信息安全风险评估工作要按照“严密组织、规范操作、讲求科学、注重实效‘的原则开展

C.信息安全风险评估应管贯穿于网络和信息系统建设运行的全过程

D.开展信息安全风险评估工作应加强信息安全风险评估工作的组织领导

答案：A

解析：自评为主，检查为辅

3．某移动智能终端支持通过指纹识别解锁系统的功能，与传统的基于口令的鉴别技术相比，关于此种鉴别技术说法不正确的是

A.所选择的特征（指纹）便于收集、测量和比较

B.每个人所拥有的指纹都是独一无二的

C.指纹信息是每个人独有的，指纹识别系统不存在安全威胁问题

D.此类系统一般由用户指纹信息采集和指纹信息识别两部分组成

答案：C

解析：指纹识别系统存在安全威胁问题，同时存在着错误拒绝率和错误接受率的问题。

4．在密码学的 Kerchhof 假设中，密码系统的安全性仅依赖于_____。

A.明文

B.密文

C.密钥

D.信道

答案；C

解析：柯克霍夫原则：密码系统的安全性依赖于密钥而不依赖于算法。

5．关于 linux 下的用户和组，以下描述不正确的是

A.在 linux 中，每一个文件和程序都归属于一个特定的“用户”

B.系统中的每一个用户都必须至少属于一个用户组

C.用户和组的关系可是多对一，一个组可以有多个用户，一个用户不能属于多个组

D.root 是系统的超级用户，无论是否文件和程序的所有者都具有访问权限

答案：C

解析：一个用户可以属于多个组。

6．张三将微信个人头像换成微信群中某好友头像，并将昵称改为该好友的昵称，然后向该好友的其他好友发送一些欺骗消息。该攻击行为属于以下哪类攻击?

A.口令攻击

B.暴力破解

C.拒绝服务攻击

D.社会工程学攻击

答案：D

解析：D 属于社会工程学攻击。

7．SARSA 模型包括（），它是一个（），它在第一层从安全的角度定义了（）。模型的每一层在抽象方面逐层减少，细节逐层增加，因此，它的层级都是建在其他层之上的，从策略逐渐到技术和解决方案的（）。其思路上创新提出了一个包括战略、概念、设计、实施、度量和审计层次的（ ）

A.五层；业务需求；分层模型；实施实践；安全链条

B.六层；分层模型；业务需求；实施实践；安全链条

C.五层；分层模型；业务需求；实施实践；安全链条

D.六层；分层模型；实施实践；业务需求；安全链条

答案；B

解析：SABSA 舍伍德模型六层模型，从安全角度定义了业务需求

8．某信息安全公司的团队对某款名为“红包快抢”的外挂进行分析，发现此外挂是一个典型的木马后门，使黑客能够获得受害者电脑的访问权，该后门程序为了达到长期驻留在受害都的计算机中，通过修改注册表启动项来达到后门程序随受害者计算机系统启动而启动，这防范此类木马后门的攻击，以下做法无用的是（）

A.不下载，不执行、不接收不来历明的软件

B.不随意打开来历不明的邮件，不浏览不健康不正规的网站

C.使用共享文件夹

D.安装反病毒软件和防火墙，安装专门的木马防治软件

答案：C

解析：使用共享文件夹不是一种防范措施

9．GB／T 22080-2008 《信息技术 安全技术 信息安全管理体系 要求》指出，建立信息安全管理体系应参照 PDCA 模型进行，即信息安全管理体系应包括建立 ISMS、实施和运行 ISMS、监视和评审 ISMS、保持和改进 ISMS 等过程，并在这些过程中应实施若干活动，请选出以下描述错误的选项（）

A.“制定 ISMS 方针”是建立 ISMS 阶段工作内容

B.“实施培训和意识教育计划“是实施和运行 ISMS 阶段工作内容

C.“进行有效性测量”是监视和评审 ISMS 阶段工作内容

D.“实施内部审核”是保护和改进 ISMS 阶段工作内容

答案：D

解析：“实施内部审核”是监视和评审阶段的工作内容。P98 页

10. 终端访问控制器访问控制系统（Terminal Access Controller Access-Control System,TACACS）由 RFC1492 定义，标准的 TACACS 协议只认证用户是否可以登录系统，目前已经很少使用，TACACS+协议由 Cisco 公司提出，主要应用于 Ciso 公司的产品中，运行与 TCP 协议之上。TACACS+协议分为（）两个不同的过程

A.认证和授权

B.加密和认证

C.数字签名和认证

D.访问控制和加密

答案：A

解析：P304 页

11. 从 Linux 内核 2.1 版开始，实现了基于权能的特权管理机制，实现了对超级用户的特权分割，打破了 UNIX/LINUX 操作系统中超级用户/普通用户的概念，提高了操作系统的安全性。下列选项中，对特权管理机制的理解错误的是（）。

A.进程可以放弃自己的某些权能

B.普通用户及其 shell 没有任何权能，而超级用户及其 shell 在系统启动之初拥有全部权能

C.当普通用户的某些操作设计特权操作时，仍然通过 setuid 实现

D.系统管理员可以剥夺和恢复超级用户的某些权能

答案：D

解析：在 Linux 操作系统中，root 用户是最高权限用户，系统管理员不可以剥夺和恢复超级用户的某些权能

12.数据库的安全很复杂,往往需要考虑多种安全策略,才可以更好地保护数据库的安全。以下关于数据库常用的安全策略理解不正确的是（）。

A.粒度最小策略，将数据库中的数据项进行划分，粒度越小，安全级别越高，在实际中需要选择最小粒度

B.最小特权原则，是让用户可以合法的存取或修改数据库的前提下，分配最小的特权，使得这些信息恰好能够完成用户的工作

C.按内容存取控制策略，不同权限的用户访问数据库的不同部分

D.最大共享策略，在保证数据库的完整性、保密性和可用性的前提下，最大程度地共享数据库中的信息

答案：D
解析：数据库安全一般遵循最小化原则。

13. 《信息安全保障技术框架》（Information Assurance Technical Framework，IATF）是由（）发布的。
A.中国
B.美国
C.欧盟
D.俄罗斯
答案：B。
解析：信息安全保障技术框架由美国国家安全局发布，一般由英文翻译过来的大多数都是美国人弄出来的。P28 页。

14. 小赵是某大学计算机科学与技术专业的毕业生，在前往一家大型企业应聘时，面试经理要求他给出该企业信息系统访问控制模型的设计思路。如果想要为一个存在大量用户的信息系统实现自主访问控制功能，在以下选项中，从时间和资源消耗的角度，下列选项中他应该采取的最合适的模型或方法是（）。
A.BLP 模型
B.Biba 模型
C.能力表（CL）
D.访问控制列表（ACL）
答案：D
解析：目前 Wiondows 和 linux 操作系统使用的都是 ACL，访问控制表（ACL）是在每个文件下面附着一个客户权限表，正常情况下一个系统客户数再多也不会有文件的数量多，所以选 D；而 BLP 模型、Biba 模型属于强制访问控制模型，与题干不符。P307 页。

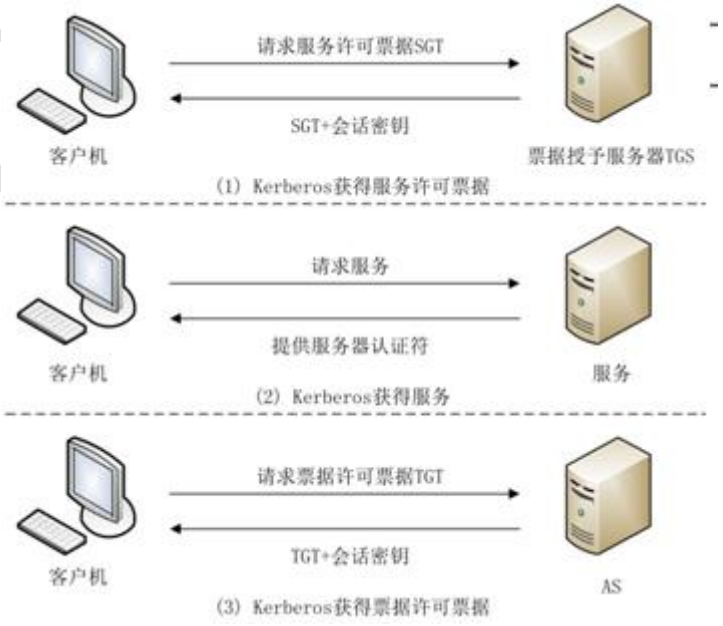
15. 小牛在对某公司的信息系统进行风险评估后，因考虑到该业务系统中部分涉及金融交易的功能模块风险太高，他建议该公司以放弃这个功能模块的方式来处理该风险。请问这种风险处置的方法是（）。
A.放弃风险
B.规避风险
C.降低风险
D.转移风险
答案：B
解析：风险规避：在某些情形下，变更、延缓或停止某种服务或业务功能，可能是合适的方法。根据题干“建议放弃这个功能模块”判断为风险规避。P143 页。

16. 小张新购入了一台安装了 Windows 操作系统的笔记本电脑。为了提升操作系统的安全性，小张在 Windows 系统中的“本地安全策略”中，配置了四类安全策略：账号策略、本地策略、公钥策略和 IP 安全策略。那么该操作属于操作系统安全配置内容中的（）。
A.关闭不必要的端口
B.关闭不必要的服务

C.查看日志记录
D.制定安全策略
答案：D
解析：该操作是指：配置了四类安全策略：账号策略、本地策略、公钥策略和IP安全策略

17．某个新成立的互联网金融公司拥有10个与互联网直接连接的IP地址，但是该网络内有15台个人计算机，这些个人计算机不会同时开机并连接互联网。为解决公司员工的上网问题，公司决定将这10个互联网地址集中起来使用，当任意一台个人计算机开机并连接网络时，管理中心从这10个地址中任意取出一个尚未分配的IP地址分配给这个人的计算机。他关机时，管理中心将该地址收回，并重新设置为未分配。可见，只要同时打开的个人计算机数量少于或等于可供分配的IP地址，那么，每台个人计算机可以获取一个IP地址，并实现与互联网的连接。该公司使用的IP地址规划方式是（）。
A.静态NAT分配地址
B.端口NAT分配地址
C.静态分配地址
D.动态分配地址
答案：D
解析:动态IP地址(Dynamic IP)指的是在需要的时候才进行IP地址分配的方式，“只要同时打开的个人计算机数量少于或等于可供分配的IP地址，那么，每台个人计算机可以获取一个IP地址”显然属于动态分配地址。

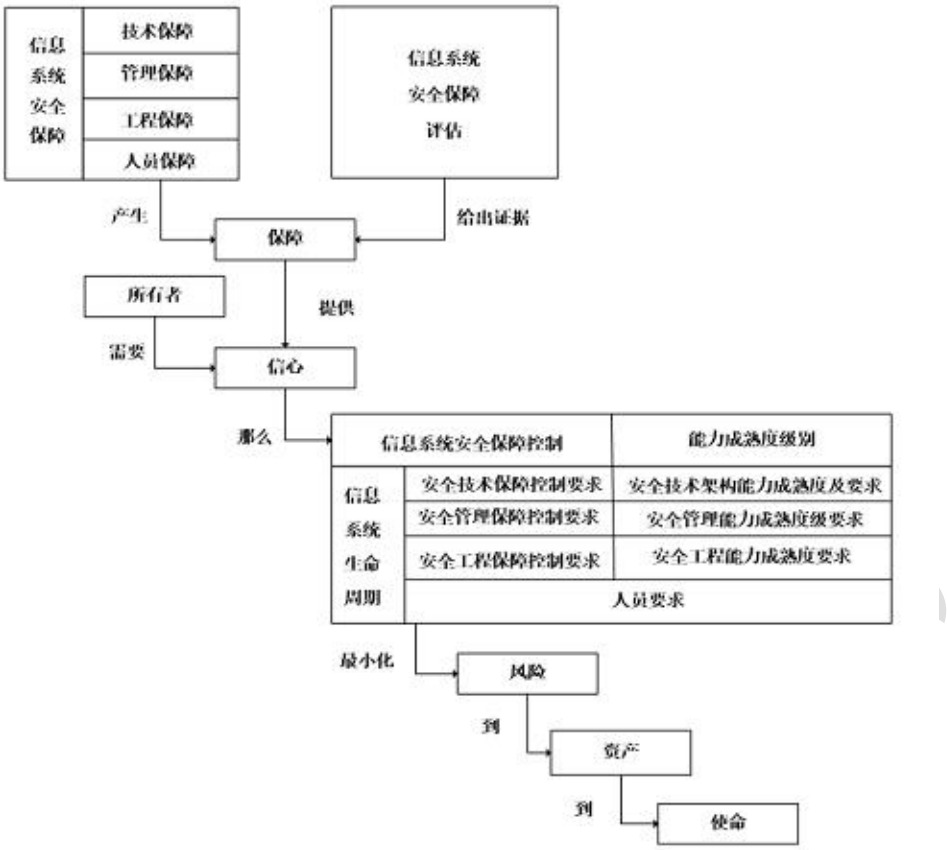
18．Kerberos协议是常用的集中访问控制协议，通过可信第三方的认证服务，减轻应用服务器的负担。Kerberos的运行环境由密钥分发中心（KDC）、应用服务器和客户端三个部分组成。其中，KDC分为认证服务器AS和票据授权服务器TGS两部分。下图展示了Kerberos协议的三个阶段，分别为（1）Kerberos获得服务许可票据，（2）Kerberos获得服务，（3）Kerberos获得票据许可票据。下列选项中，对这三个阶段的排序正确的是（）。



A.（1）→（2）→（3）
B.（2）→（1）→（3）
C.（3）→（2）→（1）
D.（3）→（1）→（2）
答案：D
解析：Kerberos 基本认证过程分为三个阶段：第一阶段：获得票据许可票据；第二阶段：获得服务许可票据；第三阶段：获得服务。P301 页。

19. PKI 的主要理论基础是（）。
A.摘要算法
B.对称密码算法
C.量子密码
D.公钥密码算法
答案：D
解析：PKI（公钥基础设施），也称公开密钥基础设施。P286 页。

20. 信息系统安全保障评估概念和关系如图所示。信息系统安全保障评估，就是在信息系统所处的运行环境中对信息系统安全保障的具体工作和活动进行客观的评估。通过信息系统安全保障评估所搜集的（ ），向信息系统的所有相关方提供信息系统的（ ）能够实现其安全保障策略，能够将其所面临的风险降低到其可接受的程度的主观信心。信息系统安全保障评估的评估对象是（ ），信息系统不仅包含了仅讨论技术的信息技术系统，还包括同信息系统所处的运行环境相关的人和管理等领域。信息系统安全保障是一个动态持续的过程，涉及信息系统整个（ ），因此信息系统安全保障的评估也应该提供一种（ ）的信心。



A.客观证据；安全保障工作；动态持续；信息系统；生命周期
B.安全保障工作；客观证据；信息系统；生命周期；动态持续
C.客观证据；安全保障工作；信息系统；生命周期；动态持续
D.客观证据；安全保障工作；生命周期；信息系统；动态持续
答案：C
解析：P33 页。

21．老王是某政府信息中心主任。以下哪项项目是符合《保守国家秘密法》要求的（）
A.老王要求下属小张把中心所有计算机贴上密级标志
B.老王提出对加密机和红黑电源插座应该与涉密信息系统同步投入使用
C.老王安排下属小李将损害的涉密计算机的某国外品牌硬盘送到该品牌中国区维修中心修理
D.老王每天晚上 12 点将涉密计算机连接上互联网更新杀毒软件病毒库
答案：B
解析：保密设施、设备应当与涉密信息系统同步规划，同步建设，同步运行（三同步）。P57 页，A 项非涉密计算机不应贴涉密标识，C 涉密计算机应送往有涉密资质的维修中心，D 项目涉密计算机不上网。

22．以下关于 Web 传输协议、服务端和客户端软件的安全问题说法不正确的是（）。

A.HTTP 协议主要存在明文传输数据、弱验证和缺乏状态跟踪等方面的安全问题

B.Cookie 是为了辨别用户身份，进行会话跟踪而存储在用户本地终端上的数据，用户可以随意查看存储在 Cookie 中的数据，但其中的内容不能被修改

C.HTTP 协议缺乏有效的安全机制，易导致拒绝服务、电子欺骗、嗅探等攻击

D.针对 HTTP 协议存在的安全问题，使用 HTTPS 具有较高的安全性，可以通过证书来验证服务器的身份，并为浏览器和服务器之间的通信加密

答案：B

解析：Cookie 是为了辨别用户身份，进行会话跟踪而存储在用户本地终端上的数据，用户不可以随意查看存储在 Cookie 中的数据，查看 cookie 必须安装专用的插件也行。P376 页。

23.随机进程名称是恶意代码迷惑管理员和系统安全检查人员的技术手段之一，以下对于随机进程名技术，描述正确的是（）。

A.随机进程名技术每次启动时随机生成恶意代码进程名称，通过不固定的进程名称使自己不容易被发现真实的恶意代码程序名称

B.恶意代码生成随机进程名称的目的是使进程名称不固定，因为杀毒软件是按照进程名称进行病毒进程查杀

C.恶意代码使用随机进程名是通过生成特定格式的进程名称，使进程管理器中看不到恶意代码的进程

D.随机进程名技术虽然每次进程名都是随机的，但是只要找到了进程名称，就找到了恶意代码程序本身

答案：A

解析：B 恶意代码生成随机进程名称的目的是使进程名称不固定，杀毒软件是按照特征码扫描和行为检测进行病毒进程查杀；C 恶意代码使用随机进程名是通过生成特定格式的进程名称，进程管理器中可以所有的进程；D 找到恶意代码进程名称不意味能找到程序本身以及存储路径。P370。

24.（）第二十三条规定存储、处理国家秘密的计算机信息系统（以下简称涉密信息系统）按照（）实行分级保护。（）应当按照国家保密标准配备保密设施、设备。（）、设备应当与涉密信息系统同步规划、同步建设、同步运行（三同步）。涉密信息系统应当按照规定，经（）后，方可投入使用。

A.《保密法》；涉密程度；涉密信息系统；保密设施；检查合格

B.《安全保密法》；涉密程度；涉密信息系统；保密设施；检查合格

C.《国家保密法》；涉密程度；涉密系统；保密设施；检查合格

D.《网络保密法》；涉密程度；涉密系统；保密设施；检查合格

答案：A

解析：《保密法》第二十三条规定存储、处理国家秘密的计算机信息系统（以下简称涉密信息系统）按照涉密程度实行分级保护。涉密信息系统应当按照国家保密标准配备保密设施、设备。保密设施、设备应当与涉密信息系统同步规划、同步建设、同步运行（三同步）。涉密信息系统应当按照规定，经检查合格后，方可投入使用。P57 页。

25. 有关能力成熟度模型（CMM），错误的理解是（）。

A.CMM 的思想来源于项目管理、质量管理和过程管理
B.CMM 是一种衡量工程实施能力的方法，是一种面向工程过程的方法
C.CMM 是建立在统计过程控制理论基础上的，它基于这样一个假设，即“生产过程的高质量和在过程中组织实施的成熟性可以低成本地生产出高质量产品”
D.CMM 的思想不关注结果，而是强调了过程的控制，过程如果是高质量的，结果通常会是高质量的
答案：A
解析：CMM 的思想来源于已有多年历史的项目管理、质量管理，自产生以来几经修订，成为具有广泛影响的模型。P178 页。

26. 以下哪项制度或标准被作为我国的一项基础制度加以推行，并且有一定强制性，其实施的主要目标是有效地提高我国信息和信息系统安全建设的整体水平，重点保障基础信息网络和重要信息系统的安全。（）
A.信息安全管理体系（ISMS）
B.信息安全等级保护
C.ISO 270000 系列
D.NIST SP800
答案：B
解析：信息安全等级保护制度（等保）是一项强制性基础制度。P75 页。
27. 一个信息管理系统通常会对用户进行分组并实施访问控制。例如，在一个学校的教务系统中，教师能够录入学生的考试成绩，学生只能查看自己的分数，而学校教务部门的管理人员能够对课程信息、学生的选课信息等内容进行修改。下列选项中，对访问控制的作用的理解错误的是（）。
A.对经过身份鉴别后的合法用户提供所有服务
B.在用户对系统资源提供最大限度共享的基础上，对用户的访问权进行管理
C.拒绝非法用户的非授权访问请求
D.防止对信息的非授权篡改和滥用
答案：A
解析：访问控制的核心：允许合法用户的授权访问，防止非法用户的访问和合法用户的越权访问。。P304 页。

28. 由于 Internet 的安全问题日益突出，基于 TCP/IP 协议，相关组织和专家在协议的不同层次设计了相应的安全通信协议，用来保障网络各层次的安全。其中，属于或依附于传输层的安全协议是（）。
A.IPSec
B.PP2P
C.L2TP
D.SSL
答案：D
解析：IPSec 工作在网络层，PP2P 和 L2TP 工作在数据链路层，SSL 工作在传输层。P338 页。

29. 关于信息安全管理体系（Information Security Management Systems，ISMS），下面描述错误的是（ ）。

A.概念上，信息安全管理体系有广义和狭义之分，狭义的信息安全管理体系是指按照 ISO27001 标准定义的管理体系，它是一个组织整体管理体系的组成部分

B.信息安全管理体系是组织在整体或特定范围内建立信息安全方针和目标，以及完成这些目标所用方法的体系，包括组织架构、方针、活动、职责及相关实践要素

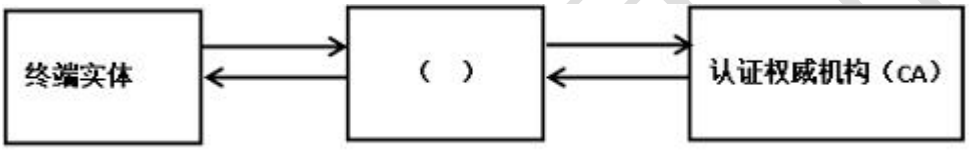
C.同其他管理体系一样，信息安全管理体系也要建立信息安全管理组织机构、健全信息安全管理制度、构建信息安全技术防护体系和加强人员的安全意识等内容

D.管理体系（Management Systems）是为达到组织目标的策略、程序、指南和相关资源的框架，信息安全管理体系是管理体系思想和方法在信息安全领域的应用

答案：我们给出的答案是 B，但其他一些题库给出的答案是 C

解析：“以及完成这些目标所用方法的体系”应是“所用各类安全措施的体系”。

30. 公钥基础设施（Public Key Infrastructure，PKI）引入数字证书的概念，用来表示用户的身份。下图简要地描述了终端实体（用户）从认证权威机构 CA 申请、撤销和更新数字证书的流程。请为中间框空白处选择合适的选项（）。



A.OCSP

B.证书库

C.CRL 库

D.RA

答案：D

解析：PKI 由：CA、RA、证书库和终端实体等部分。P286 页

31.私有 IP 地址是一段保留的 IP 地址。只使用在局域网中，无法在 Internet 上使用。关于私有地址，下面描述正确的是（）。

A.A 类地址中没有私有地址，B 类和 C 类地址中可以设置私有地址

B.A 类、B 类和 C 类地址中都可以设置私有地址

C.A 类和 B 类地址中没有私有地址，C 类地址中可以设置私有地址

D.A 类、B 类和 C 类地址中都没有私有地址

答案：B

解析：私有地址就是在互联网上不使用，而被用在局域网络中的地址。A、B、C 类地址中均可设置是由地址，其中：A 类私有地址是 10.0.0.0 到 10.255.255.255；B 类私有地址 172.16.0.0 到 172.31.255.255；C 类私有地址是 192.168.0.0 到 192.168.255.255。

32. 2016 年 10 月 21 日，美国东部地区发生大规模断网事件，此次事件是由于美国主要 DNS 服务商 Dyn 遭遇大规模 DDos 攻击所致，影响规模惊人，对人们生产生活 造成严重影响。DDoS 攻击的主要目的是破坏系统的（）。

A.抗抵赖性

B.保密性
C.可用性
D.不可否认性
答案：C
解析：DDOS（分布式拒绝服务攻击）主要攻击目标所提供的服务，以破坏可用性为主要目的。P350 页。

33．关于计算机取证描述不正确的是（）。
A.取证的目的包括：通过证据查找肇事者、通过证据推断犯罪过程、通过证据判断受害者损失程度及收集证据提供法律支持
B.计算机取证的过程可以分为准备、保护、提取、分析和提交 5 个步骤
C.电子证据是计算机系统运行过程中产生的各种信息记录及存储的电子化资料及物品。对于电子证据，取证工作主要围绕两方面进行：证据的获取和证据的保护
D.计算机取证是使用先进的技术和工具，按照标准规程全面地检查计算机系统，以提取和保护有关计算机犯罪的相关证据的活动
答案：C
解析：对于电子证据，取证工作主要围绕两方面进行：证据的获取和证据的分析。P151 页。

34．为保障信息系统的安全，某经营公众服务系统的公司准备并编制一份针对性的信息安全保障方案，并将编制任务交给了小王，为此，小王决定首先编制出一份信息安全需求描述报告。关于此项工作，下面说法错误的是（）。
A.信息安全需求描述报告是设计和撰写信息安全保障方案的前提和依据
B.信息安全需求描述报告的主体内容可以按照技术、管理和工程等方面需求展开编写
C.信息安全需求描述报告应当基于信息安全风险评估结果和有关政策法规和标准的合规性要求得到
D.信息安全需求报告应依据该公众服务信息系统的功能设计方案为主要内容来撰写
答案：D
解析：信息安全需求报告不应依据该公众服务信息系统的功能设计方案为主要内容来撰写，而应该依据现有安全现状，痛点以及客户需求来写。
35．信息安全组织的管理涉及内部组织和外部各方两个控制目标。为了实现对组织内部信息安全的有效管理，应该实施常规的控制措施，不包括哪些选项（）
A.与特定利益集团的联系、信息安全的独立评审
B.信息处理设施的授权过程、保密性协议、与政府部门的联系
C.与外部各方相关风险的识别、处理外部各方协议中的安全问题
D.信息安全的管理承诺、信息安全协调、信息安全职责的分配
答案：C
解析：C 选项针对组织外部，与题干不符。

36．由于密码技术都依赖于密钥，因此密钥的安全管理是密码技术应用中非常重要的环节，下列关于密钥管理说法错误的是（）。

A.在保密通信过程中，通信双方也可利用 Diffie-Hellman 协议协商出会话密钥进行保密通信

B.科克霍夫在《军事密码学》中指出系统的保密性不依赖于对加密体制或算法的保密，而依赖于密钥

C.密钥管理需要在安全策略的指导下处理密钥生命周期的整个过程，包括产生、存储、备份、分配、更新、撤销等

D.在保密通信过程中，通信双方可以一直使用之前用过的会话密钥，不影响安全性

答案：D

解析：通信双方可以一直使用之前用过的会话密钥，会影响安全性

37．关于信息安全应急响应管理过程描述不正确的是（）。

A.应急响应方法和过程并不是唯一的

B.一种被广为接受的应急响应方法是将应急响应管理过程分为准备、检测、遏制、根除、恢复和跟踪总结 6 个阶段，这 6 个阶段的响应方法一定能确保事件处理的成功

C.一种被广为接受的应急响应方法是将应急响应管理过程分为准备、检测、遏制、根除、恢复和跟踪总结 6 个阶段

D.基于应急响应工作的特点和事件的不规则性，事先制定出事件应急响应方法和过程，有助于一个组织在事件发生时阻止混乱的发生或是在混乱状态中迅速恢复控制，将损失和负面影响降至最低

答案：B

解析：一定能确保事件处理成功，过于绝对。P152 页。

38．若一个组织声称自己的 ISMS 符合 ISO/IEC 27001 或 GB/T22080 标准要求，其信息安全控制措施通常需要在符合性方面实施常规控制。符合性常规控制这一领域不包括以下哪项控制目标（）

A.符合安全策略和标准以及技术符合性

B.访问控制的业务要求、用户访问管理

C.符合法律要求

D.信息系统审核考虑

答案：B

解析：访问控制的业务要求，用户访问管理不属于符合性常规控制。P127 页。

39．在信息系统中，访问控制是重要的安全功能之一。它的任务是在用户对系统资源提供最大限度共享的基础上，对用户的访问权限进行管理，防止对信息的非授权篡改和滥用。访问控制模型将实体划分为主体和客体两类，通过对主体身份的识别来限制其对客体的访问权限。下列选项中，对主体、客体和访问权限的描述中错误的是（）。

A.对目录的访问权限可分为读、写和拒绝访问

B.对文件进行操作的用户是一种主体

C.主体可以接收客体的信息和数据，也可以改变客体相关的信息

D.访问权限是指主体对客体所允许的操作

答案：A

解析：对目录的访问模式只有读和写。P305.

40. 根据《信息安全等级保护管理办法》、《关于开展信息安全等级保护测评体系建设试点工作的通知》（公信安[2009]812 号）、关于推动信息安全等级保护（）建设和开展（）工作的通知（公信安[2010]303 号）等文件，由公安部（）对等级保护测评机构管理，接受测评机构的申请、考核和定期（），对不具备能力的测评机构则（）。

A.测评体系；等级测评；等级保护评估中心；能力验证；取消授权

B.等级测评；测评体系；等级保护评估中心；能力验证；取消授权

C.测评体系；等级保护评估中心；能力验证；等级测评；取消授权

D.测评体系；等级保护评估中心；等级测评；能力验证；取消授权

答案：A

解析：

41. 某商贸公司信息安全管理员考虑到信息系统对业务影响越来越重要，计划编制本单位信息安全应急响应预案，在向主管领导写报告时，他列举了编制信息安全应急响应预案的好处和重要性，在他罗列的四条理由中，其中不适合作为理由的一条是（）

A.编制应急预案是国家网络安全法对所有单位的强制要求，因此必须建设

B.应急预案是保障单位业务系统信息安全的重要措施

C.应急预案是提高应对网络和信息系统突发事件能力，减少突发事件造成的损失和危害，保障信息系统运行平稳、安全、有序、高效的手段

D.应急预案是明确关键业务系统信息安全应急响应指挥体系和工作机制的重要方式

答案：A

解析：编制应急响应预案并非对所有单位的强制要求。P150。

42. 自主访问控制模型（DAC）的访问控制关系可以用访问控制表（ACL）来表示，该 ACL 利用在客体上附加一个主体明细表的方法来表示访问控制矩阵，通常使用由客体指向的链表来存储相关数据。下面选项中说法正确的是（）。

A.ACL 在删除用户时，去除该用户所有的访问权限比较方便

B.ACL 在增加客体时，增加相关的访问控制权限较为简单

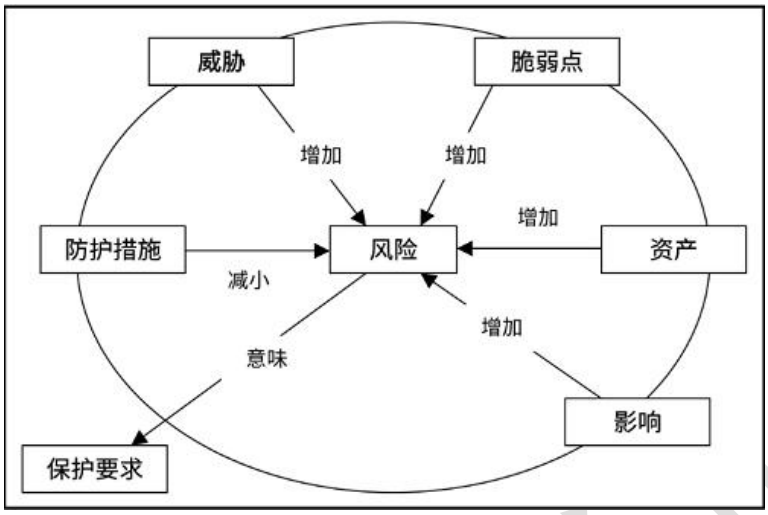
C.ACL 对于统计某个主体能访问哪些客体比较方便

D.ACL 是 Bell-LaPadula 模型的一种具体实现

答案：B

解析：

43. 风险，在 GB/T 22081 中定义为事态的概率及其结果的组合。风险的目标可能有很多不同的方面，如财务、健康和人身安全目标、信息安全目标和环境目标等；目标也可能有不同的级别，如战略目标、组织目标、项目目标、产品目标和过程目标等。ISO/IEC 13335-1 中揭示了风险各要素关系模型，如图所示。请结合此图，怎么才能降低风险对组织产生的影响？（）



A.组织应该根据风险建立相应的保护要求，通过构架防护措施降低风险对组织产生的影响

B.加强防护措施，降低风险

C.减少资产降低风险

D.减少威胁和脆弱点，降低风险

答案：A

解析：通过题干，是针对组织产生的影响，选 A，B 项不是所有的加强防护措施都可以降低风险，有时候接受风险，转移风险，规避风险都有可能使用；C 项不现实，威胁来自外部，不可控，很难减少，但可以通过减少脆弱性来减少风险。

44. Linux 系统的安全设置主要从磁盘分区、账户安全设置、禁用危险服务、远程登录安全、用户鉴别安全、审计策略、保护 root 账户、使用网络防火墙和文件权限操作共 10 个方面来完成。小张在学习了 Linux 系统安全的相关知识后，尝试为自己计算机上的 Linux 系统进行安全配置。下列选项是他的部分操作，其中不合理的是（）。

A.编辑文件/etc/pam.d/system-auth，设置 auth required pam_tally.so onerr=fail deny=6 unlock_time=300

B.编辑文件/etc/profile，设置 TMOUT=600

C.编辑文件/etc/passwd，检查文件中用户 ID，禁用所有 ID=0 的用户

D.编辑文件/etc/ssh/sshd_config，将 PermitRootLogin 设置为 no

答案：C

解析：ID 为 0 的用户为 root 用户，通常不使用 root 用户远程运维，但也不应本地禁用。

45. 金女士经常通过计算机在互联网上购物，从安全角度看，下面哪项是不好的操作习惯（）

A.使用专用上网购物用计算机，安装好软件后不要对该计算机上的系统软件、应用软件进行升级

B.为计算机安装具有良好声誉的安全防护软件，包括病毒查杀、安全检查和安全加固方面的软件

C.在 IE 的配置中，设置只能下载和安装经过签名的、安全的 ActiveX 控件

D.在使用网络浏览器时，设置不在计算机中保留网络历史记录和表单数据
答案：A
解析：安装好软件后应及时对该计算机上的系统软件、应用软件进行升级，以增加操作系统的安全性。

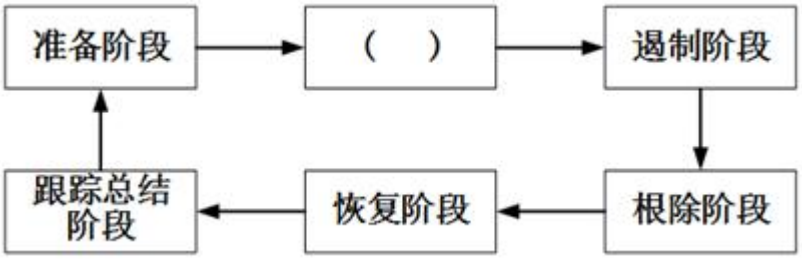
46．某社交网站的用户点击了该网站上的一个广告。该广告含有一个跨站脚本，会将他的浏览器定向到旅游网站，旅游网站则获得了他的社交网络信息。虽然该用户没有主动访问该旅游网站，但旅游网站已经截获了他的社交网络信息（还有他的好友们的信息），于是犯罪分子便可以躲藏在社交网站的广告后面，截获用户的个人信息了。这种向 Web 页面插入恶意 html 代码的攻击方式称为（）
A.SQL 注入攻击
B.缓冲区溢出攻击
C.分布式拒绝服务攻击
D.跨站脚本攻击
答案：D
解析：跨站脚本是由于网页支持脚本的执行，而程序员又没有对用户输入的数据进行严格控制，使得攻击者可以向 Web 页面插入恶意 HTML 代码，当用户浏览网页时，嵌入其中的 HTML 代码会被执行，从而实现攻击者的特殊目的。

47．王工是某单位的系统管理员，他在某次参加了单位组织的风险管理工作时，根据任务安排，他依据已有的资产列表，逐个分析可能危害这些资产的主体、动机、途径等多种因素，分析这些因素出现及造成损失的可能性大小，并为其赋值。请问，他这个工作属于下面哪一个阶段的工作（ ）
A.确认已有的安全措施并赋值
B.脆弱性识别并赋值
C.威胁识别并赋值
D.资产识别并赋值
答案：C
解析：依据资产列表逐个分析可能危害这些资产的主体、动机、途径等多种因素，分析这些因素出现及造成损失的可能性大小，并为其赋值，属于 C 威胁识别并赋值。

48．小王在学习定量风险评估方法后，决定试着为单位机房计算火灾的风险大小。假设单位机房的总价值为 400 万元人民币，暴露系数（Exposure Factor,EF）是 25%，年度发生率（Annualized Rate of Occurrence，ARO）为 0.2，那么小王计算的年度预期损失（Annualized Loss Expectancy，ALE）应该是（）。
A.100 万元人民币
B.180 万元人民币
C.400 万元人民币
D.20 万元人民币
答案：D
解析：年度预期损失=总价值*暴露系数*年度发生率即 400*25%*0.2=20 万元

49．为了能够合理、有序地处理安全事件，应事先制定出事件应急响应方法和过程，有助于一个组织在事件发生时阻止混乱的发生或是在混乱状态中迅速恢

复控制，将损失和负面影响降至最低。PDCERF 方法论是一种广泛使用的方法，其将应急响应分成六个阶段，如下图所示，请为图中括号空白处选择合适的内容（ ）。



A.检测阶段
B.培训阶段
C.文档阶段
D.报告阶段
答案：A
解析：一种被广为接受的应急响应方法是将应急响应管理过程分为 6 个阶段，为准备->检测->遏制->根除->恢复->跟踪总结。P152 页。

50. 以下关于灾难恢复和数据备份的理解，说法正确的是（）。
A.依据具备的灾难恢复资源程度的不同，灾难恢复能力分为 7 个等级
B.使用差分备份，数据恢复时只需最后一次的标准备份与差分备份，如果每天都有大量数据变化，差分备份工作非常费时
C.数据备份按数据类型划分可以划分为操作系统备份和数据库备份
D.增量备份是备份从上次完全备份后更新的全部数据文件
答案：B
解析：A 依据具备的灾难恢复资源程度的不同，灾难恢复能力分为 6 个等级；C：数据备份按数据类型划分可以划分为系统数据备份和业务数据备份；D 差分备份是备份从上次完全备份后更新的全部数据文件，D 选项说的是增量备份所以，D 错误了。

51. 与 PDR 模型相比，P2DR 模型则更强调（），即强调系统安全的（），并且以安全检测、（）和自适应填充“安全间隙”为循环来提高（）
A.漏洞监测：控制和对抗：动态性：网络安全
B.动态性：控制和对抗：漏洞监测：网络安全
C.控制和对抗：漏洞监测：动态性：网络安全
D.控制和对抗：动态性：漏洞监测：网络安全
答案：D
解析：P27 页

52. 若一个组织声称自己的 ISMS 符合 ISO / IEC 27001 或 GB / T 22080 标准要求，其信息安全控制措施通常需要在资产管理方面实施常规控制，资产管理包含对资产负责和信息分类两个控制目标，信息分类控制的目标是为了确保信息受到适当级别的保护，通常采取以上哪项控制措施（）
A.资产清单

B.资产责任人
C.资产的可接受使用
D.分类指南，信息的标记和处理
答案：D
解析：P109 页。

53．若一个组织声称自己的 ISMS 符合 ISO/IBC 27001 或 GB/T22080 标准要求，其信息安全控制措施通常在以下方面实施常规控制，不包括哪一项（）
A.信息安全方针、信息安全组织、资产管理
B.人力资源安全、物理和环境安全、通信和操作管理
C.访问控制、信息系统获取、开发和维护、符合性
D.规划与建立 ISMS
答案：D
解析：P103-128 页。

54．面对过国家秘密定级和范围的描述，哪项不符合《保密法》要求（）
A.国家秘密及其密级的具体范围，由国家保密工作部分分别会问外交、公安、国家安全和其他中央有关机关规定
B.各级国家机关、单位对所产生的国家秘密事项，应当按照国家秘密及其密级具体范围的规定确定密级
C.对是否属于国家秘密和属于何种密级不明确的事项，可由各单位自行参考国家要求确定和定级，然后报国家保密工作部分确定
D.对是否属于国家秘密和属于何种密级不明确的事项，由国家保密工作部分，省，自治区、直辖市的保密工作部门，省、自治区政府所在地的市和经国务院批准的较大的时的保密工作部分或者国家保密工作部门审定的机关确定
答案：C
解析：“可由各单位自行参考国家要求确定和定级”，应由由相应部门认定。

55．账号锁定策略中对超过一定次数的错误登录账号进行锁定是为了对抗以下哪种攻击?
A.分布式拒绝服务攻击(DDoS)
B.病毒传染
C.口令暴力破解
D.缓冲区溢出攻击
答案：C
解析：账号锁定是为了解决暴力破解攻击的。

56．在 ISO 的 OSI 安全体系结构中，以下哪一个安全机制可以提供抗抵赖安全服务?
A.加密
B.数字签名
C.访问控制
D.路由控制
答案：B

解析：数字签名可以提供抗抵赖、鉴别和完整性。

57．关于密钥管理，下列说法错误的是（）
A.科克霍夫原则指出算法的安全性不应基于算法的保密，而应基于密钥的安全性
B.保密通信过程，通信使用之前用过的会话密钥建立会话，不影响通信安全
C.密钥管理需要考虑密钥产生、存储、备份、分配、更新、撤销等生命周期过程的每一个环节
D.在网络通信中，通信双方可利用 Diffie-Hellman 协议协商出会话密钥
答案：B
解析：会话密钥不应重复使用，如果使用用过的会影响通信安全。

58．某单位在一次信息安全风险管理活动中，风险评估报告提出服务器 A 的 FTP 服务存在高风险漏洞，随后该单位在风险处理时选择了关闭 FTP 服务的处理措施，请问该措施属于哪种风险处理方式（）
A.风险降低
B.风险规避
C.风险转移
D.风险接受
答案：B
解析：关闭 FTP 服务属于风险规避

59．以下哪个不是导致地址解析协议(ARP)欺骗的根源之一?
A.ARP 协议是一个无状态的协议
B.为提高效率，ARP 信息在系统中会缓存
C.ARP 缓存是动态的，可被改写
D.ARP 协议是用于寻址的一个重要协议
答案：D
解析：D 不是导致欺骗的根源。

60．有关系统工程的特点，以下错误的是（）
A.系统工程研究问题一般采用先决定整体框架，后进入详细设计的程序
B.系统工程的基本特点，是需要把研究对象结构为多个组织部分分别独立研究
C.系统工程研究强调多学科协作，根据研究问题涉及到的学科和专业范围，组成一个知识结构合理的专家体系
D.系统工程研究是以系统思想为指导，采取的理论和方法是综合集成各学科、各领域的理论和方法
答案：B
解析：“分别独立研究”错误，系统工程的目的是实现总体效果最优，即从复杂问题的总体入手，认为总体大于各部分之和，各部分虽然存在不足，但总体可以优化。

61.Apache HIIP Server(简称 Apache)是一个开放源代码 Web 服务运行平台，在使用过程中，该软件默认会将自己的软件名和版本号发送给客户端。从安全角度出发，为隐藏这些信息，应当采取以下哪种措施（）

A.不选择 Windows 平台下安装使用
B.安装后，修改配置文件 http.cenf 中的有关参数
C.安装后，删除 Apache HTTP Server 源码
D.从正确的官方网站下载 Apache HTTP Server，并安装使用
答案：B
解析：修改配置参数是可行的。

62．按照我国信息安全等级保护的有关政策和标准，有些信息系统只需自主定级、自主保护，按照要求向公安机关备案即可，可以不需要上级或主管部门来测评和检查。此类信息系统应属于（）。
A.零级系统
B.一级系统
C.二级系统
D.三级系统
答案：B
解析：一级系统只需要自主定级备案，不需要测评。

63．在数据库安全性控制中，授权的数据对象( )，授权子系统就越灵活?
A.粒度越小
B.约束越细致
C.范围越大
D.约束范围大
答案：A
解析：数据粒度越细则授权策略越灵活便利。

64．TCP/IP 协议就 Internet 最基本的协议，也是 Internet 构成的基础，TCP/IP 通常被认为就是一个 N 层协议，每一层都使用它的下一层所提供的网络服务来完成自己的功能，这里 N 应等于（）
A.4
B.5
C.6
D.7
答案：A
解析：OSI 7 层和 TCP/IP 四层

65．下列我国哪一个政策性文件明确了我国信息安全保障工作的方针和总体要求以及加强信息安全保障工作的主要原则（）
A.《关于加强政府信息系统安全和保密管理工作的通知》
B.《中华人民共和国计算机信息系统安全保护条例》
C.《国家信息化领导小组关于加强信息安全保障工作的意见》
D.《关于开展信息安全风险评估工作的意见》
答案：C
解析：

66．信息安全风险管理过程中，背景建立是实施工作的第一步，下面哪项是错误的（）
A.背景建立的依据是国家，地区行业的相关政策、法律、法规和标准，以及机构的使命，信息系统的业务目标和特性
B.背景建立阶段应识别需要保护的资产、面临的威胁以及存在的脆弱性，并分别赋值，同时确认已有的安全措施，形成需要保护的资产清单
C.前景建立阶段应调查信息系统的业务目标、业务特性、管理特性和技术特性、形成信息系统的描述报告
D.背景建立阶段应分析信息系统的体系结构和关键要素，分析信息系统的安全环境和要求，形成信息系统的安全需求报告
答案：B
解析：P89

67．由于频繁出现计算机运行时被黑客远程攻击获取数据的现象，某软件公司准备加强软件安全开发管理，在下面做法中，对于解决问题没有直接帮助的是
A.要求所有的开发人员参加软件安全开发知识培训
B.要求增加软件源代码审核环节，加强对软件代码的安全性审查
C.要求统一采用 Windows8 系统进行开发，不能采用之前的 Windows 版本
D.要求邀请专业队伍进行第三方安全性测试，尽量从多角度发现软件安全问题
答案：C
解析：统一采用 Windows8 系统对软件安全无帮助。

68．随着计算机在商业和民用领域的应用，安全需求变得越来越多样化，自主访问控制和强制访问控制难以适应需求，基于角色的访问控制（RBAC）逐渐成为安全领域的一个研究热点。RBAC 模型可以分为 RBAC0、RBAC1、RBAC2 和 RBAC3 四种类型，它们之间存在相互包含关系。下列选项中，对它们之间的关系描述错误的是（）。
A.RBAC0 是基于模型，RBAC1、RBAC2 和 RBAC3 都包含 RBAC0
B.RBAC1 在 RBAC0 的基础上，加入了角色等级的概念
C.RBAC2 在 RBAC1 的基础上，加入了约束的概念
D.RBAC3 结合 RBAC1 和 RBAC2，同时具备角色等级和约束
答案：C
解析：RBAC2 在 RBAC0 的基础上，加入了约束的概念，P313 页

69．在软件保障成熟度模型（Software Assurnce Maturity Mode, SAMM）中，规定了软件开发过程中的核心业务功能，下列哪个选项不属于核心业务功能（）
A.管理，主要是管理软件开发的过程和活动
B.构造，主要是在开发项目中确定目标并开发软件的过程与活动
C.验证，主要是测试和验证软件的过程和活动
D.购置，主要是购买第三方商业软件或者采用开源组件的相关管理过程与活动
答案：D
解析：注意题干核心：软件开发过程中的核心业务功能

70. /etc/peddwd 文件是 UNIX/Linux 安全的关键是文件之一，该文件用于用户登录时校验用户的登录名、加密的口令数据项、用户 ID（UID）、默认的用户分组 ID（GID）、用户信息、用户登录目录以及登录后使用的 shell 程序。某黑客设法窃取了银行账户管理系统的 passwd 文件后，发现每个用户的加密口令数据项都是显示为“X”，下列选项中，对此现象的解释正确的是（）
A.黑客窃取的 passwd 文件是假的
B.用户的登录口令经过不可逆转的加密算法加密结果为“X”
C.加密口令被转移到了另一个文件里
D.这些账户都被禁用了
答案：C
解析：加密口令被转移到了/etc/shadow 文件里

71. 入侵检测系统有其技术优越性，但也有局限性，下列说法错误的是（ ）
A.对用户知识要求高，配置、操作和管理使用过于简单，容易遭到攻击
B.高虚频率，入侵检测系统会产生大量的警告信息和可疑的入侵行为记录，用户处理负担很重
C.入侵检测系统在应对自身攻击时，对其他数据的检测可能会被控制或者受到影响
D.警告消息记录如果不完整，可能无法与入侵行为关联
答案：A
解析：“配置、操作和管理使用过于简单，容易遭到攻击”错误。

72. 以下关于数字签名说法正确的是（ ）
A.数字签名是在所传输的数据后附加上一段和传输数据毫无关系的数字信息
B.数字签名能够解决数据的加密传输，即安全传输问题
C.数字签名一般采用对称加密机制
D.数字签名能够解决篡改、伪造等安全性问题
答案：D
解析：数字签名的作用就是“解决篡改、伪造等安全性问题”，A 项毫无关系是错误的，B 项数字签名的作用不是用来加密传输的，C 项数字签名一般采用非对称加密机制。

73. 下面关于信息系统安全保障模型的说法不正确的是：（ ）
A.国家标准《信息系统安全保障评估框架第一部分：简介和一般模型》(GB/T20274. 1-2006)中的信息系统安全保障模型将风险和策略作为基础和核心
B.模型中的信息系统生命周期模型是抽象的概念性说明模型，在信息系统安全保障具体操作时，可根据具体环境和要求进行改动和细化
C.信息系统安全保障强调的是动态持续性的长效安全，而不仅是某时间点下的安全
D.信息系统安全保障主要是确保信息系统的保密性、完整性和可用性，单位对信息系统运行维护和使用的人员在能力和培训方面不需要投入
答案(d)
解析：“单位对信息系统运行维护和使用的人员在能力和培训方面不需要投入”错误。

74．有关能力成熟度模型（CMM），错误的理解是（ ）。
A.CMM 的基本思想是，因为问题是由技术落后引起的，所以新技术的运用会在一定程度上提高质量、生产率和利润率
B.CMM 是思想来源于项目管理和质量管理
C.CMM 是一种衡量工程实施能力的方法，是一种面向工程过程的方法
D.CMM 是建立在统计过程控制理论基础上的，它基于这样一个假设，即“生产过程的高质量和在过程中组织实施的成熟性可以低成本的生产出高质量产品
答案：A
解析：P178

75．关于对信息安全事件进行分类分级管理的原因描述不正确的是（）
A.信息安全事件的种类很多，严重程度不尽相同，其响应和处理方法也应各不相同
B.信息安全事件实行分类和分级管理，是有效防范和响应信息安全事件的基础
C.能够使事前准备，事中应对和事后处理的各项相关工作更具针对性和有效性
D.我国早期的计算机安全事件的应急响应工作主要包括计算机病毒防范和“千年虫”问题的解决，关于网络安全应急响应的起步最早。
答案：D
解析：D 项不是信息安全事件进行分类分级管理的原因，P146 页。

76．数字签名不能实现的安全特性为（ ）
A.防抵赖
B.防伪造
C.防冒充
D.保密通信
答案：D
解析：数字签名的作用不在于保密通信。

77．由于信息系统的复杂性，因此需要一个通用的框架对其进行解构和描述，然后再基于此框架讨论信息系统的（）。在 IATF 中，将信息系统的信息安全保障技术层面分为以下四个焦点领域：（ ）：区域边界即本地计算环境的外缘；( )；支持性基础设施，在深度防御技术方案中推荐（ ）原则、（ ）原则。
A.网络和基础设施；安全保护问题；本地的计算机环境；多点防御；分层防御
B.安全保护问题；本地的计算机环境；多点防御；网络和基础设施；分层防御
C.安全保护问题；本地的计算机环境；网络和基础设施；多点防御；分层防御
D.本地的计算环境；安全保护问题；网络和基础设施；多点防御；分层防御
答案：C
解析：参考 P29 页，IATF 4 个焦点领域。

78．针对软件的拒绝服务攻击是通过消耗系统资源使软件无法响应正常请求的一种攻击方式，在软件开发时分析拒绝服务攻击的威胁，以下哪个不是需要考虑的攻击方式（ ）

A.攻击者利用软件存在的逻辑错误，通过发送某种类型数据导致运算进入死循环，CPU 资源占用始终 100%
B.攻击者利用软件脚本使用多重嵌套咨询，在数据量大时会导致查询效率低，通过发送大量的查询导致数据库响应缓慢
C.攻击者利用软件不自动释放连接的问题，通过发送大量连接消耗软件并发连接数，导致并发连接数耗尽而无法访问
D.攻击者买通 IDC 人员，将某软件运行服务器的网线拔掉导致无法访问
答案：D
解析：ABC 都是从软件领域考虑解决，D 项一般不是拒绝服务攻击采用的方式。

79．随着即时通讯软件的普及使用，即时通讯软件也被恶意代码利用进行传播，以下哪项功能不是恶意代码利用即时通讯进行传播的方式（ ）
A.利用即时通讯软件的文件传送功能发送带恶意代码的可执行文件
B.利用即时通讯软件发送指向恶意网页的 URL
C.利用即时通讯软件发送指向恶意地址的二维码
D.利用即时通讯发送携带恶意代码的 txt 文档
答案：D
解析：D 项 txt 文档不可被执行，所以不是可被利用的传播方式。

80．某单位需要开发一个网站，为了确保开发出安全的软件。软件开发商进行了 OA 系统的威胁建模，根据威胁建模，SQL 注入是网站系统面临的攻击威胁之一， 根据威胁建模的消减威胁的做法。以下哪个属于修改设计消除威胁的做法（ ）
A.在编码阶段程序员进行培训，避免程序员写出存在漏洞的代码
B.对代码进行严格检查，避免存在 SQL 注入漏洞的脚本被发布
C.使用静态发布，所有面向用户发布的数据都使用静态页面
D.在网站中部署防 SQL 注入脚本，对所有用户提交数据进行过滤
答案：C
解析：A 项是加强安全培训，B 和 D 是进行安全加固，只有 C 是修改了设计。

81．某企业内网中感染了一种依靠移动存储进行传播的特洛伊木马病毒，由于企业部署的杀毒软件，为了解决该病毒在企业内部传播，作为信息化负责人，你应采取以下哪项策略()
A.更换企业内部杀毒软件，选择一个可以查杀到该病毒的软件进行重新部署
B.向企业内部的计算机下发策略，关闭系统默认开启的自动播放功能
C.禁止在企业内部使用如 U 盘、移动硬盘这类的移动存储介质
D.在互联网出口部署防病毒网关，防止来自互联网的病毒进入企业内部
答案：B
解析：“关闭系统默认开启的自动播放功能”可以防止移动存储介质插入电脑后自动打开，导致病毒被执行。

82．安全漏洞产生的原因不包括以下哪一点()
A.软件系统代码的复杂性
B.软件系统市场出现信息不对称现象

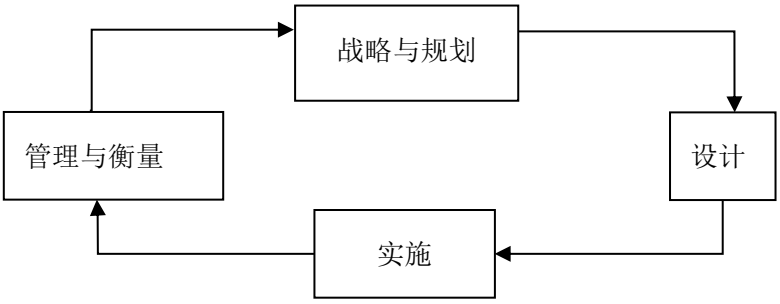
C.复杂异构的网络环境
D.攻击者的恶意利用
答案：D
解析：攻击者的恶意利用是安全漏洞产生导致的结果。

83．某 IT 公司针对信息安全事件已经建立了完善的预案，在年度企业信息安全总结会上，信息安全管理员对今年应急预案工作做出了四个总结，其中有一项总结工作是错误，作为企业的 CSO，请你指出存在问题的是哪个总结？（）
A.公司自身拥有优秀的技术人员，系统也是自己开发的，无需进行应急演练工作，因此今年的仅制定了应急演练相关流程及文档，为了不影响业务，应急演练工作不举行
B.公司制定的应急演练流程包括应急事件通报、确定应急事件优先级应急响应启动实施、应急响应时间后期运维、更新现在应急预案五个阶段，流程完善可用
C.公司应急预案包括了基本环境类、业务系统、安全事件类、安全事件类和其他类，基本覆盖了各类应急事件类型
D.公司应急预案对事件分类依据 GB/Z 20986 - 2007《信息安全技术信息安全事件分类分级指南》，分为 7 个基本类别，预案符合国家相关标准
答案：A
解析：“无需进行应急演练工作”错误

84．某软件在设计时，有三种用户访问模式，分别是仅管理员可访问、所有合法用户可访问和允许匿名访问)采用这三种访问模式时，攻击面最高的是()。
A.仅管理员可访问
B.所有合法用户可访问
C.允许匿名
D.三种方式一样
答案：C
解析：D 项是干扰项，D 项的意思是三种方式攻击面一样。

85．某政府机构委托开发商开发了一个 OA 系统。其中公交分发功能使用了 FTP 协议，该系统运行过程中被攻击者通过 FTP 对 OA 系统中的脚本文件进行了篡改，安全专家提出使用 Http 下载代替 FTP 功能以解决以上问题，该安全问题的产生主要是在哪个阶段产生的()
A.程序员在进行安全需求分析时，没有分析出 OA 系统开发的安全需求
B.程序员在软件设计时，没遵循降低攻击面的原则，设计了不安全的功能
C.程序员在软件编码时，缺乏足够的经验，编写了不安全的代码
D.程序员在进行软件测试时，没有针对软件安全需求进行安全测试
答案：B
解析：FTP 功能本身没有问题，但是不太安全容易被攻击，所以选 B。

86.从 SABSA 的发展过程，可以看出整个 SABSA 在安全架构中的生命周期（如下图所示），在此 SABSA 生命周期中，前两个阶段的过程被归类为所谓的（ ），其次是（ ），它包含了建筑设计中的（ ）、物理设计、组件设计和服务管理设计，再者就是（ ），紧随其后的则是（ ）



A.设计；战略与规划；逻辑设计；实施；管理与衡量
B. 战略与规划；逻辑设计；设计；实施；管理与衡量
C. 战略与规划；实施；设计；逻辑设计；管理与衡量
D.战略与规划；设计；逻辑设计；实施；管理与衡量
答案：D
解析：P42

87. 在 Linux 系统中，下列哪项内容不包含在/etc/passwd 文件中（）
A.用户名
B.用户口令明文
C.用户主目录
D.用户登录后使用的 SHELL
答案：B
解析：在 Linux，操作系统中，用户口令是通过哈希后保存在/etc/shadow 文件中的

88. 某攻击者想通过远程控制软件潜伏在某监控方的 UNIX 系统的计算机中，如果攻击者打算长时间地远程监控某服务器上的存储的敏感数据，必须要能够清除在监控方计算机中存在的系统日志。否则当监控方查看自己的系统日志的时候，就会发现被监控以及访向的痕迹。不属于清除痕迹的方法是()。
A.窃取 root 权限修改 wtmp/wtmpx、utmp/utmpx 和 lastlog 三个主要日志文件
B.采用干扰手段影响系统防火墙的审计功能
C.保留攻击时产生的临时文件
D.修改登录日志，伪造成功的登录日志，增加审计难度
答案：C
解析：C 属于痕迹留存。

89. 某软件公司准备提高其开发软件的安全性，在公司内部发起了有关软件开发生命周期的讨论，在下面的发言观点中，正确的是（）
A.软件安全开发生命周期较长，而其中最重要的是要在软件的编码安全措施，就可以解决 90%以上的安全问题。
B.应当尽早在软件开发的需求和设计阶段增加一定的安全措施，这样可以比在软件发布以后进行漏洞修复所花的代价少得多。
C.和传统的软件开发阶段相比，微软提出的安全开发生命周期（SDL)最大特点是增加了一个专门的安全编码阶段

D.软件的安全测试也很重要，考试到程序员的专业性，如果该开发人员已经对软件进行了安全性测试，就没有必要再组织第三方进行安全性测试。
答案：B
解析：A-现代软件工程体系中软件最重要的阶段为设计阶段。C-SDL 最大的特点是增加了安全培训和应急响应。D-第三方测试是必要的软件安全测试类型。

90．小牛在对某公司的信息系统进行风险评估后，因考虑到该业务系统中部分涉及金融交易的功能模块风险太高，他建议该公司以放弃这个功能模块的方式来处理风险，请问这种风险处置的方法是（）
A.降低风险
B.规避风险
C.放弃风险
D.转移风险
答案：B
解析：放弃高风险模块的功能，属于风险规避。

91．以下哪个组织所属的行业的信息系统不属于关键信息基础设施？
A.人民解放军战略支援部队
B.中国移动吉林公司
C.重庆市公安局消防总队
D.上海市卫生与计划生育委员会
答案：D
解析：关键信息基础:面向公众提供网络信息服务或支撑能源、通信、金融、交通、公用事业等重要行业运行的信息系统或工业控制系统;且这些系统一旦发生网络安全事故，会影响重要行业正常运行，对国家政治、经济、科技、社会、文化、国防、环境以及人民生命财产造成严重损失 。

92．信息安全管理体系 ISMS 是建立和维持信息安全管理体系的（），标准要求组织通过确定信息安全管理系统范围、制定（）、明确定管理职责、以风险评估为基础选择控制目标与控制方式等活动建立信息安全管理体系；体系一旦建立组织应按体系规定的要求进行运作，保持体系运作的有效性；信息安全管理体系应形成一定的（），即组织应建立并保持一个文件化的信息安全（），其中应阐述被保护的资产、组织安全管理体系应形成一定的（）
A.信息安全方针；标准；文件；管理体系；保证程度
B.标准；文件；信息安全方针；管理体系；保证程度
C.标准；信息安全方针；文件；管理体系；保证程度
D.标准；管理体系；信息安全方针；文件；保证程度
答案：C
解析：

93．目前应用面临的威胁越来越多，越来越难发现。对应用系统潜在的威胁目前还没有统一的分类，但小赵认为同事小李从对应用系统的攻击手段角度出发所列出的四项例子中有一项不对，请问是下面哪一项（）
A.数据访问权限

B.伪造身份
C.钓鱼攻击
D.远程渗透
答案：A
解析：BCD 都是常见的威胁方式，A 项至少一种数据访问控制方式。

94．某单位在进行内部安全评估时，安全员小张使用了单位采购的漏洞扫描软件进行单位内的信息系统漏洞扫描。漏洞扫描报告的结论为信息系统基本不存在明显的安全漏洞，然而此报告在内部审计时被质疑，原因在于小张使用的漏洞扫描软件采购于三年前，服务已经过期，漏洞库是半年前最后一次更新的。关于内部审计人员对这份报告的说法正确的是（）
A.内部审计人员的质疑是对的，由于没有更新漏洞库，因此这份漏洞扫描报告准确性无法保证
B.内部审计人员质疑是错的，漏洞扫描软件是正版采购，因此扫描结果是准确的
C.内部审计人员的质疑是正确的，因为漏洞扫描报告是软件提供，没有经过人为分析，因此结论不会准确
D.内部审计人员的质疑是错误的，漏洞软件是由专业的安全人员操作的，因此扫描结果是准确的
答案：A
解析：漏洞库半年不更新又可能会漏报一些最新的漏洞。

95．为了防止授权用户不会对数据进行未经授权的修改，需要实施对数据的完整性保护，下列哪一项最好地描述了星或（•-）完整性原则？（）
A.Bell-LaPadula 模型中的不允许向下写
B.Bell-LaPadula 模型中的不允许向上读
C.Biba 模型中的不允许向上写
D.Biba 模型中的不允许向下读
答案：C
解析：BLP 模型保障机密性，上写下读，Biba 模型保障完整性，上读下写，C 向上写会破坏完整性。

96．组织应定期监控、审查、审计（）服务，确保协议中的信息安全条款和条件被遵守，信息安全事件和问题得到妥善管理。应将管理供应商关系的责任分配给指定的个人或（）团队。另外，组织应确保落实供应商符合性审查和相关协议要求强制执行的责任。应保存足够的技术技能和资源的可用性以监视协议要求尤其是（）要求的实现。当发现服务交付的不足时，宜采取（）.当供应商提供的服务，包括对（）方针、规程和控制措施的维持和改进等发生变更时，应在考虑到其对业务信息、系统、过程的重要性和重新评估风险的基础上管理。
A.供应商；服务管理；信息安全；合适的措施；信息安全
B.服务管理；供应商；信息安全；合适的措施；信息安全
C.供应商；信息安全；服务管理；合适的措施；信息安全
D.供应商；合适的措施；服务管理；信息安全；信息安全
答案：A
解析：P124

97．火灾是机房日常运营中面临最多的安全威胁之一，火灾防护的工作是通过构建火灾预防、检测和响应系统，保护信息化相关人员和信息系统，将火灾导致的影响降低到可接受的程度。下列选项中，对火灾的预防、检测和抑制的措施描述错误的选项是（）。
A.将机房单独设置防火区，选址时远离易燃易爆物品存放区域，机房外墙使用非燃烧材料，进出机房区域的门采用防火门或防火卷帘，机房通风管设防火栓
B.火灾探测器的具体实现方式包括；烟雾检测、温度检测、火焰检测、可燃气体检测及多种检测复合等
C.自动响应的火灾抑制系统应考虑同时设立两组独立的火灾探测器，只要有一个探测器报警，就立即启动灭火工作
D.前在机房中使用较多的气体灭火剂有二氧化碳、七氟丙烷、三氟甲烷等
答案：C
解析：自动相应一般多个探测器报警才会启动灭火工作，单个报警器报警容易误报。

98．信息安全管理体系也采用了（） 模型，该模型可应用于所有的（）。ISMS 把相关方的信息安全要求和期望作为输入，并通过必要的()，产生满足这些要求和期望的（）。
A.ISMS；PDCA 过程；行动和过程；信息安全结果
B.PDCA;ISMS 过程；行动和过程；信息安全结果
C.ISMS;PDCA 过程；信息安全结果；行动和过程
D.PDCA;ISMS 过程；信息安全结果；行动和过程
答案：B
解析：

99．小王学习了灾备备份的有关知识，了解到常用的数据备份方式包括完全备份、增量备份、差量备份，为了巩固所学知识，小王对这三种备份方式进行对比，其中在数据恢复速度方面三种备份方式由快到慢的顺序是（）
A.完全备份、增量备份、差量备份
B.完全备份、差量备份、增量备份
C.增量备份、差量备份、完全备份
D.差量备份、增量备份、完全备份
答案：B
解析：全部备份是对整个系统所有文件进行完全备份，包括所有系统和数据；增量备份是每次备份的数据相当于上一次备份后增加和修改过的数据；差分备份是每次备份的数据是相对于上一次全备份之后新增加和修改过的数据。所以单独就该题来说，如果采用的是完全备份方式，数据丢失后只需要恢复最近的一次完全备份的数据；如果采用的是差分备份方式，则需要恢复最近一次完全备份的数据和最近一次差分备份的数据；如果采用的是增量备份方式，则需要恢复最近一次完全备份的数据，以及后面一次次增量备份的数据。所以对比起来，完全备份方式恢复起来最快，增量最慢。

100．风险评估文档是指在整个风险评估过程中产生的评估过程文档和评估结果文档，其中，明确评估的目的、职责、过程、相关的文档要求，以及实施本次评估所需要的各种资产、威胁、脆弱性识别和判断依据的文档是（）
A.《风险评估方案》
B.《风险评估程序》
C. 《资产识别清单》
D.《风险评估报告》
答案：B
解析：P260 页

练习题第二卷

101．等级保护实施根据 GB/T 25058-2010 《信息安全技术 信息系统安全等级保护实施指南》分为五大阶段；（）、总体规划、设计实施、（）和系统终止。但由于在开展等级保护试点工作时，大量信息系统已经建设完成，因此根据实际情况逐步形成了（）、备案、差距分析（也叫差距测评）、建设整改、验收测评、定期复查为流程的（）工作流程。和《等级保护实施指南》中规定的针对（）的五大阶段略有差异。
A.运行维护；定级；定级；等级保护；信息系统生命周期
B.定级；运行维护；定级；等级保护；信息系统生命周期
C.定级运行维护；等级保护；定级；信息系统生命周期
D.定级；信息系统生命周期；运行维护；定级；等级保护
答案：B
解析：P76 页
以过程管理方法进行的系统管理。P177 页

102．信息可以以多种形式存在。它可以打印写在纸上、以（ ）、用邮寄或电子手段传递、呈现在 信息可以以多种形式存在。它可以打印写在纸上、以（ ）、用邮寄或电子手段传递、呈现在片上使用是（ ）。无论信息以什么形式存在，用哪种方法存储或共享，都宜对它进行适当的保护。（）是保护信息受各种威胁的损害，以确保业务（ ），业务风险最小化，投资回报和（ ）。
A.语言表达；电子方式存储；信息安全；连续性；商业机遇最大化
B.电子方式存储；语言表达；连续性；信息安全；商业机遇最大化
C.电子方式存储；连续性；语言表达；信息安全；商业机遇最大化
D.电子方式存储；语言表达；信息安全；连续性；商业机遇最大化
答案：D
解析：

103．以下哪个现象较好的印证了信息安全特征中的动态性( )
A.经过数十年的发展，互联网上已经接入了数亿台各种电子设备

B.刚刚经过风险评估并针对风险采取处理措施后仅一周，新的系统漏洞使得信息系统面临新的风险
C.某公司的信息系统面临了来自美国的“匿名者”黑客组织的攻击
D.某公司尽管部署了防火墙、防病毒等安全产品，但服务器中数据仍然产生了泄露
答案：B
解析：B 体现出了动态性

104．有关质量管理，错误的理解是（　）。
A.质量管理是与指挥和控制组织质量相关的一系列相互协调的活动，是为了实现质量目标，而进行的所有管理性质的活动
B.规范质量管理体系相关活动的标准是 ISO 9000 系列标准
C.质量管理体系将资源与结果结合，以结果管理方法进行系统的管理
D.质量管理体系从机构，程序、过程和总结四个方面进行规范来提升质量
答案：C
解析：质量管理体系是组织内部建立的、为实现质量目标所必需的系统性质量管理模式，是组织的一项战略决策。它将资源与过程结合，P177 页

105．ISO2007：2013《信息技术-安全技术-信息安全管理体系-要求》为在组织内为建立、实施、保持和不断改进（）制定了要求。ISO27001 标准的前身为（）的 BS7799 标准，该标准于 1993 年由（）立项，于 1995 年英国首次出版 BS7799-1：1995《信息安全管理实施细则》，它提供了一套综合的、由信息安全最佳惯例组成的（），其目的是作为确定工商业信息系统在大多数情况所需控制范围的唯一（），并且适用大、中、小组织。
A.ISMS；德国；德国贸易工业部；实施规则；参考基准
B.ISMS；法国；法国贸易工业部；实施规则；参考基准
C.ISMS；英国；英国贸易工业部；实施规则；参考基准
D.ISMS；德国；德国贸易工业部；参考基准；实施规则
答案：C
解析：

106．老王是一名企业信息化负责人，由于企业员工在浏览网页时总导致病毒感染系统，为了解决这一问题，老王要求信息安全员给出解决措施，信息安全员给出了四条措施建议，老王根据多年的信息安全管理经验，认为其中一条不太适合推广，你认为是哪条措施（）
A.采购防病毒网关并部署在企业互联网出口中，实现对所有浏览网页进行检测，阻止网页中的病毒进入内网
B.组织对员工进行一次上网行为安全培训，提高企业员工在互联网浏览时的安全意识
C.采购并统一部署企业防病毒软件，信息化管理部门统一进行病毒库升级，确保每台计算机都具备有效的病毒检测和查杀能力
D.制定制度禁止使用微软的 IE 浏览器上网，统一要求使用 Chrome 浏览器
答案：D
解析：更换浏览器并不能防范病毒感染系统，而且很多软件和应用与微软 IE 浏览器做了适配，强制更换 Chrome 浏览器不适合推广。

107．若一个组织声称自己的 ISMS 符合 ISO/IEC 27001 或 GB/T22080 标准要求，其信息安全控制措施通常在以下方面实施常规控制，以下哪个选项的内容不属于常规控制措施的范围（）

A.安全事件管理、供应商关系、业务安全性审计

B.信息安全方针、信息安全组织、资产管理

C.安全采购、开发与维护、合规性

D.人力资源安全、物理和环境安全、通信安全

答案：A

解析：ISO27001 信息安全管理体系包含了 14 个控制域详见 P103 页，没有业务安全性审计

108．保护-检测-响应（Protection-Detection-Response，PDR）模型是（）工作中常用的模型，其思想是承认（）中漏洞的存在，正视系统面临的（），通过采取适度防护、加强（）、落实对安全事件的响应、建立对威胁的防护来保障系统的安全。

A.信息系统；信息安全保障；威胁；检测工作

B.信息安全保障；威胁；信息系统；检测工作

C.信息安全保障；信息系统；威胁；检测工作

D.信息安全保障；信息系统；检测工作；威胁

答案：C

解析：保护-检测-响应（Protection-Detection-Response，PDR）模型是信息安全保障工作中常用的模型，其思想是承认信息系统中漏洞的存在，正视系统面临的威胁，通过采取适度防护、加强检测工作、落实对安全事件的响应、建立对威胁的防护来保障系统的安全。P25 页。

109．以下关于信息安全工程说法正确的是（）。

A.信息化建设可以先实施系统，而后对系统进行安全加固

B.信息化建设中系统功能的实现是最重要的

C.信息化建设没有必要涉及信息安全建设

D.信息化建设中在规划阶段合理规划信息安全，在建设阶段要同步实施信息安全建设

答案：D

解析：同步规划，同步实施

110．小李在检查公司对外服务网站的源代码时，发现程序在发生诸如没有找到资源、数据库连接错误、写临时文件错误等问题时，会将详细的错误原因在结果页面上显示出来。从安全角度考虑，小李决定修改代码，将详细的错误原因都隐藏起来，在页面上仅仅告知用户“抱歉，发生内部错误！”。请问，这种处理方法的主要目的是（）。

A.最小化反馈信息

B.安全处理系统异常

C.安全使用临时文件

D.避免缓冲区溢出

答案：A

解析：最小化反馈是指在程序内部处理时，尽量将少的信息反馈到运行界面，即避免给予不可靠用户过多信息，防止不可靠用户据此猜测软件程序的运行处理机制。P413 页。

111．恢复时间目标（Recovery Time Objective ，RTO）和恢复点目标（Recovery Point Objective，RPO）是业务连续性和灾难恢复工作中的两个重要指标，随着信息系统越来越重

要和信息技术越来越先进，这两个指标的数值越来越小。小华准备为其工作的信息系统拟定RTO 和 RPO 指标，则以下描述中，正确的是（ ）。

A.RTO 不可以为 0，RPO 也不可以为 0

B.RTO 可以为 0，RPO 也可以为 0

C.RTO 可以为 0，RPO 不可以为 0

D.RTO 不可以为 0，RPO 可以为 0

答案：B

解析：RPO 和 RTO 两个指标从不用的角度来反映灾难备份和恢复的能力，RTO 和 RPO 都为 0 是最完美的解决方案，因为在两个值都为 0 的情况下，意味着系统永不中断服务，而且完全没有数据丢失。P156 页。

112．部署互联网协议安全虚拟专用网（Internet Protocol Security Virtual Private Network，IPsec VPN）时，以下说法正确的是（）。

A.部署 IPsec VPN 网络时，需要考虑 IP 地址的规划，尽量在分支节点使用可以聚合的 IP 地址段，来减少 IPsec 安全关联（Security Authentication，SA）资源的消耗

B.配置 AES 算法可以提供可靠的数据完整性验证

C.配置 MD5 安全算法可以提供可靠地数据加密

D.报文验证头协议（Authentication Header，AH）可以提供数据机密性

答案：A

解析：MD5 是单向函数提供数据完整性验证，AES 是数据加密算法提供数据机密性保护，AH 提供身份验证和数据完整性保护。

113．某网络安全公司基于网络的实时入侵检测技术，动态监测来自于外部网络和内部网络的所有访问行为。当检测到来自内外网络针对或通过防火墙的攻击行为，会及时响应，并通知防火墙实时阻断攻击源，从而进一步提高了系统的抗攻击能力，更有效地保护了网络资源，提高了防御体系级别。但入侵检测技术不能实现以下哪种功能（）。

A.防止 IP 地址欺骗

B.核查系统的配置漏洞，评估系统关键资源和数据文件的完整性

C.识别违反安全策略的用户活动

D.检测并分析用户和系统的活动

答案：A

解析：入侵检测技术不包含防 IP 地址欺骗。

114．某 IT 公司针对信息安全事件已经建立了完善的预案，在年度企业信息安全总结会上，信息安全管理员对今年应急预案工作做出了四个总结，其中有一项总结工作是错误，作为企业的 CSO，请你指出存在问题的是哪个总结？（）

A.公司成立了信息安全应急响应组织，该组织由业务和技术人员组成，划分成应急响应领导小组、技术保障小组、专家小组、实施小组和日常运行小组

B.公司应急预案包括了基础环境类、业务系统类、安全事件类和其他类，基本覆盖了各类应急事件类型

C.公司制定的应急演练流程包括应急事件通报、确定应急事件优先级、应急响应启动实施、应急响应时间后期运维、更新现有应急预案五个阶段，流程完善可用

D.公司应急预案对事件分类依据 GB/Z 20986-2007《信息安全技术信息安全事件分类分级指南》，分为 7 个基本类别，预案符合国家相关标准

答案：C
解析：“后期运维、更新现有应急预案”不属于应急演练流程里面的内容。

115．目前，信息系统面临外部攻击者的恶意攻击威胁，从威胁能力和掌握资源分，这些威胁可以按照个人威胁、组织威胁和国家威胁三个层面划分，则下面选项中属于组织威胁的是（）。

A.喜欢恶作剧、实现自我挑战的娱乐型黑客

B.巩固战略优势，执行军事任务、进行目标破坏的信息作战部队

C.实施犯罪、获取非法经济利益网络犯罪团伙

D.搜集政治、军事、经济等情报信息的情报机构

答案：C

解析：A 属于个人威胁；B 和 D 属于国家威胁。

116．以下关于网络安全设备说法正确的是（）。

A.入侵检测系统的主要作用是发现并报告系统中未授权或违反安全策略的行为

B.安全隔离与信息交换系统也称为网闸，需要信息交换时，同一时间可以和两个不同安全级别的网络连接

C.虚拟专用网是在公共网络中，利用隧道技术，建立一个永久、安全的通信网络

D.防火墙既能实现内外网物理隔离，又能实现内外网逻辑隔离

答案：A

解析：B 在需要信息交换时，安全隔离与信息交换系统内部隔离安全交换单元模拟形成开关，同一时间只和一个网络进行连接，不会同时连接两个网络；C 虚拟专用网是在公共网络中，利用隧道技术，建立一个临时的、安全的网络；D 防火墙不能实现内外网物理隔离。

117．为了保障系统安全，某单位需要对其跨地区大型网络实时应用系统进行渗透测试，以下关于渗透测试过程的说法不正确的是（）。

A.由于在实际渗透测试过程中存在不可预知的风险，所以测试前要提醒用户进行系统和数据备份，以便出现问题时可以及时恢复系统和数据

B.为了深入发掘该系统存在的安全威胁，应该在系统正常业务运行高峰期进行渗透测试

C.渗透测试从“逆向”的角度出发，测试软件系统的安全性，其价值在于可以测试软件在实际系统中运行时的安全状况

D.渗透测试应当经过方案制定、信息收集、漏洞利用、完成渗透测试报告等步骤

答案：B

解析：在正常业务运行高峰期进行渗透测试可能会影响系统正常运行。

118．操作系统用于管理计算机资源，控制整个系统运行，是计算机软件的基础。操作系统安全是计算、网络及信息系统安全的基础。一般操作系统都提供了相应的安全配置接口。小王新买了一台计算机，开机后首先对自带的 Windows 操作系统进行配置。他的主要操作有：（1）关闭不必要的服务和端口；（2）在“本地安全策略”中配置账号策略、本地策略、公钥策略和 IP 安全策略；（3）备份敏感文件，禁止建立空连接，下载最新补丁；（4）关闭审核策略，开启口令策略，开启账户策略。这些操作中错误的是（）。

A.操作（1），应该关闭不必要的服务和所有端口

B.操作（4），应该开启审核策略

C.操作（3），备份敏感文件会导致这些文件遭到窃取的几率增加

D.操作（2），在“本地安全策略”中不应该配置公钥策略，而应该配置私钥策略

答案：B

解析：操作（4），应该开启审核策略。

119．关于信息安全管理体系的作用，下面理解错误的是（）。

A.对内而言，是一个光花钱不挣钱的事情，需要组织通过其他方面收入来弥补投入

B.对外而言，能起到规范外包工作流程和要求，帮助界定双方各自信息安全责任

C.对外而言，有助于使各利益相关方对组织充满信心

D.对内而言，有助于建立起文档化的信息安全管理规范，实现有“法”可依，有章可循，有据可查

答案：A

解析：“光花钱不挣钱的事情”错误

120．王工是某单位的系统管理员，他在某次参加了单位组织的风险管理工作时，发现当前案例中共有两个重要资产：资产 A1 和资产 A2 ；其中资产 A1 面临两个主要威胁：威胁 T1 和威胁 T2；而资产 A2 面临一个主要威胁：威胁 T3；威胁 T1 可以利用的资产 A1 存在的两个脆弱性：脆弱性 V1 和脆弱性 V2；威胁 T2 可以利用的资产 A1 存在的三个脆弱性，脆弱性 V3、脆弱性 V4 和脆弱性 V5；威胁 T3 可以利用的资产 A2 存在的两个脆弱性：脆弱性 V6 和脆弱性 V7。根据上述条件，请问：使用相乘法时，应该为资产 A1 计算几个风险值（ ）。

A.3

B.6

C.5

D.2

答案：C

解析：威胁利用脆弱性产生风险，相乘是指 2*1+3*1=5。

· 对威胁 T1：2 个脆弱性 →2 个风险值（T1×V1，T1×V2）

· 对威胁 T2：3 个脆弱性 →3 个风险值（T2×V3，T2×V4，T2×V5

121．在国家标准 GB/T 20274.1-2006《信息安全技术信息系统安全保障评估框架第一部分：简介和一般模型》中，信息系统安全保障模型包含哪几个方面？（）

A.保障要素、生命周期和运行维护

B.保障要素、生命周期和安全特征

C.规划组织、生命周期和安全特征

D.规划组织、生命周期和运行维护

答案：B

解析：在国家标准 GB/T 20274.1-2006《信息安全技术信息系统安全保障评估框架第一部分：简介和一般模型》中，信息系统安全保障模型包含保障要素、生命周期和安全特征 3 方面。P35 页。

122．北京某公司利用 SSE-CMM 对其自身工程队伍能力进行自我改善，其理解正确的是（）。

A.达到 SSE-CMM 最高级以后，工程队伍执行同一个过程，每次执行的结果质量必须相同

B.SSE-CMM 强调系统安全工程与其他工程学科的区别性和独立性

C.系统安全工程能力成熟度模型(SSE-CMM)定义了 3 个风险过程：评价威胁，评价脆弱性，评价影响

D.系统安全工程能力成熟度模型(SSE-CMM)定义了 6 个能力级别，当工程队伍不能执行一个过程域中的基本实践时，该过程域的过程能力是 0 级

答案：D

解析：A 错误，每次质量结果难以相同；B 错误，SSE-CMM 强调的是关联性而非独立性。C 错误，SSE-CMM 定义了一个风险过程，包括四个部分，评估影响、评估威胁、评估脆弱性、评估安全风险。D 定义了 6 个能力级别，分别是不可重复级、初始级、可重复级、已定义级、已管理级、优先级；

123．由于频繁出现软件运行时被黑客远程攻击获取数据的现象，某软件公司准备加强软件安全开发管理，在下面做法中，对于解决问题没有直接帮助的是（）。

A.要求开发人员采用瀑布模型进行开发

B.要求所有的开发人员参加软件安全意识培训

C.要求增加软件安全测试环节，尽早发现软件安全问题

D.要求规范软件编码，并制定公司的安全编码准则

答案：A

解析：瀑布模型是一种开发模型与安全防护无关，有些题目可能会把瀑布模型换成其他不设计安全的模型，例如敏捷开发模型等。

124．应急响应是信息安全事件管理的重要内容。基于应急响应工作的特点和事件的不规则性，事先制定出事件应急响应方法和过程，有助于一个组织在事件发生时阻止混乱的发生或是在混乱状态中迅速恢复控制，将损失和负面影响降到最低。应急响应方法和过程并不是唯一的。一种被广为接受的应急响应方法是将应急响应管理过程分为 6 个阶段，为准备->检测->遏制->根除->恢复->跟踪总结。请问下列说法有关于信息安全应急响应管理过程错误的是（）。

A.应按照应急响应计划中事先制定的业务恢复优先顺序和恢复步骤，顺次恢复相关的系统

B.在检测阶段，首先要进行监测、报告及信息收集

C.遏制措施可能会因为事件的类别和级别不同而完全不同。常见的遏制措施有：完全关闭所有系统、拔掉网线等

D.确定重要资产和风险，实施针对风险的防护措施是信息安全应急响应规划过程中最关键的步骤

答案：C

解析：关闭相关系统而不是关闭所有系统。P153 页。

125．某单位门户网站开发完成后，测试人员使用模糊测试进行安全性测试，以下关于模糊测试过程的说法正确的是（）。

A.模拟正常用户输入行为，生成大量数据包作为测试用例

B.深入分析网站测试过程中产生崩溃或异常的原因，必要时需要测试人员手工重现并分析

C.监测和记录输入数据后程序正常运行的情况

D.数据处理点、数据通道的入口点和可信边界点往往不是测试对象

答案：B

解析：A 选项应为模拟异常用户输入行为；C 监测和记录由输入导致的任何崩溃或异常现象；D 数据处理点、数据通道的入口点和可信边界点是测试对象.

126．对信息安全事件的分级参考下列三个要素：信息系统的重要程度、系统损失和社会影响。依据信息系统的重要程度对信息系统进行划分，不属于正确划分级别的是（）。

A.特别重要信息系统

B.重要信息系统

C.关键信息系统

D.一般信息系统

答案：C

解析：信息系统重要程度划分为特别重要信息系统、重要信息系统和一般信息系统三级。P146 页。

127．关于 ARP 欺骗原理和防范措施，下面理解错误的是（）。

A.ARP 欺骗是指攻击者直接向受害者主机发送错误的 ARP 应答报文，使得受害者主机将错误的硬件地址映射关系存入到 ARP 缓存中，从而起到冒充主机的目的

B.解决 ARP 欺骗的一个有效方法是采用“静态”的 ARP 缓存，如果发生硬件地址的更改，则需要人工更新缓存

C.单纯利用 ARP 欺骗攻击时，ARP 欺骗通常影响的是内部子网，不能跨越路由实施攻击

D.彻底解决 ARP 欺骗的方法是避免使用 ARP 协议和 ARP 缓存，直接采用 IP 地址和其他主机进行连接

答案：D

解析：如果不使用 ARP 协议可能会造成网络无法正常运行，因此不能避免使用该协议。

128．CC 标准是目前系统安全认证方面最权威的标准，以下哪一项没有体现 CC 标准的先进性（）

A.实用性，将 CC 的安全性要求具体应用到 IT 产品的开发、生产、测试和评估过程中

B.结构的开放性，即功能和保证要求都可以在具体的“保护轮廓”和“安全目标”中进一步细化和扩展

C.表达方式的通用性，即给出通用的表达方式

D.独立性，它强调将安全的功能和保证分离

答案：我们给出的答案是 D,有的题库给出的答案是 A

解析：CC 标准充分突出了“保护轮廓”这一概念，将评估过程分“功能”和“保证”两部分。CC 是对已有安全准则的总结和兼容，有通用的表达方式，ITSEC 首先提出功能和保证分离，CC 继承了这一概念，所以无法体现先进性。P233 页。

129．某单位根据业务需要准备立项开发一个业务软件，对于软件开发安全投入经费研讨时开发部门和信息中心就发生了分歧，开发部门认为开发阶段无需投入，软件开发完成后发现问题后再针对性的解决，比前期安全投入要成本更低；信息中心则认为应在软件安全开发阶段投入，后期解决代价太大，双方争执不下，作为信息安全专家，请选择对软件开发安全投入的准确说法（）

A.双方的说法都错误，软件安全问题在任何时候投入解决都可以，只要是一样的问题，解决的代价相同

B.信息中心的考虑是正确的，在软件开发需求分析阶段开始考虑安全问题，总体经费投入比软件运行后的费用要低

C.双方的说法都正确，需要根据具体情况分析是开发阶段投入解决问题还是在上线后再解决问题费用更低

D.软件开发部门的说法是正确的，因为软件出现安全问题后更清楚问题所在，安排人员进行代码修订更简单，因此费用更低

答案 B

解析：软件安全开发阶段投入，后期解决代价比前期解决代价大的多。

130．某单位在一次信息安全风险管理活动中，风险评估报告提出服务器 A 的 FTP 服务存在高风险漏洞。随后该单位在风险处理时选择了安装 FTP 服务漏洞补丁程序并加固 FTP 服务安全措施，请问该措施属于哪种风险处理方式（ ）

A.风险转移

B.风险接受

C.风险规避

D.风险降低

答案：D

解析：风险降低可采用预防性策略和反应性策略两种方案。P141 页。

131．国家科学技术秘密的密级分为绝密级、机密级、秘密级，以下哪项属于绝密级的描述（）

A.能够局部反应国家防御和治安实力的

B.我国独有、不受自然条件因素制约、能体现民族特色的精华，并且社会效益或者经济效益显著的传统工艺

C.处于国际先进水平，并且有军事用途或者对经济建设具有重要影响的

D.国际领先，并且对国防建设或者经济建设具有特别重大影响的

答案：D

解析：重在“特别重大影响”。

132．小华在某电子商务公司工作，某天他在查看信息系统设计文档时，发现其中标注该信息系统的 RPO（恢复点目标）指标为 3 小时。请问这意味着（ ）。

A.若该信息系统发生重大信息安全事件，工作人员在完成处置和灾难恢复工作后，系统至多能丢失 3 小时的业务数据

B.若该信息系统发生重大信息安全事件，工作人员在完成处置和灾难恢复工作后，系统运行 3 小时后能恢复全部数据

C.该信息系统发生重大信息安全事件后，工作人员应在 3 小时内完成应急处理工作，并恢复对外运行

D.该信息系统发生重大信息安全事件后，工作人员应在 3 小时内到位，完成问题定位和应急处理工作

答案：A

解析：RPO 是指在业务恢复后的数据与最新数据之间的差异程度，这个程度使用时间作为衡量指标。如：RPO=0，说明数据是实时备份，不会出现数据丢失的情况。P156。

133．某电子商务网站在开发设计时，使用了威胁建模方法来分析电子商务网站所面临的威胁。STRIDE 是微软 SDL 中提出的威胁建模方法，将威胁分为六类，为每一类威胁提

供了标准的消减措施，Spoofing 是 STRIDE 中欺骗类的威胁，以下威胁中哪个可以归入此类威胁（）

A.网站竞争对手可能雇佣攻击者实施 DDoS 攻击，降低网站访问速度

B.网站使用用户名、密码进行登录验证，攻击者可能会利用弱口令或其他方式获得用户密码，以该用户身份登录修改用户订单等信息

C.网站使用使用 http 协议进行浏览等操作，无法确认数据与用户发出的是否一致，可能数据被中途篡改

D.网站使用使用 http 协议进行浏览等操作，未对数据进行加密，可能导致用户传输信息泄露，例如购买的商品金额等

答案：B

解析：A 属于拒绝服务威胁；C 属于篡改威胁；D 属于信息泄露威胁。P405 页。

134．某集团公司信息安全管理员根据领导安排制定了下一年度的培训工作计划，提出了四大培训任务和目标，关于这四个培训任务和目标，作为主管领导，以下选项中不合理的是（）

A.对其他信息化相关人员（网络管理员、软件开发人员）也进行安全基础培训，使相关人员对网络安全有所了解

B.对下级单位的网络安全管理岗人员实施全面安全培训，建议通过 CISP 培训以确保人员能力得到保障

C.对全体员工安排信息安全意识及基础安全知识培训，实现全员信息安全意识教育

D.由于网络安全上升到国家安全的高度，网络安全必须得到足够的重视，因此安排了对集团公司下属单位的总经理（一把手）的网络安全法培训

答案:D

解析：不能只对公司总经理培训，A 是干扰项实际情况就是要求对信息化相关人员也进行安全基础培训，使其对网络安全有所了解。

135．关于 Wi-Fi 联盟提出的安全协议 WPA 和 WPA2 的区别，下面描述正确的是（）。

A.WPA 是适用于中国的无线局域安全协议，而 WPA2 是适用于全世界的无线局域网协议

B.WPA 是有线局域安全协议，而 WPA2 是无线局域网协议

C.WPA 是依照 802.11i 标准草案制定的，而 WPA2 是依照 802.11i 正式标准制定的

D.WPA 没有使用密码算法对接入进行认证，而 WPA2 使用了密码算法对接入进行认证

答案：C

解析：WI-FI 联盟在 802.11i 标准草案的基础上制定了 WPA 标准；2004 年，IEEE 发布了 802.11i 正式标准（也称为 WPA2）,在加密算法上采用了基于 AES 的 CCMP 算法。P341 页。

136．下列关于软件安全开发中的 BSI（Build Security In）系列模型说法错误的是（）。

A.软件安全的三根支柱是风险管理、软件安全触点和安全知识

B.BSI 含义是指将安全内建到软件开发过程中，而不是可有可无，更不是游离于软件开发生命周期之外

C.BSI 系列模型强调安全测试的重要性，要求安全测试贯穿整个开发过程及软件生命周期

D.软件安全触点是软件开发生命周期中一套轻量级最优工程化方法，它提供了从不同角度保障安全的行为方式

答案：C

解析：BSI 认为软件安全有 3 根支柱：风险管理、软件安全接触点和安全知识，其强调了在软件的整个生命周期中风险管理的重要性，并要求风险管理框架贯穿整个开发过程。P403 页。

137．在信息安全风险管理过程中，背景建立是实施工作的第一步。下面哪项理解是错误的（）。

A.背景建立阶段应分析信息系统的体系结构和关键要素，分析信息系统的安全环境和要求，形成信息系统的安全要求报告

B.背景建立阶段应调查信息系统的业务目标、业务特性、管理特性和技术特性，形成信息系统的描述报告

C.背景建立阶段应识别需要保护的资产、面临的威胁以及存在的脆弱性，并分别赋值，同时确认已有的安全措施，形成需要保护的资产清单

D.背景建立的依据是国家、地区或行业的相关政策、法律、法规和标准，以及机构的使命、信息系统的业务目标和特性

答案：C

解析：背景建立是信息安全风险管理的第一步骤，确定风险管理的对象和范围，确立实施风险管理的准备，进行相关信息的调查和分析。P89 页

138．关于《网络安全法》域外适用效力的理解，以下哪项是错误的（）

A.对于来自境外的违法信息我国可以加以阻断传播

B.对于来自境外的网络安全威胁我国可以组织技术力量进行监测、防御和处置

C.对于来自境外的网络攻击我国可以追究其法律责任

D.当前对于境外的网络攻击，我国只能通过向来源国采取抗议

答案：D

解析：对境外的机构、组织、个人从事攻击、侵入、干扰、破坏等危害中华人民共和国的关键信息基础设施活动，造成严重后果的，依法追究法律责任。P55 页。

139．某购物网站开发项目经过需求分析进入系统设计阶段，为了保证用户帐户的安全，项目开发人员决定用户登录时除了用户名口令认证方式外，还加入基于数字证书的身份认证功能，同时用户口令使用 SHA-1 算法加密后存放在后台数据库中，请问以上安全设计遵循的是哪项安全设计原则（）

A.纵深防御原则

B.最少共享机制原则

C.职责分离原则

D.最小特权原则

答案：A

解析：纵深防御原则：软件应该设置多重安全措施（户名口令认证方，基于数字证书的身份认证，用户口令使用 SMA-1 算法加密后存放在后台数据库中），并充分利用操作系统提供的安全防护机制，形成纵深防御体系，以降低攻击者成功攻击的几率和危害。P409。

140．有关系统安全工程-能力成熟度模型（SSE-CMM），错误的理解是（）。

A.基于 SSE-CMM 的工程是独立工程，与软件工程、硬件工程、通信工程等分别规划实施

B.SSE-CMM 可以使安全工程成为一个确定的、成熟的和可度量的科目

C.SSE-CMM 要求实施组织与其他组织相互作用，如开发方、产品供应商、集成商和咨询服务商等

D.SSE-CMM 覆盖整个组织的活动，包括管理、组织和工程活动等，而不仅仅是系统安全的工程活动

答案：A

解析：SSE-CMM 的工程不是独立工程，而是与其他工程并行且相互作用，包括企业工程、软件工程、硬件工程、通信工程等。P179。

141. 有关系统安全工程-能力成熟度模型（SSE-CMM）中的通用实施（Generic Practices，GP），错误的理解是（）。

A.在工程实施时，GP 应该作为基本实施（Base Practices，BP）的一部分加以执行

B.GP 适用于域维中部分过程区域（Process Areas，PA）的活动而非所有 PA 的活动

C.在评估时，GP 用于判定工程组织执行某个 PA 的能力

D.GP 是涉及过程的管理、测量和制度化方面的活动

答案：我们给出的答案是 B，但有的题库给出的答案是 A

解析：通用实施（Generic Practices，GP），又被称之为“公共特征”的逻辑域组成。通用实施可应用到每一个过程区，但第一个公共特征“执行基本实施”例外。

142．Kerberos 协议是一种集中访问控制协议，它能在复杂的网络环境中，为用户提供安全的单点登录服务。单点登录是指用户在网络中进行一次身份认证，便可以访问其授权的所有网络资源，而不再需要其他的身份认证过程，实质是消息 M 在多个应用系统之间的传递或共享。其中，消息 M 是指以下选项中的（）。

A.安全凭证

B.加密密钥

C.会话密钥

D.用户名

答案:A

解析：单点登录是指用户在网络中进行一次身份认证，便可以访问其授权的所有网络资源，而不再需要其他的身份认证过程，实质是安全凭证在多个应用系统之间的传递或共享。P300 页。

143．Gary McGraw 博士及其合作者提出软件安全应由三根支柱来支撑，这三个支柱是（）。

A.威胁建模、源代码审核和模糊测试

B.应用风险管理、软件安全接触点和安全知识

C.威胁建模、渗透测试和软件安全接触点

D.源代码审核、风险分析和渗透测试

答案：B

解析：BSI 认为软件安全有 3 根支柱：风险管理、软件安全接触点和安全知识，其强调了在软件的整个生命周期中风险管理的重要性，并要求风险管理框架贯穿整个开发过程。P403 页。

144．软件存在漏洞和缺陷是不可避免的，实践中常使用软件缺陷密度（Defects/KLOC）来衡量软件的安全性。假设某个软件共有 296 万行源代码，总共被检测出 145 个缺陷，则可以计算出其软件缺陷密度值是（）。

A.49

B.0.49

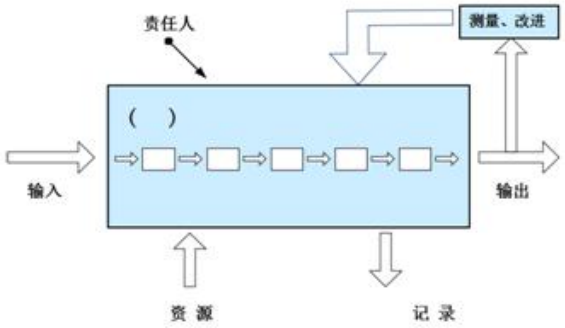
C.0.00049

D.0.049

答案：D

解析：千行代码缺陷率=缺陷数/（代码行数/1000）

145．ISO9001-2000 标准鼓励在制定、实施质量管理体系以及改进其有效性时采用过程方法，通过满足顾客要求，增进顾客满意度。下图是关于过程方法的示意图，图中括号空白处应填写（ ）。



A.策略

B.活动

C.组织

D.管理者

答案：B

解析：参考 ISO9001-2000 标准过程方法

146．随着信息技术的不断发展，信息系统的重要性也越来越突出，而与此同时，发生的信息安全事件也越来越多。综合分析信息安全问题产生的根源，下面描述正确的是（）。

A.信息系统自身存在脆弱性是根本原因。信息系统越来越重要，同时自身在开发、部署和使用过程中存在的脆弱性，导致了诸多的信息安全事件发生。因此，杜绝脆弱性的存在是解决信息安全问题的根本所在

B.信息系统面临诸多黑客的威胁，包括恶意攻击者和恶作剧攻击者。信息系统应用越来越广泛，接触信息系统的人越多，信息系统越可能遭受攻击。因此，避免有恶意攻击可能的人接触信息系统就可以解决信息安全问题

C.信息安全问题的根本原因是内因、外因和人三个因素的综合作用，内因和外因都可能导致安全事件的发生，但最重要的还是人的因素，外部攻击者和内部工作人员通过远程攻击、本地破坏和内外勾结等手段导致安全事件发生。因此，对人这个因素的防范应是安全工作重点

D.信息安全问题产生的根源要从内因和外因两个方面分析，因为信息系统自身存在脆弱性，同时外部又有威胁源，从而导致信息系统可能发生安全事件。因此，要防范信息安全风险，需从内外因同时着手

答案：D
解析：从根源来说，信息安全问题可以归因于内因和外因两个方面。P3 页。

147．某贸易公司的 OA 系统由于存在系统漏洞，被攻击者上传了木马病毒并删除了系统中的数据，由于系统备份是每周六进行一次，事件发生时间为周三，因此导致该公司三个工作日的数据丢失并使得 OA 系统在随后两天内无法访问，影响到了与公司有业务往来部分公司业务。在事故处理报告中，根据 GB/Z 20986-2007《信息安全事件分级分类指南》，该事件的准确分类和定级应该是（）

A.有害程序事件特别重大事件（I级）

B.信息破坏事件重大事件（II级）

C.有害程序事件较大事件（III级）

D.信息破坏事件一般事件（IV级）

答案：C
解析：木马病毒为有害程序事件，系统数据丢失并使得 OA 系统在随后两天内无法访问属于较大事件（III 级）

148．以下关于互联网协议安全(Internet Protocol Security，IPsec)协议说法错误的是（）。

A.IPsec 仅能保证传输数据的可认证性和保密性

B.验证头协议（Authentication Head，AH）和 IP 封装安全载荷协议（Encapsulating Security Payload，ESP）都能以传输模式和隧道模式工作

C.在隧道模式中，保护的是整个互联网协议（Internet Protocol，IP）包，包括 IP 头

D.在传送模式中，保护的是 IP 负载

答案：A
解析：IPsec 协议中通过封装安全载荷协议加密需要保护的载荷数据，为这些数据提供机密性和完整性保护能力。

149．某信息安全公司的团队对某款名为“红包快抢”的外挂进行分析，发现此外挂是一个典型的木马后门，使黑客能够获得受害者电脑的访问权。该后门程序为了达到长期驻留在受害者的计算机中，通过修改注册表启动项来达到后门程序随受害者计算机系统启动而启动。为防范此类木马后门的攻击，以下做法无用的是（）。

A.不随意打开来历不明的邮件，不浏览不健康不正规的网站

B.不下载、不执行、不接收来历不明的软件或文件

C.修改用户名和口令

D.安装反病毒软件和防火墙，安装专门的木马防治软件

答案：C
解析：修改用户名和口令不能防范此类攻击。

150．超文本传输协议（HyperText Transfer Protocol，HTTP)是互联网上广泛使用的一种网络协议。下面哪种协议基于 HTTP 并结合 SSL 协议，具备用户鉴别和通信数据加密等功能（）。

A.HTTPD 协议

B.HTTP 1.0 协议

C.HTTPS 协议

D.HTTP 1.1 协议

答案：C
解析：HTTPS 协议，是以安全为目标的 HTTP 通道，在 HTTP 的基础上通过传输加密和身份认证保证了传输过程的安全性。

151．安全漏洞扫描技术是一类重要的网络安全技术。当前，网络安全漏洞扫描技术的两大核心技术是（）。
A.PING 扫描技术和端口扫描技术
B.端口扫描技术和漏洞扫描技术
C.操作系统探测和漏洞扫描技术
D.PING 扫描技术和操作系统探测
答案：B
解析：概念题

152．下列选项中对信息系统审计概念的描述中不正确的是（）
A.信息系统审计，也可称作 IT 审计或信息系统控制审计
B.信息系统审计是一个获取并评价证据的过程，审计对象是信息系统相关控制，审计目标则是判断信息系统是否能够保证其安全性、可靠性、经济性以及数据的真实性、完整性等相关属性
C.信息系统审计是单一的概念，是对会计信息系统的安全性、有效性进行检查
D.从信息系统审计内容上看，可以将信息系统审计分为不同专项审计，例如安全审计、项目合规审计、绩效审计等
答案：C
解析：国家审计署定义：“信息系统审计是指国家审计机关依法对被审计单位信息系统的真实性、合法性、效益性和安全性进行检查监督的活动。”P260 页。

153．甲公司打算制作网络连续时所需要的插件的规格尺寸、引脚数量和线序情况，甲公司将这个任务委托了乙公司，那么乙公司的设计员应该了解 OSI 参考模型中的哪一层（）
A.数据链路层
B.会话层
C.物理层
D.传输层
答案：C
解析：物理层规定通信设备的机械的、电气的、功能的和过程的特性，用以建立、维护和拆除物理链路连接，这些特性包括网络连接时所需接插件的规格尺寸、引脚数量等，P329 页

154．下面哪一项情景属于身份鉴别（Authentication）过程？（）
A.用户依照系统提示输入用户名和口令
B.用户在网络上共享了自己编写的一份 Office 文档进行加密，以阻止其他人得到这份拷贝后到文档中的内容
C.中的内容用户使用加密软件对自己家编写的 Office 文档进行加密，以阻止其他人得到这份拷贝后到文档中的内容
D.某个人尝试登陆到你的计算机中，但是口令输入的不对，系统提示口令错误，并将这次失败的登陆过程记录在系统日志中
答案：A

解析：

155．终端访问控制器访问控制系统（TERMINAL Access Controller Access-Control System,TACACS）,在认证过程中，客户机发送一个 START 包给服务器，包的内容包括执行的认证类型、用户名等信息。START 包只在一个认证会话开始时使用一个，序列号永远为（）.服务器收到 START 包以后，回送一个 REPLY 包，表示认证继续还是结束。
A.0
B.1
C.2
D.4
答案：B
解析：P315 页

156.（）在实施攻击之前，需要尽量收集伪装身份(),这些信息是攻击者伪装成功的（）。例如攻击者要伪装成某个大型集团公司总部的（）。那么他需要了解这个大型集团公司所处行业的一些行规或者（）、公司规则制度、组织架构等信息，甚至包括集团公司相关人员的绰号等等。
A.攻击者；所需要的信息；系统管理员；基础；内部约定
B.所需要的信息；基础；攻击者；系统管理员；内部约定
C.攻击者；所需要的信息；基础；系统管理员；内部约定
D.所需要的信息；攻击者；基础；系统管理员；内部约定
答案：C
解析：

157．1993 年至 1996 年，欧美六国和美国商务部国家标准与技术局共同制定了一个供欧美各国通用的信息安全评估标准，简称 CC 标准，该安全评估标准的全称为（）
A.《可信计算机系统评估准则》
B.《信息技术安全评估准则》
C.《可信计算机产品评估准则》
D.《信息技术安全通用评估准则》
答案：D
解析：

158．计算机漏洞是在硬件、软件、协议的具体实现或系统安全策略上存在的缺陷，从而可以使攻击者能够在未授权的情况下访问或破坏系统。在病毒肆意的信息不安全时代，某公司为减少计算机系统漏洞，对公司计算机系统进行了如下措施，其中错误的是（ ）
A.减少系统日志的系统开销
B.禁用或删除不需要的服务，降低服务运行权限
C.设置策略避免系统出现弱口令并对口令猜测进行防护
D.对系统连续进行限制，通过软件防火墙等技术实现对系统的端口连续进行控制
答案：A
解析：系统日志不应该减少

159．安全审计是一种很常见的安全控制措施，它在信息全保障系统中，属于（）措施。

A.保护
B.检测
C.响应
D.恢复
答案：B
解析：

160. 下列选项分别是四种常用的资产评估方法，哪个是目前采用最为广泛的资产评估方法（）。
A.基于知识的分析方法
B.基于模型的分析方法
C.定量分析
D.定性分析
答案：D
解析：

161. 访问控制方法可分为自主访问控制、强制访问控制和基于角色访问控制，它们具有不同的特点和应用场景。如果需要选择一个访问控制模型，要求能够支持最小特权原则和职责分离原则，而且在不同的系统配置下可以具有不同的安全控制，那么在（1）自主访问控制，（2）强制访问控制，（3）基于角色的访问控制（4）基于规则的访问控制中，能够满足以上要求的选项有（）
A.只有（1）（2）
B.只有（2）（3）
C.只有（3）（4）
D.只有（4）
答案：C
解析：支持最小特权原则和职责分离原则，只有基于角色的访问控制满足，所以排除 A 和 D，基于强制访问控制不满足，所以排除 B。

162. 国家对信息安全建设非常重视，如国家信息化领导小组在（）中确定要求，“信息安全建设是信息化的有机组成部分，必须与信息化同步规划、同步建设。各地区各部门在信息化建设中，要同步考虑信息安全建设，保证信息安全设施的运行维护费用。”国家发展改革委所下发的（）要求；电子政务工程建设项目必须同步考虑安全问题，提供安全专项资金，信息安全风险评估结论是项目验收的重要依据。在我国 2017 年正式发布的（）中规定“建设关键信息基础设施应当确保其具有支持业务稳定、持续运行的性能，并保证安全技术措施同步规划、同步建设、同步使用。”信息安全工程就是要解决信息系统生命周期的“过程安全”问题。
A.《关于加强信息安全保障工作的意见》；《关于加强国家电子政务工程建设项目信息安全风险评估工作的通知》；《网络安全法》
B.《关于加强国家电子政务工程建设项目信息安全风险评估工作的通知》；《关于加强信息安全保障工作的意见》；《网络安全法》
C.《网络安全法》；《关于加强信息安全保障工作的意见>>;
D.《网络安全法》；《关于加强国家电子政务工程建设项目信息安全风险评估工作的通知》；《关于加强信息安全保障工作的意见》

答案：A
解析：

163. 现如今的时代是信息的时代，每天都会有大量的信息流通或交互，但自从斯诺登曝光美国政府的“棱镜”计划之后，信息安全问题也成为了每个人乃至整个国家所不得不重视的问题，而网络信息对抗技术与电子信息对抗技术也成为了这个问题的核心。某公司为有效对抗信息收集和分析，让该公司一位网络工程师提出可行的参考建议，在该网络工程师的建议中，错误的是（）
A.通过信息安全培训，使相关信息发布人员了解信息收集的风险
B.发布信息应采取最小原则，所有不是必要的信息都不发布
C.重点单位应建立信息发布审查机制，对发布的信息进行审核，避免敏感信息的泄露
D.增加系统中对外服务的端口数量，提高会话效率
答案：D
解析：增加对外服务端口数量会有助于攻击者进行信息收集

164. 分析针对 Web 的攻击前，先要明白 http 协议本身是不存在安全性的问题的，就是说攻击者不会把它当作攻击的对象。而是应用了 http 协议的服务器或则客户端、以及运行的服务器的 wed 应用资源才是攻击的目标。针对 Web 应用的攻击，我们归纳出了 12 种，小陈列举了其中的 4 种，在这四种当中错误的是（）
A.拒绝服务攻击
B.网址重定向
C.传输保护不足
D.错误的访问控制
答案：D
解析：A 项攻击的是 web 应用资源，B 项攻击的是把 web 服务器的地址重定向到其他地址，C 项攻击的是运行 http 协议的客户端或者服务器铭文传输的问题。

165. 在新的信息系统或增强已有()业务要求陈述中，应规定对安全控制措施的要求。信息安全的系统要求与实施安全的过程宜在信息系统项目的早期阶段被集成，在早期如设计阶段引入控制措施的更高效和节省。如果购买产品，则宜遵循一个正式的（）过程。通过（）访问的应用易受到许多网络威胁，如欺诈活动、合同争端和信息的泄露或修改。因此要进行详细的风险评估并进行适当的控制，包括验证和保护数据传输的加密方法等，保护在公共网络上的应用服务以防止欺诈行为、合同纠纷以及未经授权的（）。应保护涉及到应用服务交换的信息以防不完整的传输、路由错误、未经授权的改变、擅自披露、未经授权的（）。
A.披露和修改；信息系统；测试和获取；公共网路；复制或重播
B.信息系统；测试和获取；披露和修改；公共网路；复制或重播
C.信息系统；测试和获取；公共网路；披露和修改；复制或重播
D.信息系统；公共网路；测试和获取；披露和修改；复制或重播
答案：C
解析：

166. 2016 年 12 月 27 日，经中央网络安全和信息化领导小组批准，国家互联网信息办公室发布《国家网络空间安全战略》（以下简称：“战略”）。全文共计（）部分，6000 余字。除了提出网络安全空间总体发展（）之外,其中主要对我国当前面临的网络空间安全 7

大机遇思想，阐明了中国关于网络空间发展和安全的重大立场和主张，明确了战略方针和主要任务，切实维护国家在网络空间的主权、安全、发展利益，是指导国家网络安全工作的纲领性文件。《战略》指出，网络空间机遇和挑战并存，机遇大于挑战。必须坚持积极利用、科学发展、依法管理、确保安全，坚决维护网络安全，最大限度利用网络空间发展潜力，更好惠及13亿多中国人民，造福全人类，（）。《战略》要求，要以（），贯彻落实创新、协调、绿色、开放、共享的发展理念，增强风险意识和危机意识，统筹国内国际两个大局，统筹发展安全两件大事，积极防御、有效应对，推进网络空间和平、安全、开放、合作、有序，维护国家主权、安全、发展利益，实现建设网络强国的（）。

A.4个；总体目标；坚定维护世界和平；总体国家安全观为指导；战略目标

B.5个；基本目标；坚定维护世界和平；总体国家安全观为指导；战略目标

C.6个；总体目标；坚定维护世界和平；总体国家安全观为指导；战略目标

D.7个；基本目标；坚定维护世界和平；总体国家安全观为指导；战略目标

答案：A

解析：《国家网络空间安全战略》原文

167. 哪种攻击是攻击者通过各种手段来消耗网络宽带或者服务器系统资源，最终导致被攻击服务器资源耗尽或者系统崩溃而无法提供正常的网络服务（）

A.拒绝服务

B.缓冲区溢出

C.DNS欺骗

D.IP欺骗

答案：A

解析：题干是针对拒绝服务攻击的描述

168. 以下关于VPN说法正确的是（）

A.VPN指的是用户自己租用线路，和公共网络物理上完全隔离的、安全的线路

B.VPN不能做到信息认证和身份认证

C.VPN指的是用户通过公用网络建立的临时的、安全的连接

D.VPN只能提供身份认证，不能提供数据加密传输的功能

答案：C

解析：VPN和公共网络是逻辑隔离的关系，可以进行信息认证，身份认证，数据加密（例如：IPsec VPN），

169. 社会工程学是（）与（）结合的学科，准确来说，它不是一门科学，因为它不能总是重复合成功，并且在信息充分多的情况下它会失效。基于系统、体系、协议等技术体系缺陷的（），随着时间流逝最终都会失效，因为系统的漏洞可以弥补，体系的缺陷可能随着技术的发展完善或替代，社会工程学利用的是人性的“弱点”，而人性是（）,这使得它几乎是永远有效的（）。

A.网络安全；心理学；攻击方式；永恒存在的；攻击方式

B.网络安全；攻击方式；心理学；永恒存在的；攻击方式

C.网络安全；心理学；永恒存在的；攻击方式

D.网络安全；攻击方式；心理学；攻击方式；永恒存在的

答案：A

解析：

170. 系统安全工程能力成熟度模型评估方法（SSAM, SSE-CMM Appraisal Method）是专门基于 SSE-CMM 的评估方法。它包含对系统安全工程-能力成熟度模型中定义的组织的（）流程能力和成熟度进行评估所需的（）。SSAM 评估过程分为四个阶段，（）、（）、（）、（）。
A.信息和方向；系统安全工程；规划；准备；现场；报告
B.信息和方向；系统工程；规划；准备；现场；报告
C.系统安全工程；信息；规划；准备；现场；报告
D.系统安全工程；信息和方向；规划；准备；现场；报告
答案：D
解析：

171. 当使用移动设备时，应特别注意确保()不外泄。移动设备方针应考虑与非保护环境移动设备同时工作时的风险。当在公共场所、会议室和其他不受保护的区域使用移动计算设施时，要加以小心。应采取保护措施以避免通过这些设备存储和处理的信息未授权的访问或泄露，如使用()、强制使用秘钥身份验证信息。要对移动计算设施进行物理保护，以防被偷窃，例如，特别是遗留在汽车和其他形式的交通工具上、旅馆房间、会议中心和会议室。要为移动计算机设施的被窃或丢失等情况建立一个符号法律、保险和组织的其他安全要求的（）。携带重要、敏感和或关键业务信息的设备不宜无人值守，若有可能，要以物理的方式锁起来，或使用（）来保护设备。对于使用移动计算设施的人员要安排培训，以提高他们对这种工作方式导致的附加风险的意识，并且要实施控制措施。
A.加密技术；业务信息；特定规程；专用锁
B.业务信息；特定规程；加密技术；专用锁
C.业务信息；加密技术；特定规程；专用锁
D.业务信息；专用锁；加密技术；特定规程
答案：C
解析：

172. 在规定的时间间隔或重大变化发生时，组织的（）和实施方法（如信息安全的控制目标、控制措施、方针、过程和规程）应（）。独立评审宜由管理者启动，由独立被评审范围的人员执行，例如内部审核部、独立的管理人员或专门进行这种评审的第三方组织。从事这些评审的人员宜具备适当的（）。管理人员宜对自己职责范围内的信息处理是否符合合适的安全策略、标准和任何其他安全要求进行（）。为了日常评审的效率，可以考虑使用自动测量和（）。评审结果和管理人员采取的纠正措施宜被记录，且这些记录宜予以维护。
A.信息安全管理；独立审查；报告工具；技能和经验；定期评审
B.信息安全管理；技能和经验；独立审查；定期评审；报告工具
C.独立审查；信息安全管理；技能和经验；定期评审；报告工具
D.信息安全管理；独立审查；技能和经验；定期评审；报告工具
答案：D
解析：

173. 选择信息系统部署的场地应考虑组织机构对信息安全的需求并将安全性防在重要的位置，信息资产的保护很大程度上取决与场地的安全性，一个部署在高风险场所的额信息系统是很难有效的保障信息资产安全性的。为了保护环境安全，在下列选项中，公司在选址时最不应该选址的场地是()

A.自然灾害较少的城市
B.部署严格监控的独立园区
C.大型医院旁的建筑
D.加油站旁的建筑
答案：D
解析：

174. 1998 年英国公布标准的第二部分《信安全管理体系规范》，规定（）管理体系要求与（）要求，它是一个组织的全面或部分信息安全管理体系评估的（），它可以作为一个正式认证方案的（）。BS 7799-1 与 BS7799-2 经过修订于 1999 年重新予以发布，1999 版考虑了信息处理技术，尤其是在网络和通信领域应用的近期发展，同时还非常强调了商务涉及的信息安全及（）的责任。
A.信息安全；信息安全控制；根据；基础；信息安全
B.信息安全控制；信息安全；根据；基础；信息安全
C.信息安全控制；信息安全；基础；根据；信息安全
D.信息安全；信息安全控制；基础；根据；信息安全
答案：A
解析：

175. 社会工程学本质上是一种（），（）通过种种方式来引导受攻击者的（）向攻击者期望的方向发展。罗伯特•B•西奥迪尼（Robert B Cialdini）在科学美国人（2001 年 2 月）杂志中总结对（）的研究，介绍了 6 种“人类天性基本倾向”，这些基本倾向都是（）工程师在攻击中所依赖的（有意思或者无意识的）。
A.攻击者；心理操纵；思维；心理操纵；思维；社会工程学
B.攻击者；心理操纵；心理操纵；社会工程学
C.心理操纵；攻击者；思维；心理操纵；社会工程学
D.心理操纵；思维；心理操纵；攻击者；社会工程学
答案：C
解析：

176. 风险评估的工具中，（）是根据脆弱性扫描工具扫描的结果进行模拟攻击测试，判断被非法访问者利用的可能性，这类工具通常包括黑客工具、脚本文件。
A.脆弱性扫描工具
B.渗透测试工具
C.拓扑发现工具
D.安全审计工具
答案：B
解析：

177. 某公司正在进行 IT 系统灾难恢复测试，下列问题中哪个最应该引起关注()
A.由于有限的测试时间窗，仅仅测试了最必须的系统，其他系统在今年的剩余时间里陆续单独测试
B.在测试的过程中，有些备份系统有缺陷或者不能正常工作，从而导致这些系统的测试失败
C.在开启备份站点之前关闭和保护原生产站点的过程比计划需要多得多的时间

D.每年都是由相同的员工执行此测试，由于所有的参与者都很熟悉每一个恢复步骤，因而没有使用灾难恢复计划（DRP）文档
答案：B
解析：“备份系统有缺陷或者不能正常工作，从而导致这些系统的测试失败”

178. 关于软件安全问题，下面描述错误的是（）
A.软件的安全问题可能造成软件运行不稳定，得不到正确结果甚至崩溃
B.软件的安全问题应该依赖于软件开发的设计、编程、测试以及部署等各个阶段措施解决
C.软件的安全问题可能被攻击者利用后影响人身健康安全
D.软件的安全问题是由程序开发者遗留的，和软件部署运行环境无关
答案：D
解析：“由程序开发者遗留的，和软件部署运行环境无关”

179. 随着计算机和网络技术的迅速发展，人们对网络的依赖性达到了前所未有的程度，网络安全也面临着越来越严峻的考验。如何保障网络安全就显得非常重要，而网络安全评估是保证网络安全的重要环节。以下不属于网络安全评估内容的是（）
A.数据加密
B.漏洞检测
C.风险评估
D.安全审计
答案：A
解析：数据加密只是一种数据保护方式

180. 2006 年 5 月 8 日电，中共中央办公厅、国务院办公厅印发了《2006-2020 年国家信息化发展战略》。全文分（）部分共计约 15000 余字。对国内外的信息化发展做了宏观分析，对我国信息化发展指导思想和战略目标标准要阐述，对我国（）发展的重点、行动计划和保障措施做了详尽描述。该战略指出了我国信息化发展的（），当前我国信息安全保障工作逐步加强。制定并实施了（）,初步建立了信息安全管理体制和（）。基础信息网络和重要信息系统的安全防护水平明显提高，互联网信息安全管理进一步加强。
A. 5 个；信息化；基本形势；国家安全战略；工作机制
B.6 个；信息化；基本形势；国家信息安全战略；工作机制
C.7 个；信息化；基本形势；国家安全战略；工作机制
D.8 个；信息化；基本形势；国家信息安全战略；工作机制
答案：B
解析：

181. 张主任的计算机使用 Windows7 操作系统，他常登陆的用户名为 zhang,张主任给他个人文件夹设置了权限为只有 zhang 这个用户有权访问这个目录,管理员在某次维护中无意将 zhang 这个用户删除了，随后又重新建了一个用户名为 zhang，张主任使用 zhang 这个用户登陆系统后，发现无法访问他原来的个人文件夹，原因是（）
A.任何一个新建用户都需要经过授权才能访问系统中的文件
B.windows 不认为新建立的用户 zhang 与原来的用户 zhang 是同一个用户，因此无权访问
C.用户被删除后，该用户创建的文件夹也会自动删除，新建用户找不到原来用户的文件夹，因此无法访问

D.新建的用户 zhang 会继承原来用户的权限，之所以无权访问时因为文件夹经过了加密
答案：B
解析：用户的真正标识是 SID，系统根据 SID 来判断是否是同一个用户，新建用户名虽然相同，但是 SID 不同，所以系统认为不是同一个用户。

182. 信息应按照其法律要求、价值、对泄露或篡改的()和关键性予以分类。信息资产的所有者应对其分类负责。分类的结果表明了(),该价值取决于其对组织的敏感性和关键性如保密性、完整性和有效性。信息要进行标记并体现其分类,标记的规程需要涵盖物理和电子格式的 ( )。分类信息的标记和安全处理是信息共享的一个关键要求。( )和元数据标签是常见的形式。标记应易于辨认,规程应对标记附着的位置和方式给出指导,并考虑到信息被访问的方式和介质类型的处理方式。组织要建立与信息分类一致的资产处理、加工、存储和( )
A.敏感性；物理标签；资产的价值；信息资产；交换规程
B.敏感性；信息资产；资产的价值；物理标签；交换规程
C.资产的价值；敏感性；信息资产；物理标签； 交换规程
D.敏感性；资产的价值 ；信息资产物理标签；交换规程
答案：D
解析：来源于 27002 标准的原文

183.杀毒软件一般是通过对代码与特征库中的特征码进行比对,判断这个文件是否是为恶意代码,如果是则进女联系到病毒库中对该病毒的描述,从而确认其行为,达到分析的目的。下列对恶意代码静态分析的说法中,错误的是( )
A.静态分析不需要实际执行恶意代码,它通过对其二进制文件的分析,获得恶意代码的基本结构和特征,了解其工作方式和机制
B.静态分析通过查找恶意代码二进制程序中嵌入的可疑字符串,如:文件名称、URL 地址、域名、调用函数等来进行分析判断
C.静态分析检测系统函数的运行状态,数据流转换过程,能判别出恶意代码行为和正常软件操作
D.静态分析方法可以分析恶意代码的所有执行路径,但是随着程序复杂度的提高,冗余路径增多,会出现分析效率很低的情况
答案：C
解析：无法检测运行状态，P371。

184.数据库是一个单位或是一个应用领域的通用数据处理系统,它存储的是属于企业和事业部门、团体和个人的有关数据的集合。数据库中的数据是从全局观点出发建立的,按一定的数据模型进行组织、描述和存储。其结构基于数据间的自然联系,从而可提供一切必要的存取路径,且数据不再针对某一应用,而是面向全组织,具有整体的结构化特征。数据库作为应用系统数据存储的系统,毫无疑问会成为信息安全的重点防护对象。数据库安全涉及到数据资产的安全存储和安全访问,对数据库安全要求不包括下列( )
A.向所有用户提供可靠的信息服务
B.拒绝执行不正确的数据操作
C.拒绝非法用户对数据库的访问
D.能跟踪记录,以便为合规性检查、安全责任审查等提供证据和迹象等
答案：A

解析：A 项不在数据库安全存储和安全访问范畴。

185. 目前,很多行业用户在进行信息安全产品选项时,均要求产品需通过安全测评。关于信息安全产品测评的意义,下列说法中不正确的是:（ ）
A.有助于建立和实施信息安全产品的市场准入制度
B.对用户采购信息安全产品,设计、建设、使用和管理安全的信息系统提供科学公正的专业指导
C.对信息安全产品的研究、开发、生产以及信息安全服务的组织提供严格的规范引导和质量监督
D.打破市场垄断,为信息安全产业发展创造一个良好的竞争环境
答案：D
解析：题干中信息安全产品测评的主要目的是安全作用，不是经济作用。

186. 风险评估相关政策,目前主要有( ) (国信办[2006]5 号)。主要内容包括:分析信息系统资产的( ),评估信息系统面临的( )、存在的( )、已有的安全措施和残余风险的影响等、两类信息系统的( )、涉密信息系统参照“分级保护”、非涉密信息系统参照“等级保护”。
A.《关于开展信息安全风险评估工作的意见》；重要程度 ；安全威胁；脆弱性； 工作开展
B.《关于开展风险评估工作的意见》;安全威胁；重要程度；脆弱性；工作开展
C.《关于开展风险评估工作的意见》；重要程度；安全威胁；脆弱性；工作开展
D.《关于开展信息安全风险评估工作的意见》 脆弱性;重要程度；安全威胁；工作开展
答案：A
解析：

187. ( )在实施攻击之前,需要尽量收集伪装身份(),这些信息是攻击者伪装成功的( )。例如攻击者要伪装成某个大型集团公司总部的( ),那么他需要了解这个大型集团公司所处行业的一些行规或者 ( )、公司规则制度、组织架构等信息,甚至包括集团公司中相关人员的绰号等等。
A.攻击者;所需要的信息;系统管理员;基础;内部约定
B.所需要的信息;基础;攻击者;系统管理员;内部约定
C.攻击者;所需要的信息:基础;系统管理员;内部约定
D.所需要的信息;攻击者;基础;系统管理员;内部约定
答案：C
解析：

188. 方法指导类标准主要包括 GB/T-T25058-2010-《信息安全技术信息系统安全等级保护实施指南》GB / T25070-2010《信息系统等级保护安全设计技术要求》等。其中《等级保护实施指南》原以()政策文件方式发布,后修改后以标准发布。这些标准主要对如何开展()做了详细规定。状况分析类标准主要包括 GB/T28448-2012《信息安全技术信息系统安全等级保护测评要求》和 GB/T 284492012《信息安全技术信息系统安全等级保护测评过程指南》等。其中在()工作期间还发布过《等级保护测评准则》等文件,后经过修改以《等级保护测评要求》发布。这些标准主要对如何开展( )工作做出了( )
A.公安部；等级保护试点；等级保护工作；等级保护测评；详细规定.

B.公安部；等级保护工作；等级保护试点；等级保护测评；详细规定
C.公安部；等级保护工作；等级保护测评；等级保护试点；详细规定
D.公安部；等级保护工作；等级保护试点；详细规定；等级保护测评
答案：B
解析：

189. 下列选项中,对风险评估文档的描述中正确的是( )
A.评估结果文档包括描述资产识别和赋值的结果,形成重要资产列表
B.描述评估结果中不可接受的风险制定风险处理计划,选择适当的控制目标及安全措施,明确责任、进度、资源,并通过对残余风险的评价以确定所选择安全措施的有效性的《风险评估程序》
C.在文档分发过程中作废文档可以不用添加标识进行保留
D.对于风险评估过程中形成的相关文档行,还应规定其标识、储存、保护、检索、保存期限以及处置所需的控制
答案：D
解析：P260 页

190.供电安全是所有电子设备都需要考虑的问题,只有持续平稳的电力供应才能保障电子设备作稳定可靠因此电力供应需要解决问题包括两个,一是确保电力供应不中断、二是确保电力供应平稳。下列选项中,对电力供应的保障措施的描述正确的是（）
A.可以采用双路供电来确保电力供应稳定性
B.UPS 可提供持续、平稳的电力供应,不会受到电涌的影响
C.可以部署电涌保护器来确保电力供应稳定性
D.发动机供电是目前电力防护最主要的技术措施
答案：C
解析：A 项是防止电力中断，B 项 UPS 里面有电子元器件，一样有可能会受到电涌的影响，D 项，在教材里面并没有这个表述，C 项没有原则性错误

191. 组织应开发和实施使用( )来保护信息的策略,基于风险评估,应确定需要的保护级别,并考虑需要的加密算法的类型、强度和质量。当选择实施组织的( )时,应考虑我国应用密码技术的规定和限制,以及( )跨越国界时的问题。组织应开发和实施在密钥生命周期中使用和保护密钥的方针。方针应包括密钥在其全部生命周期中的管理要求,包括密钥的生成、存储、归档、检索、分配、卸任和销毁。宜根据最好的实际效果选择加密算法、密钥长度和使用习惯。适合的( )要求密钥在生成、存储、归档、检索、分配、卸任和销毁过程中的安全。宜保护所有的密钥免遭修改和丢失。另外,秘密和私有密钥需要防范非授权的泄露。用来生成、存储和归档密钥的设备应进行( )。
A.加密控制措施；加密信息；密码策略；密钥管理；物理保护
B.加密控制措施；密码策略；密钥管理；加密信息；物理保护
C.加密控制措施；密码策略；加密信息；密钥管理：物理保护
D.加密控制措施；物理保护；密码策略；加密信息；密钥管理
答案：C
解析：P112 页

192. 由于病毒攻击、非法入侵等原因,校园网整体瘫痪,或者校园网络中心全部 DNS 主 WEB 服务器不能正常工作;由于病毒攻击、非法入侵、人为破坏或不可抗力等原因,造成校园网出口中断,属于以下哪种级别事件(　　)

A.特别重大事件

B.重大事件

C.较大事件

D.一般事件

答案：我们给出的答案是 B，有的题库给出 A 或者 D

解析：参考 P147 页安全事件定级。

193.某网盘被发现泄露了大量私人信息,通过第三方网盘搜索引擎可查询到该网盘用户的大量照片、通讯录。盘建议用户使用“加密分享”功能,以避免消息泄露,“加密分享”可以采用以下哪些算法（　）。

A.MD5 算法，SHA-1 算法

B.DSA 算法，RSA 算法

C.SHA-1 算法，SM2 算法

D.RSA 算法，SM2 算法

答案：D

解析：加密分享是通过加密手段进行文件数据的分享，可以加密并解密，MD5、SHA-1 是单项函数用于数据完整性保护，DSA 是一种数字签名的算法，RSA 和 SM2 是公钥加密算法。

194.作为单位新上任的CSO,你组织了一次本单位的安全评估工作以了解单位安全现状。在漏洞扫描报告发现了某部署在内网且仅对内部服务的业务系统存在一个漏洞,对比上一年度的漏洞扫描报告,发现这个已经报告出来,经询问安全管理员得知,这个业务系统开发商已经倒闭,因此无法修复。对于这个问题处理(　　)

A.向公司管理层提出此问题,要求立即立项重新开发此业务系统,避免单位中存在这样的安全风险

B.既然此问题不是新发现的问题,之前已经存在,因此与自己无关,可以不予理会

C.让安全管理人员重新评估此漏洞存在的安全风险并给出进一步的防护措施后再考虑如何处理

D.让安全管理员找出验收材料看看有没有该业务系统源代码,自己修改解决这个漏洞

答案：C

解析：C 项更为合适一些。

195. 风险评估的过程包括（　）、（　）、（　）和（　）四个阶段。在信息安全风险管理过程中,风险评估建立阶段的输出,形成本阶段的最终输出《风险评估报告》,此文档为风险处理活动提供输入。(　　)贯穿风险评估的四个阶段。

A.风险评估准备；风险要素识别；风险分析；监控审查；风险结果判定；沟通咨询

B.风险评估准备；风险要素识别；监控审查 ;风险分析；风险结果判定；沟通咨询

C.风险评估准备；监控审查 ;风险要素识别；风险分析 ;风险结果判定；沟通咨询

D.风险评估准备；风险要素识别：风险分析：风险结果判定 监控审查，沟通咨询

答案：D

解析：

196. 信息安全风险值应该是以下哪些因素的函数？（）
A.信息资产的价值、面临的威胁以及自身存在的脆弱性
B.病毒、黑客、漏洞等
C.保密信息如国家秘密、商业秘密等
D.网络、系统、应用的复杂程度
答案：A
解析：信息安全风险三要素：资产、威胁、脆弱性

197. 以下关于开展软件安全开发必要性描述错误的是？（）
A.软件应用越来越广泛
B.软件应用场景越来越不安全
C.软件安全问题普遍存在
D.以上都不是
答案：D
解析：ABC 实际上都是软件安全开发的必要性

198. 软件危机是指落后的软件生产方式无法满足迅速增长的计算机软件需求，从而导致软件开发与维护过程中出现一系列严重问题的现象。为了克服软件危机，人们提出了用（）的原理来设计软件，这就是软件工程诞生的基础。
A.数学
B.软件学
C.运筹学
D.工程学
答案：D
解析：软件学科全称：计算机软件工程学,P392 页。

199. 在设计信息系统安全保障方案时，以下哪个做法是错误的（）
A.要充分企切合信息安全需求并且实际可行
B.要充分考虑成本效益，在满足合规性要求和风险处置要求的前提下，尽量控制成本
C.要充分采取新技术，在使用过程中不断完善成熟，精益求精，实现技术投入保障要求
D.要充分考虑用户管理和文化的可接受性，减少系统方案实验障碍
答案：C
解析：安全保障方案，一般谨慎选择新技术，大部分情况选择一些经过检验的成熟的安全技术。

200. 灾备指标是指信息安全系统的容灾抗毁能力，主要包括四个具体指标：恢复时间目标（Recovery Time Oh jective,RTO）.恢复点目标（Recovery Point Objective,RPO）降级操作目标（Degraded Operations Ob jective-DOO）和网络恢复目标（NeLwork Recovery Ob jective-NRO）,小华准备为其工作的信息系统拟定恢复点目标 RPO-O，以下描述中，正确的是（）。
A.RPO-O，相当于没有任何数据丢失，但需要进行业务恢复处理，覆盖原有信息
B.RPO-O，相当于所有数据全部丢失，需要进行业务恢复处理。修复数据丢失
C.RPO-O，相当于部分数据丢失，需要进行业务恢复处理，修复数据丢失
D.RPO-O，相当于没有任何数据丢失，且不需要进行业务恢复处理

答案：A
解析：

练习题第三卷

201. 关于信息安全事件管理和应急响应，以下说法错误的是（）。

A.应急响应是指组织为了应对突发/重大信息安全事件的发生所做的准备，以及在事件发生后所采取的措施

B.根据信息安全事件的分级参考要素，可将信息安全事件划分为 4 个级别：特别重大事件（I 级）、重大事件（II 级）、较大事件（III 级）和一般事件（IV 级）

C.应急响应方法，将应急响应管理过程分为遏制、根除、处置、恢复、报告和跟踪 6 个阶段

D.对信息安全事件的分级主要参考信息系统的重要程度、系统损失和社会影响三方面因素

答案：C

解析：应急响应方法是将应急响应管理过程分为 6 个阶段，为准备->检测->遏制->根除->恢复->跟踪总结。P152 页。

202. 规范的实施流程和文档管理，是信息安全风险评估能否取得成功的重要基础。某单位在实施风险评估时，形成了《待评估信息系统相关设备及资产清单》。在风险评估实施的各个阶段中，该《待评估信息系统相关设备及资产清单》应是如下（）中的输出结果。

A.风险要素识别

B.风险结果判定

C.风险分析

D.风险评估准备

答案：A

解析：在信息安全风险评估前，首先要进行的工作是资产分类与分级，资产清单作为资产登记的重要输出物。P253

203. 以下关于威胁建模流程步骤说法不正确的是（）。

A.威胁建模主要流程包括四步：确定建模对象、识别威胁、评估威胁和消减威胁

B.评估威胁是对威胁进行分析，评估被利用和攻击发生的概率，了解被攻击后资产的受损后果，并计算风险

C.消减威胁是根据威胁的评估结果，确定是否要消除该威胁以及消减的技术措施，可以通过重新设计直接消除威胁，或设计采用技术手段来消减威胁

D.识别威胁是发现组件或进程存在的威胁，它可能是恶意的，也可能不是恶意的，威胁就是漏洞

答案：D

解析：识别威胁是发现组件或进程存在的威胁，威胁是一种不希望发生、对资产目标有害的事件。从本质上看，威胁是潜在事件，它可能是恶意的，也可能不是恶意的。因此，威胁并不等于漏洞。P404 页。

204. 即使最好用的安全产品也存在（）。结果，在任何的系统中敌手最终都能够找出一个被开发出的漏洞。一种有效的对策是在敌手和它的目标之间配备多种（）。每一种机制都应包括（）两种手段。

A.安全缺陷；安全机制；外边和内部

B.安全机制；安全缺陷；保护和检测

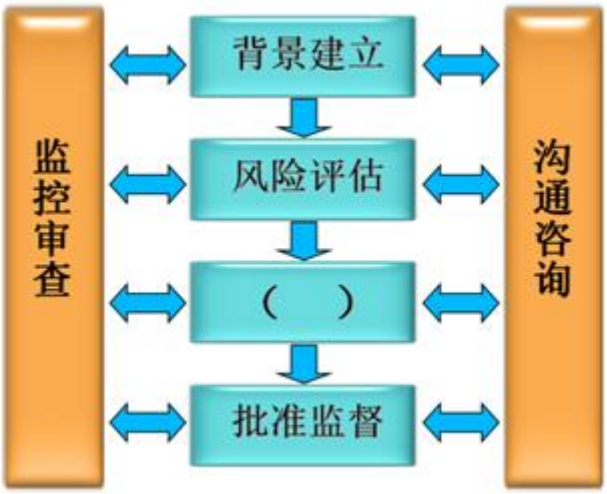
C.安全缺陷；安全机制；保护和检测

D.安全缺陷；保护和检测；安全机制

答案：C

解析：

205. 我国标准《信息安全风险管理指南》（GB/Z 24364）给出了信息安全风险管理的内容和过程，可以用下图来表示。图中空白处应该填写（）。



A.风险评价

B.风险计算

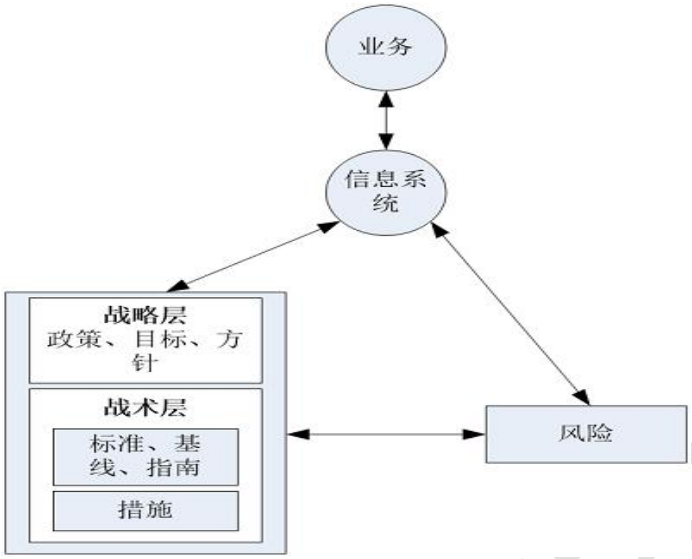
C.风险预测

D.风险处理

答案：D

解析：背景建立、风险评估、风险处理和批准监督是信息安全风险管理的 4 个具体步骤，监控审查和沟通咨询则贯穿于这 4 个基本步骤中。P89 页。

206. 信息系统安全保障是在信息系统的整个生命周期中，通过对信息系统的风险分析，制定并执行相应的安全保障策略，从技术、管理、工程和人员等方面提出安全保障要求，确保信息系统的保密性、完整性和可用性，降低安全风险到可接受的程度，从而保障系统实现组织机构的业务。信息系统保障工作如图所示。从该图不难得出，信息系统是（）。信息系统安全风险的因素主要有（）



A.用于采集、处理、存储、传输、分发和部署信息的整个基础设施、组织结构、人员和组件的总和；信息系统自身存在的漏洞

B.用于采集、处理整个基础设施、组织结构、人员和组件的总和；信息系统自身存在的漏洞、来自系统外部的威胁和人为操作引入的安全风险

C.用于采集、处理、存储、传输、分发和部署信息的整个基础设施、组织结构、人员和组件的总和；信息系统来自系统外部的威胁和人为操作引入的安全风险

D.用于采集、处理、存储、传输、分发和部署信息的整个基础设施、组织结构、人员和组件的总和；信息系统自身存在的漏洞和来自系统外部的威胁

答案：D

解析：信息系统是用于采集、处理、存储、传输、分发和部署信息的整个基础设施、组织结构、人员和组件的综合。信息系统安全风险是具体的风险，产生风险的因素主要有信息系统自身存在的漏洞和来自系统外部的威胁。P31 页。

207. 以下有关系统工程说法错误的是（）。

A.系统工程只需使用定量分析的方法，通过建立实际对象的数学模型，应用合适的优化算法对模型求解，解决实际问题

B.系统工程的目的是实现总体效果最优化，即从复杂问题的总体入手，认为总体大于各部分之和，各部分虽然存在不足，但总体可以优化

C.霍尔三维结构将系统工程整个活动过程分为前后紧密衔接的 7 个阶段和 7 个步骤

D.系统工程不属于基本理论，也不属于技术基础，它研究的重点是方法论

答案：A

解析：系统工程是 20 世纪中期兴起的一门新兴的交叉学科，它主要是应用定性分析和定量分析相结合的方法，通过实际对象的数学模型，应用合适的优化算法对模型进行求解，从而解决实际问题。P175 页。

208. 某集团公司根据业务需要，在各地分支机构部署前置机，为了保证安全，集团总部要求前置机开放日志共享，由总部服务器采集进行集中分析，在运行过程中发现攻击者也可通过共享从前置机中提取日志，从而导致部分敏感信息泄露，根据降低攻击面的原则，应采取以下哪项处理措施（）

A.日志的存在就是安全风险，最好的办法就是取消日志，通过设置让前置机不记录日志

B.只允许特定的 IP 地址从前置机提取日志，对日志共享设置访问密码且限定访问的时间

C.由于共享导致了安全问题，应直接关闭日志共享，禁止总部提取日志进行分析

D.为配合总部的安全策略，会带来一定的安全问题，但不影响系统使用，因此接受此风险

答案：B

解析：通过 IP 指定和访问策略的设定，有效的降低被攻击几率。

209. 随着信息安全涉及的范围越来越广，各个组织对信息安全管理的需求越来越迫切，越来越多的组织开始尝试使用参考 ISO27001 介绍的 ISMS 来实施信息安全管理体系，提高组织的信息安全管理能力。关于 ISMS，下面描述错误的是（ ）。

A.组织的管理层应确保 ISMS 目标和相应的计划得以制定，信息安全管理目标应明确、可度量，风险管理计划应具体，具备可行性

B.组织的管理层应全面了解组织所面临的信息安全风险，决定风险可接受级别和风险可接受准则，并确认接受相关残余风险

C.组织的信息安全目标、信息安全方针和要求应传达到全组织范围内，应包括全体员工，同时，也应传达到客户、合作伙伴和供应商等外部各方

D.在组织中，应由信息技术责任部门（如信息中心）制定并颁布信息安全方针，为组织的 ISMS 建设指明方向并提供总体纲领，明确总体要求

答案：D

解析：方针应由组织的管理层颁布。

210. GB/T 22080-2008 《信息技术 安全技术 信息安全管理体系 要求》指出，建立信息安全管理体系应参照 PDCA 模型进行，即信息安全管理体系应包括建立 ISMS、实施和运行 ISMS、监视和评审 ISMS、保持和改进 ISMS 等过程，并在这些过程中应实施若干活动。请选出以下描述错误的选项（ ）。

A.“制定 ISMS 方针”是建立 ISMS 阶段工作内容

B.“实施内部审核”是保持和改进 ISMS 阶段工作内容

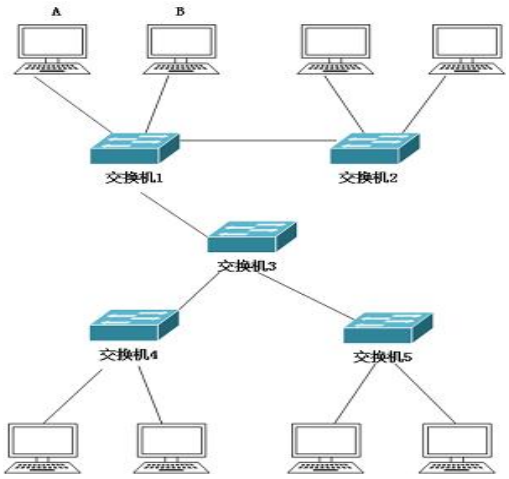
C.“实施培训和意识教育计划”是实施和运行 ISMS 阶段工作内容

D.“进行有效性测量”是监视和评审 ISMS 阶段工作内容

答案：B

解析：“实施内部审核”是监视和评审 ISMS 阶段工作内容。P98 页。

211. 某银行有 5 台交换机连接了大量交易机构的网络（如图所示），在基于以太网的通信中，计算机 A 需要与计算机 B 通信，A 必须先广播“ARP 请求信息”，获取计算机 B 的物理地址。每到月底时用户发现该银行网络服务速度极其缓慢。银行经调查后发现为了当其中一台交换机收到 ARP 请求后，会转发给接收端口以外的其他所有端口，ARP 请求会被转发到网络中的所有客户机上。为降低网络的带宽消耗，将广播流限制在固定区域内，可以采用的技术是（）。



A.动态分配地址

B.配置虚拟专用网络

C.VLAN 划分

D.为路由交换设备修改默认口令

答案：C

解析：VLAN 划分可以有效的限制广播域。

212. 以下关于检查评估和自评估说法错误的是（）。

A.信息安全风险评估分自评估、检查评估两形式。应以检查评估为主，自评估和检查评估相互结合、互为补充

B.自评估只能由组织自身发起并实施，对信息系统及其管理进行风险评估活动

C.检查评估可以依据相关标准的要求，实施完整的风险评估，也可以在自评估实施的基础上，对关键环节或重点内容实施抽样评估

D.信息安全风险评估应贯穿于网络和信息系统建设运行的全过程

答案：A

解析：信息安全风险评估分自评估、检查评估两形式。应以自评估为主，自评估和检查评估相互结合、互为补充。

213. 我国等级保护政策发展的正确顺序是（）。

①等级保护相关政策文件颁布

②计算机系统安全保护等级划分思想提出

③等级保护相关标准发布

④网络安全法将等级保护制度作为基本国策

⑤等级保护工作试点

A.①②③④⑤

B.②⑤①③④

C.①②④③⑤

D.②③①⑤④

答案：B

解析：计算机系统安全保护等级划分思想提出（1994-1999）；等级保护工作试点（2002-2006）；等级保护相关政策文件颁布（2004-2009）；等级保护相关标准发布（2008-2014）;网络安全法明确我国实行网络安全等级保护制度（2016）；P61 页

214. 以下关于 Windows 操作系统身份标识与鉴别，说法不正确的是（）。

A.Windows 操作系统远程登录经历了 SMB 鉴别机制、LM 鉴别机制、NTLM 鉴别机制、Kerberos 鉴别体系等阶段

B.完整的安全标识符（SID）包括用户和组的安全描述，48 比特的身份特权、修订版本和可变的验证值

C.本地安全授权机构（LSA）生成用户账户在该系统内唯一的安全标识符（SID）

D.用户对鉴别信息的操作，如更改密码等都通过一个以 Administrator 权限运行的服务“Security Accounts Manager”来实现

答案：D

解析：用户对鉴别信息的操作，如更改密码等都通过一个以 system 权限运行的服务“Security Accounts Manager”来实现。P357 页。

215. 数据在进行传输前，需要由协议栈自上而下对数据进行封装。TCP/IP 协议中,数据封装的顺序是（）。

A.传输层、网络接口层、互联网络层

B.传输层、互联网络层、网络接口层

C.互联网络层、传输层、网络接口层

D.互联网络层、网络接口层、传输层

答案：B

解析：TCP/IP 协议模型自上而下分别是：应用层、传输层、互联网络层、网络接口层

216. 分组密码算法是一类十分重要的密码算法，下面描述中，错误的是（）。

A.分组密码算法要求输入明文按组分成固定长度的块

B.分组密码算法也称为序列密码算法

C.分组密码算法每次计算得到固定长度的密文输出块

D.常见的 DES、IDEA 算法都属于分组密码算法

答案：B

解析：分组密码是在加密过程中将明文进行分组后在进行加密，序列密码又叫流密码对每一个字节进行加密。

217. 以下关于项目的含义，理解错误的是（）。

A.项目有明确的开始日期，结束日期由项目的领导者根据项目进度来随机确定

B.项目目标要遵守 SMART 原则,即项目的目标要求具体(Specific)、可测量(Measurable)、需相关方的一致同意(Agree to)、现实 (Realistic)、有一定的时限 (Time-oriented)

C.项目资源指完成项目所需要的人、财、物等

D.项目是为达到特定的目的、使用一定资源、在确定的期间内、为特定发起人而提供独特的产品、服务或成果而进行的一次性努力

答案：A

解析：结束日期并非由领导者随机确定，项目上习惯把验收报告日期视为结束日期，另有约定的以约定为准。

218. 应急响应是信息安全事件管理的重要内容之一。关于应急响应工作，下面描述错误的是（ ）。

A.信息安全应急响应，通常是指一个组织为了应对各种安全意外事件的发生所采取的防范措施，既包括预防性措施，也包括事件发生后的应对措施

B.应急响应工作的起源和相关机构的成立和1988年11月发生的莫里斯蠕虫病毒事件有关，基于该事件，人们更加重视安全事件的应急处置和整体协调的重要性

C.应急响应工作有其鲜明的特点：具有高技术复杂性与专业性、强突发性、对知识经验的高依赖性，以及需要广泛的协调与合作

D.应急响应是组织在处置应对突发/重大信息安全事件时的工作，其主要包括两部分工作：安全事件发生时正确指挥、事件发生后全面总结

答案：D

解析：应急响应是指组织为了应对突发 / 重大信息安全事件的发生所做的准备，以及在事件发生后所采取的措施。

219. 小王在学习信息安全管理体系相关知识之后，对于建立信息安全管理体系，自己总结了下面四条要求，其中理解不正确的是（ ）。

A.信息安全管理体系应体现科学性和全面性的特点，因为要对信息安全管理涉及的方方面面实施较为均衡的管理，避免遗漏某些方面而导致组织的整体信息安全水平过低

B.信息安全管理体系的建立应参照国际国内有关标准实施，因为这些标准是标准化组织在总结研究了很多实际的或潜在的问题后，制定的能共同的和重复使用的规则

C.信息安全管理体系的建立应基于一次风险评估彻底解决所有安全问题的思想，因为这是国家有关信息安全的法律和法规方面的要求，这体现以预防控制为主的思想

D.信息安全管理体系应强调全过程和动态控制的思想，因为安全问题是动态的，系统所处的安全环境也不会一成不变，不可能建设永远安全的系统

答案：C

解析：“一次风险评估彻底解决所有安全问题”错误

220. 在设计信息系统安全保障方案时，以下哪个做法是错误的（）

A.要充分考虑成本效益，在满足合规性要求和风险处置要求的前提下，尽量控制成本

B.要充分符合信息安全需求并且实际可行

C.要使用当前最新的技术和成本最高的设备，从而保障信息系统的绝对安全

D.要充分考虑用户管理和文化的可接受性，减少系统方案实施障碍

答案：C

解析：“要使用当前最新的技术和成本最高的设备”错误，使用经过检验成熟及安全的技术或设备。

221. 一个密码系统至少由明文、密文、加密算法、解密算法和密钥 5 部分组成，而其安全性是由下列哪个选项决定的（）。

A.加密和解密算法

B.解密算法

C.密钥

D.加密算法

答案：C

解析：系统的保密性不依赖于加密体制和算法的保密，而依赖于密。P271 页。

222. 小李在某单位是负责信息安全风险管理方面工作的部门领导，主要负责对所在行业的新人进行基本业务素质培训。一次培训的时候，小李主要负责讲解风险评估方法。请问小李的所述论点中错误的是哪项（）

A.定性风险分析需要凭借分析者的经验和直觉或者业界的标准和惯例，因此具有随意性

B.定量风险分析试图在计算风险评估与成本效益分析期间收集的各个组成部分的具体数字值，因此更具客观性

C.风险评估方法包括：定性风险分析、定量风险分析以及半定量风险分析

D.半定量风险分析技术主要指在风险分析过程中综合使用定性和定量风险分析技术对风险要素的赋值方式，实现对风险各要素的度量数值化

答案：A

解析：定性风险分析是利用已识别风险的发生概率、风险发生对项目目标的相应影响，以及其他因素。

223. 关于标准，下面哪项理解是错误的（）。

A.标准是在一定范围内为了获得最佳秩序，经协商一致制定并由公认机构批准，共同重复使用的一种规范性文件。标准是标准化活动的重要成果

B.行业标准是针对没有国家标准而又需要在全国某个行业范围内统一的技术要求而制定的标准。同样是强制性标准，当行业标准和国家标准的条款发生冲突时，应以国家标准条款为准

C.国际标准是由国际标准化组织通过并公开发布的标准。同样是强制性标准，当国家标准和国际标准的条款发生冲突时，应以国际标准条款为准

D.地方标准由省、自治区、直辖市标准化行政主管部门制定，并报国务院标准化行政主管部门和国务院有关行政主管部门备案，在公布国家标准之后，该地方标准即应废止

答案：C

解析：国际标准是由国际标准化组织通过并公布的标准，同样是强制性标准，当国家标准和国际标准的条款发生冲突，应以国家标准条款为准。

224. 作为信息安全从业人员，以下哪种行为违反了 CISP 职业道德准则（）

A.不在计算机网络系统中进行造谣、欺诈、诽谤等活动

B.通过公众网络传播非法软件

C.帮助和指导信息安全同行提升信息安全保障知识和能力

D.抵制通过网络系统侵犯公众合法权益

答案：B

解析：违反了职业道德中的“诚实守信，遵纪守法”准则。

225. 以下哪项的行为不属于违反国家保密规定的行为（）

A.以不正当手段获取商业秘密

B.在私人交往中涉及国家秘密

C.将涉密计算机、涉密存储设备接入互联网及其他公共信息网络

D.通过普通邮政等无保密措施的渠道传递国家秘密载体

答案：A

解析：A 属于商业秘密，不属于国家秘密。

226. 关于信息安全保障技术框架（IATF），以下说法不正确的是（）。

A.IATF 深度防御战略要求在网络体系结构的各个可能位置实现所有信息安全保障机制

B.分层策略允许在适当的时候采用低安全级保障解决方案以便降低信息安全保障的成本

C.IATF 从人、技术和操作三个层面提供一个框架实施多层保护，使攻击者即使攻破一层也无法破坏整个信息基础设施

D.允许在关键区域（例如区域边界）使用高安全级保障解决方案，确保系统安全性

答案：A

解析：IATF 深度防御战略要求在人、技术和操作 3 个核心要素来共同实现。

227. 主体和客体是访问控制模型中常用的概念。下面描述中错误的是（）。

A.主体是动作的实施者，比如人、进程或设备等均是主体，这些对象不能被当作客体使用

B.一个主体为了完成任务，可以创建另外的主体，这些主体可以独立运行

C.主体是访问的发起者，是一个主动的实体，可以操作被动实体的相关信息或数据

D.客体也是一种实体，是操作的对象，是被规定需要保护的资源

答案：A

解析：主体和客体是相对的概念，主体在一定情况下可以成为客体，客体也可以成为主体。

228. 若一个组织声称自己的 ISMS 符合 ISO/IEC 27001 或 GB/T22080 标准要求，其信息安全控制措施通常需要在物理和环境安全方面实施常规控制。物理和环境安全领域包括安全区域和设备安全两个控制目标。安全区域的控制目标是防止对组织场所和信息的未授权物理访问、损坏和干扰，关键或敏感的信息及信息处理设施应放在安全区域内，并受到相应保护，该目标可以通过以下控制措施来实现，不包括哪一项（）

A.物理安全边界、物理入口控制

B.在安全区域工作，公共访问、交接区安全

C.通信安全、合规性

D.办公室、房间和设施的安全保护，外部和环境威胁的安全防护

答案：C

解析：C 项不属于物理和环境安全的范畴。

229. 你是单位安全主管，由于微软刚发布了数个系统漏洞补丁，安全运维人员给出了针对此批漏洞修补的四个建议方案，请选择其中一个最优方案执行（）

A.对于重要的服务，应在测试环境中安装并确认补丁兼容性问题后再在正式生产环境中部署

B.对于服务器等重要设备，立即使用系统更新功能安装这批补丁，用户终端计算机由于没有重要数据，由终端自行升级

C.本次发布的漏洞目前尚未出现利用工具，因此不会对系统产生实质性危害，所以可以先不做处理

D.由于本次发布的数个漏洞都属于高危漏洞，为了避免安全风险，应对单位所有的服务器和客户端尽快安装补丁

答案：A

解析：对于重要的服务，在测试环境中安装并确定补丁的兼容性问题后再在正式生产环境中部署，这样可以有效的避免应补丁升级后可能会对系统服务造成不必要的影响。

230. 《国家信息化领导小组关于加强信息安全保障工作的意见》中办发[2003]27 号明确了我国信息安全保障工作的（）、加强信息安全保障工作的（）、需要重点加强的信息安全保障工作。27 号文的重大意义是，它标志着我国信息安全保障工作有了（）、我国最近十余年的信息安全保障工作都是围绕此政策性文件来（）的、促进了我国（）的各项工作。

A.方针和总体要求；主要原则；总体纲领；展开和推进；信息安全保障建设

B.总体要求；总体纲领；主要原则；展开；信息安全保障建设

C.方针；主要原则；总体纲领；展开和推进；信息安全保障建设

D.总体要求；主要原则；总体纲领；展开；信息安全保障建设

答案：A

解析：27 号文标志着我国信息安全保障工作有了总体纲领。

231. PDCA 循环又叫戴明环，是管理学常用的一种模型。关于 PDCA 四个字母，下面理解错误的是（ ）。

A.D 是 Do，指实施、具体运作，实现计划中的内容

B.P 是 Prepare，指准备，包括明确对象、方法，制定活动规划

C.A 是 Act 或 Adjust，指改进、完善和处理，对总结检查的结果进行处理，对成功的经验加以肯定，并予以标准化，总结失败的教训并加以重视，对没有解决的问题，应该交给下一个 PDCA 循环解决

D.C 是 Check，指检查、总结执行计划的结果，明确效果，找出问题

答案:B

解析：PDCA（plan-do-check-act 或者 plan-do-check-adjust）循环的 4 个阶段，“策划-实施-检查-改进”。P94 页。

232. 以下说法正确的是（）。

A.软件测试计划开始于软件设计阶段，完成于软件开发阶段

B.验收测试是由承建方和用户按照用户使用手册执行软件验收

C.软件测试的目的是为了验证软件功能是否正确

D.监理工程师应按照有关标准审查提交的测试计划，并提出审查意见

答案：D

解析：软件测试开始与软件设计阶段，在软件开发完成以后还有回归测试，验收测试；验收测试一般按照软件开发预期（软件开发需求或者合同）来进行；软件测试的目的是检验它是否满足规定的需求或是弄清预期结果与实际结果之间的差异。P416 页

233. 规范的实施流程和文档管理，是信息安全风险评估能否取得成果的重要基础。某单位在实施风险评估时，按照规范形成了若干文档，其中，下面（）中的文档应属于风险评估中“风险要素识别”阶段输出的文档。

A.《风险评估方法和工具列表》，主要包括拟用的风险评估方法和测试评估工具等内容

B.《已有安全措施列表》，主要包括经检查确认后的已有技术和管理各方面安全措施等内容

C.《风险评估方案》，主要包括本次风险评估的目的、范围、目标、评估步骤、经费预算和进度安排等内容

D.《风险评估准则要求》，主要包括现有风险评估参考标准、采用的风险分析方法、资产分类标准等内容

答案：B

解析：P256 页或者见下表：

工作阶段	输出文档	文档内容
准备阶段	《系统调研报告》	对被评估系统的调查了解情况，涉及网络结构、系统情况、业务应用等内容
	《风险评估方案》	根据调研情况及评估目的，确定评估的目标、范围、对象、工作计划、主要技术路线、应急预案等
识别阶段	《资产价值分析报告》	资产调查情况，分析资产价值，以及重要资产说明
	《威胁分析报告》	威胁调查情况，明确存在的威胁及其发生的可能性，以及严重威胁说明
	《安全技术脆弱性分析报告》	物力、网络、主机、应用、数据等方面的脆弱性说明
	《安全管理脆弱性分析报告》	安全组织、安全策略、安全制度、人员安全、系统运维等方面的脆弱性说明
	《已有安全措施分析报告》	分析组织或信息系统已部署安全措施的有效性，包括技术和管理两方面的安全管控说明
风险分析	《风险评估报告》	对资产、威胁、脆弱性等评估数据进行关联计算、分析评价等，应说明风险分析模型、分析计算方法
风险处置	《安全整改建议》	对评估中发现的安全问题给予有针对性的风险处置建议

234. 在某次信息安全应急响应过程中，小王正在实施如下措施：消除或阻断攻击源、找到并消除系统的脆弱性/漏洞、修改安全策略、加强防范措施、格式化被感染恶意程序的介质等。请问，按照 PDCERF 应急响应方法，这些工作应处于以下哪个阶段（）

A.遏制阶段

B.检测阶段

C.准备阶段

D.根除阶段

答案：D

解析：常见的根除措施有消除或阻断攻击源、找到并消除系统的脆弱性/漏洞、修改安全策略、加强防范措施、格式化被感染恶意程序的介质等。P154 页。

235. 在信息安全管理体系的实施过程中，管理者的作用对于信息安全管理体系能否成功实施非常重要，但是以下选项中不属于管理者应有职责的是（）。

A.确保组织的信息安全管理体系目标和相应的计划得以制定，目标应明确、可度量，计划应具体、可实施

B.制定并颁布信息安全方针，为组织的信息安全管理体系建设指明方向并提供总体纲领，明确总体要求

C.建立健全信息安全制度，明确安全风险管理作用，实施信息安全风险评估过程，确保信息安全风险评估技术选择合理、计算正确

D.向组织传达满足信息安全的重要性，传达满足信息安全要求、达成信息安全目标、符合信息安全方针、履行法律责任和持续改进的重要性

答案：C

解析：“实施信息安全风险评估过程”不属于管理者责任。

236. 下面有关软件安全问题的描述中，哪项不是由于软件设计缺陷引起的（）

A.设计了用户权限分级机制和最小特权原则，导致软件在发布运行后，系统管理员不能查看系统审计信息

B.设计了缓存用户隐私数据机制以加快系统处理性能，导致软件在发布运行后，被黑客攻击获取到用户隐私数据

C.设计了采用不加盐（SALT）的 SHA-1 算法对用户口令进行加密存储，导致软件在发布运行后，不同的用户如使用了相同的口令会得到相同的加密结果，从而可以假冒其他用户登录

D.设计了采用自行设计的加密算法对网络传输数据进行保护，导致软件在发布运行后，被攻击对手截获网络数据并破解后得到明文

答案：A

解析：首先是软件设计缺陷，其次对应的设计有缺陷导致某一后果。用户权限分级机制和最小特权原则导致系统管理员不能查看系统审计信息，这个在安全、保密等领域是专门这样设计的；BCD 都是由软件缺陷引起的。

237．对于关键信息基础设施的理解以下哪项是正确的（）

A.关键信息基础设施是国家最为重要的设施，包括三峡大坝水利设施、神舟载人航天设施和高铁网络设施

B.等级保护定级的系统属于关键信息基础设施

C.我国总体国家安全观将信息安全作为国家安全的一个重要组成部分，说明缺少信息安全我国的国家安全将无法得到保障

D.关键信息基础设施不会向公众提供服务，所以受到攻击损害后不会影响到我们日常生活

答案：C

解析：关键信息基础设施是指面向公众提供网络信息服务或支撑能源、通信、金融、交通、公用事业等重要行业运行的信息系统或工业控制系统。显然载人航天不属于，等级保护定级有 1-5 级，定级标准和要求和关键信息基础设施保护有很大的不同，所以 B 错误；D 概念错误。

238．密码学是网络安全的基础，但网络安全不能单纯依靠安全的密码算法，密码协议也是网络安全的一个重要组成部分。下面描述中，错误的是（）。

A.密码协议（cryptographic protocol），有时也称安全协议（security protocol），是使用密码学完成某项特定的任务并满足安全需求的协议，其目的是提供安全服务

B.根据密码协议应用目的的不同，参与该协议的双方可能是朋友和完全信任的人，也可能是敌人和互相完全不信任的人

C.在实际应用中，密码协议应按照灵活性好、可扩展性高的方式制定，不要限制和框住所有的执行步骤，有些复杂的步骤可以不明确处理方式

D.密码协议定义了两方或多方之间为完成某项任务而指定的一系列步骤，协议中的每个参与方都必须了解协议，且按步骤执行

答案：C

解析：“不要限制和框住所有的执行步骤，有些复杂的步骤可以不明确处理方式”错误

239．以下哪种风险被认为是合理的风险（）。

A.残余风险

B.未识别的风险

C.可接受的风险

D.最小的风险

答案：C

解析：残余风险未必是可接受的风险，如果残余风险不可接受还要进一步处理才行例如风险转移，风险规避。

240. 在某信息系统的设计中，用户登录过程是这样的：（1）用户通过 HTTP 协议访问信息系统；（2）用户在登录页面输入用户名和口令；（3）信息系统在服务器端检查用户名和密码的正确性，如果正确，则鉴别完成。可以看出，这个鉴别过程属于（）。

A.双向鉴别

B.三向鉴别

C.第三方鉴别

D.单向鉴别

答案：D

解析：参考登陆网页系统，属于单向鉴别。

241. 信息安全保障技术框架（Information Assurance Technical Framework，IATF），目的是为保障政府和工业的（）提供了（）。信息安全保障技术框架的一个核心思想是（）。深度防御战略的三个核心要素：（）、技术和运行（亦称为操作）。

A.信息基础设施；深度防御；技术指南；人员

B.技术指南；信息基础设施；深度防御；人员

C.信息基础设施；技术指南；人员；深度防御

D.信息基础设施；技术指南；深度防御；人员

答案：D

解析：P28 页

242. 具有行政法律责任强制力的安全管理规定和安全制度包括（）

（1）安全事件（包括安全事故）报告制度（2）安全等级保护制度（3）信息系统安全监控（4）安全专用产品销售许可证制度

A.2，3

B.1，2，3

C.2，3，4

D.1，2，4

答案：D

解析：（1）来源于《安全生产法》第八十条，（2）（4）是常识。

243. 应用安全，一般是指保障应用程序使用过程和结果的安全。以下内容中不属于应用安全防护考虑的是（）。

A.机房与设施安全，保证应用系统处于有一个安全的环境条件，包括机房环境、机房安全等级、机房的建造和机房的装修等

B.身份鉴别，应用系统应对登录的用户进行身份鉴别，只有通过验证的用户才能访问应用系统资源

C.安全标记，在应用系统层面对主体和客体进行标记，主体不能随意更改权限，增加访问控制的力度，限制非法访问

D.剩余信息保护，应用系统应加强硬盘、内存或缓冲区中剩余信息的保护，防止存储在硬盘、内存或缓冲区中的信息被非授权的访问

答案：A
解析：机房与设施安全属于物理环境安全范畴，不属于应用安全范畴。

244. 近几年,无线通信技术迅猛发展,广泛应用于各个领域。而无线信道是一个开放性信道,它在赋予无线用户通信自由的同时也给无线通信网络带来一些不安全因素,下列选项中,对无线通信技术的安全特点描述正确的是（）
A.无线信道是一个开放信道,任何具有适当无线设备的人均可以通过搭线窃听而获得网络通信内容
B.通过传输流分析,攻击者可以掌握精确的通信内容
C.对于无线局域网络和无线个人区域网络来说,它们的通信内容更容易被窃听
D.群通信方式可以防止网络外部人员获取网络内部通信内容
答案：C
解析：A 项，搭线窃听错误一般使用无线嗅探获得别人的网络通信内容，B“掌握精确的通信内容”有点夸张，一般获得大概的内容就够用了，D 群通信很容易导致外部人员获取网内通信内容。

245. 下列信息安全评估标准中，哪一个是我国信息安全评估的国家标准？（）
A.TCSEC 标准
B.CC 标准
C.FC 标准
D.ITSEC 标准
答案：B P241 页
解析：TCSEC 标准（可信计算机系统评估标准）是美国政府国防部标准，为评估计算机系统内置的计算机安全功能的有效性设定了基本要求,在 2005 年最初被公布的国际标准《通用准则（CC）》所取代，《信息技术安全性评估准则》是我国在 2008 年等同采用《ISO/IEC 15408：2005 信息技术-安全技术-信息技术安全评估标准》形成的国家标准，标准编号为 GB/T 18336。标准定义了作为评估信息技术产品和系统安全特性的基础准则，由于历史和连续性的原因，仍叫通用准则（Common Criteria，CC）；FC 上美国 1991 年制定了一个《联邦（最低安全要求）评估准则》，但由于其不完备性，未能推行；ITSEC（Information Technology Security Evaluation Criteria，信息技术安全评估标准）是评估产品和系统中计算机安全性的一套结构化的标准。于 1990 年 5 月首先在法国，德国，荷兰和英国出版，后来主要在一些欧洲国家使用。

246. 组织应依照已确定的访问控制策略限制对信息和（ ）功能的访问。对访问的限制要基于各个业务应用要求，访问控制策略还要与组织访问策略一致。应建立安全登录规程控制实现对系统和应用的访问。宜选择合适的身份验证技术以验证用户身份。在需要强认证和（）时，宜使用加密、智能卡、令牌或生物手段等替代密码的身份验证方法。应建立交互式的口令管理系统，并确保使用优质的口令。对于可能覆盖系统和应用的控制措施的实用工具和程序的使用，应加以限制并（ ）。对程序源代码和相关事项（例如设计、说明书、验证计划和确认计划）的访问宜严格控制，以防引入非授权功能、避免无意识的变更和维持有价值的知识产权的（ ）。对于程序源代码的保存，可以通过这种代码的中央存储控制来实现，更好的是放在( )中。
A.应用系统；身份验证；严格控制；保密性；源程序库
B.身份验证；应用系统；严格控制；保密性；源程序库
C.应用系统；严格控制；身份验证；保密性；源程序库

D.应用系统；保密性；身份验证；严格控制；源程序库
答案：A
解析：教材第 112 页 9.4.5 表格之下的所有部分，到 118 页的最上面一段

247．信息是流动的，在信息的流动过程中必须能够识别所有可能途径的（）与（）；面对于信息本身，信息的敏感性的定义是对信息保护的（）和（），信息在不同的环境存储和表现的形式也决定了（）的效果，不同的截体下，可能体现出信息的（）、临时性和信息的交互场景，这使得风险管理变得复杂和不可预测。
A.基础；依据；载体；环境；永久性；风险管理
B.基础；依据；载体；环境；风险管理；永久性
C.载体；环境；风险管理；永久性；基础；依据
D.载体；环境；基础；依据；风险管理；永久性
答案：D
解析：

248．某项目组进行风险评估时由于时间有限，决定采用基于知识的分析方法，使用基于知识的分析方法进行风险评估，最重要的在于评估信息的采集，该项目组对信息源进行了讨论，以下说法中不可行的是（）
A.可以通过对当前的信息安全策略和相关文档进行复查采集评估信息
B.可以通过进行实施考察的方式采集评估信息
C.可以通过建立模型的方法采集评估信息
D.可以制作问卷，进行调查
答案：C
解析：基于知识的风险评估方法和基于模型的风险评估方法是并列关系

249．小张在一不知名的网站上下载了鲁大师并进行了安装，电脑安全软件提示该软件有恶意捆绑，小张惊出一身冷汗，因为他知道恶意代码终随之进入系统后会对他的系统信息安全造成极大的威胁，那么恶意代码的软件部署常见的实现方式不包括（）
A.攻击者在获得系统的上传权限后，将恶意部署到目标系统
B.恶意代码自身就是软件的一部分，随软件部署传播
C.内镶在软件中，当文件被执行时进入目标系统
D.恶意代码通过网上激活
答案：D
解析：“恶意代码通过网上激活”错误，一些恶意代码一经下载就可以自动激活运行。

250．恶意代码经过 20 多年的发展,破坏性、种类和感染性都得到增强。随着计算机的网络化程度逐步提高,网络播的恶意代码对人们日常生活影响越来越大。小李发现在自己的电脑查出病毒的过程中,防病毒软件通过对有毒件的检测,将软件行为与恶意代码行为模型进行匹配,判断出该软件存在恶意代码,这种方式属于( )
A.简单运行
B.行为检测
C.特征数据匹配
D.特征码扫描
答案：B

解析：恶意代码检测包括特征码扫描和行为检测，行为检测是防病毒软件通过对软件的行为检测，将软件行为与恶意代码行为模型进行匹配，以判断是否为恶意代码。P370 页

251. 管理层应该表现对 (),程序和控制措施的支持, 并以身作则。管理职责要确保雇员和承包方人员都了()角色和职责,并遵守相应的条款和条件。组织要建立信息安全意识计划,并定期组织信息安全()。组织立正式的(),确保正确和公平的对待被怀疑安全违规的雇员。纪律处理过程要规定(),考虑例如违规的性质、重要性及对于业务的影响等因素,以及相关法律、业务合同和其他因素。

A.信息安全:信息安全政策:教育和培训;纪律处理过程:分级的响应

B.信息安全政策:信息安全:教育和培训:纪律处理过程:分级的响应

C.信息安全政策:教育和培训:信息安全;纪律处理过程:分级的响应

D.信息安全政策:纪律处理过程信息安全;教育和培训:分级的响应

答案：B

解析：P107 页

252. 在一个网络中,当拥有的网络地址容量不够多,或普通终端计算机没有必要分配静态 IP 地址时,可以采用通过在计算机连接到网络时,每次为其临时在 IP 地址池中选择一个 IP 地址并分配的方式为( )

A.动态分配 IP 地址

B.静态分配 IP 地址

C.网络地址转换分配地址

D.手动分配

答案：A

解析：“没有必要分配静态”首先排除 B，实际上题干介绍的是动态分配 IP 地址概述。

253. 信息安全风险管理是基于( )的信息安全管理,也就是,始终以( )为主线进行信息安全的管理。应根据实际( )的不同来理解信息安全风险管理的侧重点,即()选择的范围和对象重点应有所不同。

A..风险; 风险; 信息系统: 风险管理

B.风险; 风险; 风险管理; 信息系统

C.风险管理; 信息系统; 风险;风险

D.风险管理; 风险; 风险 ;信息系统

答案：a)

解析：P84 页

254.数据链路层负责监督相邻网络节点的信息流动,用检错或纠错技术来确保正确的传输,确保解决该层的流量控制问题。数据链路层的数据单元是( )

A.报文

B.比特流

C.帧

D.包

答案：C

解析：P330 页

255. 以下对于标准化特点的描述哪项是错误的?

A.标准化的对象是共同的、可重复的事物。不是孤立的一件事、一个事物
B.标准化必须是静态的,相对科技的进步和社会的发展不能发现变化
C.标准化的相对性,原有标准随着社会发展和环境变化,需要更新
D.标准化的效益,通过应用体现经济和社会效益,否则就没必要
答案：B
解析：标准化是动态的,会随着科技的进步和社会的发展与时俱进。

256. 以下哪个是国际信息安全标准化组织的简称?( )
A.ANSI
B.ISO
C.IEE
D.NIST
答案：B
解析：ANSI:美国国家标准学会(AMERICAN NATIONAL STANDARDS INSTITUTE)；ISO：国际标准化组织（International Organization for Standardization）；IEE:国际电气工程师学会（The Institution of Electrical Engineers）；NIST：美国国家标准与技术研究院(National Institute of Standards and Technology)直属美国商务部，从事物理、生物和工程方面的基础和应用研究。

257. 某公司财务服务器受到攻击被攻击者删除了所有用户数据,包括系统日志,公司网络管理员在了解情况后,给出了一些解决措施建议，作为信息安全主管，你必须指出不恰当的操作并阻止此次操作（）
A.由于单位并无专业网络安全应急人员,网络管理员希望出具授权书委托某网络安全公司技术人员对本次攻击进行取证
B.由于公司缺乏备用硬盘,因此计划将恢复服务器上被删除的日志文件进行本地恢复后再提取出来进行取证
C.由于公司缺乏备用硬盘,因此网络管理员申请采购与服务器硬盘同一型号的硬盘用于存储恢复出来的数据
D.由于公司并无专业网络安全应急人员,因此由网络管理员负责此次事件的应急协调相关工作
答案：B
解析：取证要求不能本地恢复，恢复出的日志数据会覆盖现有日志内容，应避免对原始盘进行任何写入操作，防止破坏证据。

258. 在你对远端计算机进行 ping 操作,不同操作系统回应的数据包中初始 TTL 值是不同的, TTL 是 IP 协议包中的一个值,它告诉网络,数据包在网络中的时间是否太长而应被丢弃。(简而言之,你可以通过 TTL 值推算一下下列数据包已经通过了多少个路由器)根据回应的数据包中的 TL 值,可以大致判断( )
A.内存容量
B.操作系统的类型
C.对方物理位置
D.对方的 MAC 地址
答案：B

解析：TTL 是 Time To Live 的缩写，该字段指定 IP 包被路由器丢弃之前允许通过的最大网段数量，Widows 操作系统默认是 128，Linux 默认是 64，每经过一个路由器减 1。

259.（ ）攻击是建立在人性“弱点”利用基础上的攻击,大部分的社会工程学攻击都是经过（ ）才能实施成功的。即使是最简单的“直接攻击”也需要进行 （ ）。如果希望受害者接受攻击者所（ ）,攻击者就必须具备这个身份需要的 （ ）
A.社会工程学：精心策划；前期的准备；伪装的身份；一些特征
B.精心策划；社会工程学；前期的准备；伪装的身份；一些特征
C.精心策划；社会工程学；伪装的身份；前期的准备：一些特征
D.社会工程学；伪装的身份；精心策划；前期的准备；一些特征
答案：a)
解析：P221 页

260.内容安全是我国信息安全保障工作中的一个重要环节,互联网所带来的数字资源大爆发是使得内容安全越 越受到重视,以下哪个描述不属于内容安全的范畴 （ ）
A.某杂志在线网站建立内容正版化审核团队,对向网站投稿的内容进行版权审核,确保无侵犯版权行为后才能在网站好进行发布
B.某网站采取了技术措施,限制对同一 P 地址对网站的并发连接,避免爬虫通过大量的访问采集网站发布数据
C.某论坛根据相关法律要求，进行了大量的关键词过滤，使用户无法发布包含被过滤关键词的相关内容
D.某论坛根据国家相关法律要求,为了保证用户信息泄露,对所有用户信息,包括用户名、密码、身份证号等都进行了加密的存储
答案：D
解析：D 项是用户数据安全的范畴。

261.恶意软件抗分析技术的发展,恶意软件广泛使用了加壳、加密、混淆等抗分析技术,对恶意软件的分析难度越来越大。对恶意代码分析的研究已经成为信息安全领域的一个研究热点。小赵通过查阅发现一些安全软件的沙箱功能 实际上是虚拟化技术的应用,是动态分析中广泛采用的一种技术。小赵列出了一些动态分析的知识,其中错误的是（ ）
A.动态分析是指在虚拟运行环境中,使用测试及监控软件,检测恶意代码行为,分析其执行流程及处理数据的状态,从而判断恶意代码的性质,并掌握其行为特点
B.动态分析针对性强,并且具有较高的准确性,但由于其分析过程中覆盖的执行路径有限,分析的完整性难以保证
C.动态分析通过对其二进制文件的分析,获得恶意代码的基本结构和特征,了解其工作方式和机制
D.动态分析通过监控系统进程、文件和注册表等方面出现的非正常操作和变化,可以对恶意代码非法行为进行分析
答案：C
解析：“通过对其二进制文件的分析,获得恶意代码的基本结构和特征,了解其工作方式和机制”是静态分析的内容,P371 页。

262.操作系统是作为一个支撑软件,使得你的程序或别的应用系统在上面正常运行的一个环境。操作系统提供了多的管理功能,主要是管理系统的软件资源和硬件资源。操作系统

软件自身的不安全性,系统开发设计的不周而下的破绽,都给网络安全留下隐患。某公司的网络维护师为实现该公司操作系统的安全目标,按书中所学建立了相应的安全机制,这些机制不包括（）
A.标识与鉴别
B.访问控制
C.权限管理
D.网络云盘存取保护
答案：D
解析：D 不属于信息安全机制的范畴。

263.即时通讯安全是移动互联网时代每个用户和组织机构都应该认真考虑的问题,特别对于使用即时通讯进行工作交流和协作的组织机构。安全使用即时通讯应考虑许多措施,下列措施中错误的是(　　)
A.如果经费许可,可以使用自建服务器的即时通讯系统
B.在组织机构安全管理体系中制定相应安全要求,例如禁止在即时通讯中传输敏感及以上级别的文档;建立管理流程及时将离职员工移除等
C.选择在设计上已经为商业应用提供安全防护的即时通讯软件,例如提供传输安全性保护等即时通讯
D.涉及重要操作包括转账无需方式确认
答案：D
解析：D 项常识性错误。

264. 以下哪些因素属于信息安全特征?(　)
A.系统和网络的安全
B.系统和动态的安全
C.技术、管理、工程的安全
D.系统的安全;动态的安全;无边界的安全;非传统的安全
答案：D
解析：P3

265. 以下对单点登录技术描述不正确的是:()。
A.单点登录技术实质是安全凭证在多个用户之间的传递或共享
B.使用单点登录技术用户只需在登录时进行一次注册,就可以访问多个应用
C.单点登录不仅方便用户使用,而且也便于管理
D.使用单点登录技术能简化应用系统的开发
答案：A
解析：单点登录技术实质是安全凭证在多个应用系统之间的传递或共享。

266. 软件安全设计和开发中应考虑用户隐私保护，以下关于用户隐私保护的说法错误的是（）
A.告诉用户需要收集什么数据及搜集到的数据会如何被使用
B.当用户的数据由于某种原因要被使用时，给客户选择是否允许
C.用户提交的用户名和密码属于隐私数据，其他都不是
D.确保数据的使用符合国家、地方、行业的相关法律法规

答案:C
解析:客户的私人信息都是隐私数据而不仅仅是用户名和密码。

267. 自主访问控制(DAC)是应用很广泛的访问控制方法,常用于多种商业系统中。以下对 DAC 模型的理解中,存在错误的是（）
A.在 DAC 模型中,资源的所有者可以规定谁有权访问它们的资源
B.DAC 是一种对单个用户执行访问控制的过程和措施
C.DAC 可为用户提供灵活调整的安全策略,具有较好的易用性可扩展性,可以抵御特洛伊木马的攻击
D.在 DAC 中,具有某种访问能力的主体能够自主地将访问权的某个子集授予其它主体
答案:C
解析:DAC 不能抵御特洛伊木马攻击，P306 页

268. 关于微软的 SDL 原则，弃用不安全的函数属于哪个阶段？（ ）
A.规则
B.计划
C.实现
D.测试
答案:C
解析:弃用不安全函数属于编码实现阶段的工作，P398 页。

269. 优秀源代码审核工具有哪些特点（ ）1 安全性； 2 多平台性； 3 可扩民性； 4 知识性； 5 集成性。
A.1 2 3 4 5
B. 2 3 4
C.1 2 3 4
D.2 3
答案:A
解析:P416 页

270. 某公司在讨论如何确认已有的安全措施，对于确认已有这全措施，下列选项中近期内述不正确的是（ ）
A.对有效的安全措施继续保持，以避免不必要的工作和费用，防止安全措施的重复实施
B.安全措施主要有预防性、检测性和纠正性三种
C.安全措施的确认应评估其有效性，即是否真正地降低了系统的脆弱性，抵御了威胁
D.对确认为不适当的安全措施可以置不顾
答案:D
解析:常识性错误。

271. 密码是一种用来混淆的技术，使用者希望正常的（可识别的）信息转变为无法识别的信息。但这种无法识别信息部分是可以再加工并恢复和破解的，小刚是某公司新进的员工，公司要求他注册一个公司网站的账号，小刚使用一个安全一点的密码，请问以下选项中哪个密码是最安全（ ）
A.使用和与用户名相同的口令

B.选择可以在任何字典或语言中找到的口令
C.选择任何和个人信息有关的口令
D.采取数字，字母和特殊符号混合并且易于记忆
答案:D
解析:常识问题

272．基于对（ ）的信任，当一个请求或命令来自一个“权威”人士时，这个请求就可能被毫不怀疑的（ ）。在（ ）中，攻击者伪装成“公安部门”人员要求受害者对权威的信任。在（ ）中，攻击者可能伪装成监管部门、信息系统管理人员等身份，去要求受害者执行操作，例如伪装成系统管理员，告诉用户请求配合进行一次系统测试，要求（ ）等 。
A.权威；执行；电信诈骗；网络攻击；更改密码
B.权威；执行；网络攻击；电信诈骗；更改密码
C.执行；权威；电信诈骗；网络攻击；更改密码
D.执行；权威；网络攻击；电信诈骗；更改密码
答案:A
解析:

273．在软件项目开发过程中，评估软件项目风险时，（）与风险无关。
A.高级管理人员是否正式承诺支持该项目
B.开发人员和用户是否充分理解系统的需求
C.最终用户是否同意部署已开发的系统
D.开发需求的资金是否能按时到位
答案:C
解析:ABD 都对项目风险有一定影响，C 项是否同意部署在开发完成以后。

274．物理安全是一个非常关键的领域包括环境安全、设施安全与传输安全。其中，信息系统的设施作为直存储、处理数据的载体，其安全性对信息系统至关重要。下列选项中，对设施安全的保障的描述正确的是（）。
A.安全区域不仅包含物理区域，还包含信息系统等软件区域
B.建立安全区域需要建立安全屏蔽及访问控制机制
C.由于传统门锁容易被破解，因此禁止采用门锁的方式进行边界防护
D.闭路电视监控系统的前端设备包括摄像机、数字式控制录像设备，后端设备包括中央控制设备、监视器等
答案:B
解析:A 物理安全包括信息系统所在物理区域，但不包含软件区域，C“进展采用门锁方式”错误，D 数字式控制录像设备属于后端设备，B 描述了物理安全措施。

275．下列关于测试方法的叙述中不正确的是（）
A.从某种角度上讲，白盒测试与墨盒测试都属于动态测试
B.功能测试属于黑盒测试
C.结构测试属于白盒测试
D.对功能的测试通常是要考虑程序的内部结构的
答案:D

解析:白盒测试是在程序员十分了解程序的前提下，对程序的逻辑结构进行的测试。而黑盒测试则将程序视为一个黑盒子，仅仅是测试人员提供输入数据，观察输出数据，并不了解程序是如何运行的，结构测试属于白盒测试，关注的是如何选择合适的程序或子程序路径来执行有效的检查。功能测试则属于黑盒测试，对功能的测试通常通过提供输入数据，检查实际输出的结果，很少考虑程序的内部结构。

276. 以下哪些不是《国家网络空间安全战略》中阐述的我国网络空间当前任务？
A.捍卫网络空间主权
B.保护关键信息基础设施
C.提升网络空间防护能力
D.阻断与国外网络连接
答案:D
解析:常识问题

277. 在信息安全保障工作中人才是非常重要的因素，近年来，我国一直调试重视我国信自成安全人才队伍培养建设。在以下关于我国关于人才培养工作的描述中，错误的是（）。
A.在《中国信息化领导小组关于加强信息安全保障工作的中意见》（中办发[2003]27 号）中,针对信息安全人才建设与培养工作提出了“加快网络空间安全人才培养增强全民信息安全意识”的指导精神
B.B. 2015 年，为加快网络安全高层次人才培养，经报国务院学位委员会 批准，国务院学位委员会、教育部决定“工学”门类下增设“网络空间安全“一级学科，这对于我国网络信息安全人才成体系化、规模化、系统培养到积极的推到作用
C.经过十余年的发展，我国信息安全人才培养已经成熟和体系化，每年培养的信息全从人员的数量较多，能同社会实际需求相匹配；同时，高效信息安全专业毕业人才的合能力要求高、知识更全面，因面社会化培养重点放在非安全专业人才培养上
D.除正规大学教育外，我国信息安全非学历教育已基本形成了以各种认证为核心，辅以各种职业技能培训的信息安全人才培训休系,包括“注册信息安全专业人员(CISP)”资质认证和一些大型企业的信息安全资质认证
答案:C
解析:常识问题

278. 王明买了一个新的蓝牙耳机，但王明听说使用蓝牙设备有一定的安全威胁，于是王明找到对蓝牙技术有所了解的王红，希望王红能够给自己一点建议，以下哪一条建议不可取（）
A.在选择使用蓝牙设备时,应考虑设备的技术实现及设置是否具备防止上述安全威胁的能力
B.选择使用工能合适的设备而不是功能尽可能多的设备、尽量关闭不使用的服务及功能
C.如果蓝牙设备丢失，最好不要做任何操作
D.在配对时使用随机生成的密钥、不使用时设置不可被其他蓝牙设备发现
答案:C
解析:如果蓝牙设备丢失，应把设备从已配对列表众删除。

279.Hadoop 是目前广泛应用的大数据处理分析平台。在 Hadoop1.0.0 版本之前，Hadoop 并不存在安全认证一说。认集群内所有的节点都是可靠的，值得信赖的。用户与服务器进行交互时并不需要进行验证。导致在恶意用户装成真正的用户或者服务器入侵到 Hadoop 集群

上，恶意的提交作业篡改分布式存储的数据伪装成 Name No TaskTracker 接受任务等。在 Hadoop2.0 中引入 Kerberos 机制来解决用户到服务器认证问题，Kerberos 认证过程不包括（）
A.获得票据许可票据
B.获得服务许可票据
C.获得密钥分配中心的管理权限
D.获得服务
答案:C
解析:ABD 是 Kerberos 认证的三步曲

280. 信息安全是通过实施一组合适的（）而达到的，包括策略、过程、规程、（）以及软件和硬件功能。在必要时需建立、实施、监视、评审和改进包含这些控制措施的（）过程，以确保满足该组织的特定安全和（）。这个过程宜与其他业务（）联合进行。
A.信息安全管理；控制措施；组织结构；业务目标；管理过程
B.组织结构；控制措施；信息安全管理；业务目标；管理过程
C.控制措施；组织结构；信息安全管理；业务目标；管理过程
D.控制措施；组织结构；业务目标；信息安全管理；管理过程
答案:c)
解析:P103 页

281. 了解社会工程学攻击是应对和防御（）的关键，对于信息系统的管理人员和用户，都应该了解社会学的攻击的概念和攻击的（）。组织机构可采取对相关人员实施社会工程学培训来帮助员工了解什么是社会工程学攻击，如何判断是否存在社会工程学攻击，这样才能更好的保护信息系统和()。因为如果对攻击方式有所了解那么用户识破攻击者的伪装就()。因此组织机构应持续不断的向员工提供安全意识的培训和教育，向员工灌输（），以降低社会工程学攻击的风险。
A.社会工程学攻击；越容易；原理；个人数据；安全意识
B.社会工程学攻击；原理；越容易；个人数据；安全意识
C.原理；社会工程学攻击；个人数据；越容易；安全意识
D.社会工程学攻击；原理；个人数据；越容易；安全意识
答案:D
解析:

282. 强制访问控制是指主体和客体都有一个固定的安全属性，系统用该安全属性决定一个主体是否可以访问某个客体，具有较高的安全性，适用于专用或对安全性要求较高的系统。强制访问控制模型有多种类型，如 BLP、Biba、Clark-willson 和 ChineseWall 等。小李自学了 BLP 模型，并对该模型的特点进行了总结。以下 4 种对 BLP 模型的描述中，正确的是（）。
A.BLP 模型用于保证系统信息的完整性
B.BLP 模型的规则是“向下读，向上写”
C.BLP 的自主安全策略中，系统通过比较主体与客体的访问类属性控制主体对客体的访问
D.BLP 的强制安全策略使用一个访问控制矩阵表示
答案:B

解析:BLP 模型是一种强制访问控制模型用以保障机密性，向上写，向下读，自主访问控制模型使用一个访问控制矩阵表示。

283. 对操作系统软件安装方面应建立安装（），运行系统要化安装经过批准的可执行代码，不安装开发代码和（），应用和操作系统软件要在大范围的、成功的测试之后才能实施。而且要仅由受过培训的管理员，根据合适的（），进行运行软件、应用和程序库的更新；必要时在管理者批准情况下，仅为了支持目的才授予供应商物理或逻辑访问权，并且要监督供应商的活动。对于用户能安装何种类型的软件，组织宜定义并强制执行严格的方针，宜使用（）。不受控制的计算机设备上的软件安装可能导致脆弱性。进行导致信息泄露；整体性损失或其他信息安全事件或违反（）。

A.控制规程； 编译程序； 管理授权； 最小特权方针； 知识产权
B.编译程序； 控制规程； 管理授权； 最小特权方针； 知识产权
C.控制规程； 管理授权； 编译程序； 最小特权方针； 知识产权
D.控制规程； 最小特权方针；编译程序； 管理授权； 知识产权
答案:A
解析:

284. 建立并完善（）是有效应对社会工程攻击的方法，通过（）的建立，使得信息系统用户需要遵循（）来实施某些操作，从而在一定程度上降低社会工程学的影响。例如对于用户密码的修改，由于相应管理制度的要求，（）需要对用户身份进行电话回拨确认才能执行，那么来自外部的攻击就可能很难伪装成为内部工作人员进行（），因为他还需要想办法拥有一个组织机构内部电话才能实施。

A.信息安全管理体系；安全管理制度； 规范；网络管理员；社会工程学攻击
B.信息安全管理体系；安全管理制度； 网络管理员；规范；社会工程学攻击
C.安全管理制度；信息安全管理体系； 规范；网络管理员；社会工程学攻击
D.信息安全管理体系； 网络管理员；安全管理制度；规范；社会工程学攻击
答案:A
解析:

285. 管理，是指（）组织并利用其各个要素（人、财、物、信息和时空），借助（），完成该组织目标的过程。其中，（）就像其他重要业务资产各（）一样，也 对组织业务至关重要的一种资产，因此需要加以适当地保护。在业务环境互连日益增加的情况下这一点显得尤为重要。这种互连性的增加导致信息暴露于日益增多的、范围越来越广的威胁各（）当中。

A.管理手段；管理主体；信息；管理要素；脆弱性
B.管理主体；管理手段；信息；管理要素；脆弱性
C.管理主体；信息；管理手段；管理要素；脆弱性
D.管理主体；管理要素；管理手段；信息；脆弱性
答案:B
解析:

286. 以下对 Kerberos 协议过程说法正确的是：（）

A.协议可以分为两个步骤：一是用户身份鉴别；二是获取请求服务
B.协议可以分为两个步骤：一是获得票据许可票据；二是获取请求服务

C.协议可以分为三个步骤：一是用户身份鉴别；二是获得票据许可票据；三是获得服务许可票据
D.协议可以分为三个步骤：一是获得票据许可票据 二是获得服务许可票据；三是获得服务
答案:D
解析:

287. 下列选项中，对物理与环境安全的近期内述出现错误的是（）
A.物理安全确保了系统在对信息进行采集、传输、处理等过程中的安全
B.物理安全面对是环境风险及不可预知的人类活动，是一个非常关键的领域
C.物理安全包括环境安全、系统安全、设施安全等
D.影响物理安全的因素不仅包含自然因素，还包含人为因素
答案:A 或者 C 都有选择，我们给出的答案是 A
解析:物理安全是保护信息稳定、可靠的运行，确保信息系统在对信息进行采集、传输、存储、处理等过程中不会因为**自然因素、人为因素**等原因导致服务中断、数据丢失、破坏等问题，P319 页。

288. 风险处理是依据（），选择和实施合适的安全措施。风险处理的目的是为了将（）始终控制在可接爱的范围内。风险处理的方式主要有（）、（）、（）和（）四种方式。
A.风险；风险评估的结果；降低；规避；转移；接受
B.风险评估的结果；风险；降低；规避；转移；接受
C.风险评估；风险；降低；规避；转移；接受
D.风险；风险评估；降低；规避；转移；接受
答案:B
解析:

289. 信息收集是（）攻击实施的基础，因此攻击者在实施前会对目标进行（），了解目标所有相关的（）。这些资料和信息对很多组织机构来说都是公开或看无用的，然而对攻击者来说，这些信息都 是非常有价值的，这些信息收集得越多，离他们成功得实现（）就越近。如果为信息没有价值或价值的非常低，组织机构通常不会采取措施（），这正是社会工程学攻击者所希望的。
A.信息收集；社会工程学；资料和信息；身份伪装 ；进行保护
B.社会工程学；信息收集；资料和信息；身份伪装 ；进行保护
C.社会工程学；信息收集；身份伪装；资料和信息 ；进行保护
D.信息收集；资料和信息；社会工程学；身份伪装 ；进行保护
答案:B
解析:

290. 二十世纪二十年代，德国发明家亚瑟谢尔比乌斯 Enigma 密码机。按照密码学发展历史阶段划分，这个阶段属于（ ）
A.古典密码阶段。这一阶段的密码专家常常靠直觉和技巧来设计密码，而不是凭借推理和证明，常用的密码运算方法包括替代方法和置换方法
B.近代密码发展阶段。这一阶段开始使用机械代替手工计算，形成了机械式密码设备和更进一步的机电密码设备
C.近代密码学的早期发展阶段。这一阶段以香农的论文“保密系统的通信理论”（The Communication Theory of Secret Systems）

D.现代密码学的近期发展阶段。这一阶段以公钥密码思想为标志，引发了密码学历史上的革命性的变革，同时，众多的密码算法开始应用于非机密单位和商业场合
答案:A
解析:Enigma 密码机，按照密码学发展历史阶段划分，这个阶段属于古典密码阶段。

291．有关危害国家秘密安全的行为包括（ ）
A.严重违反保密规定行为、定密不当行为、公共信息网络运营商及服务商不履行保密义务的行为、保密行政管理部门的工作人员的违法行为
B.严重违反保密规定行为、公共信息网络运营商及服务商不履行保密义务的行为、保密行政管理部门的工作人员的违法行为，但不包括定密不当行为
C.严重违反保密规定行为、定密不当行为、保密行政管理部门的工作人员的违法行为，但不包括公共信息网络运营商及服务商不履行保密义务的行为
D.严重违反保密规定行为、定密不当行为、公共信息网络运营商及服务商不履行保密义务的行为，但不包括保密行政管理部门的工作人员的违法行为
答案:A
解析:A 最全面，严重违反保密规定行为、定密不当行为、公共信息网络运营商及服务商不履行保密义务的行为、保密行政管理部门的工作人员的违法行为

292．小王是某大学计算机科学与技术专业的学生，最近因为生病缺席了几堂信息安全课程，这几次课的内容是自主访问控制与强制访问控制，为了赶上课程，他向同班的小李借来课堂笔记，进行自学。而小李在听课时由于经常走神，所以笔记会出现一些错误。下列选项是小李笔记中关于强制访问控制模型的内容，其中出现错误的选项是（ ）
A.强制访问控制是指主体和客体都有一个固定的安全属性，系统用该安全属性来决定一个主体是否可以访问某个客体
B.安全属性是强制性的规定，它由安全管理员或操作系统根据限定的规则确定，不能随意篡改
C.系统通过比较客体和主体的安全属性来决定主体是否可以访问客体
D.它是一种对单个用户执行访问控制的过程控制措施
答案:D
解析:“对单个用户执行访问控制的过程控制措施”，P308 页。

293．在以下标准中，属于推荐性国家标准的是
A.GB/T XXXX.X-200X
B.GB XXXX-200X
C.DBXX/T XXX-200X
D.GB/Z XXX-XXX-200X
答案：a)
解析：A 为国标推荐标准；B 为国标强制标准；C 为地方标准；D 为国标指导标准。

294．常见的访问控制模型包括自主访问控制模型、强制访问控制模型和基于角色的访问控制模型等，下面描述中错误的是（ ）
A.从安全性等级来看，这三个模型安全性从低到高的排序是自主访问控制模型，强制访问控制模型和基于角色的访问控制模型

B.自主访问控制是一种广泛应用的方法，资源的所有者（往往也是创建者）可以规定谁有权利访问他们的资源，具有较好的易用性和可扩展性
C.强制访问控制模型要求主体和客体都有一个固定的安全属性，系统用该安全属性来决定一个主体是否可以访问某个客体，该模型具有一定的抗恶意程序攻击能力，适用于专用或安全性要求较高的系统
D.基于角色的访问控制模型的基本思想是根据用户所担任的角色来决定用户在系统中的访问权限，该模型便于实施授权管理和安全约束，容易实现最小特权，职责分离等各种安全策略
答案:A
解析:三个模型安全性没有横向对比，进行安全性比较是错误的，只是三种模型应用场景不同。

295．下列哪一个是我国政策性文件明确了我国信息安全保障工作的方针和总体要求以及加强信息安全工作的主要原则？（ ）
A.《关于加强政府信息系统安全和保密管理工作的通知》
B.《政府信息系统安全和保密管理工作的通知》
C.《国家信息化领导小组关于加强信息安全保障工作的意见》
D.《关于开展信息安全风险评估工作的意见》
答案；C
解析：《国家信息化领导小组关于加强信息安全保障工作的意见》是我国政策性文件明确了我国信息安全保障工作的方针和总体要求以及加强信息安全工作的主要原则。

296．残余风险是风险管理中的一个重要概念。在信息安全风险管理中，关于残余风险描述错误的是（）
A.残余风险是采取了安全措施后，仍然可能存在的风险，一般来说，是在综合考虑了安全成本与效益后不去控制的风险
B.残余风险应受到密切监理，它会随着时间的推移而发生变化，可能会在将来诱发新的安全事件
C.实施风险处理时，应将残余风险清单告知信息系统所在组织的高管，使其了解残余风险的存在和可能造成的后果
D.信息安全风险处理的主要准则是尽可能降低和控制信息安全风险，以最小的残余风险值作为风险管理效果评估指标
答案；A
解析：“不去控制”错误，残余风险无法消除，但需要监视、控制。

297．在 Windows 文件系统中，_____支持文件加密。
A.FAT16
B.NTFS
C.FAT32
D.EXT3
答案；B
解析：

298．相比 FAT 文件系统，以下那个不是 NTFS 所具有的优势？

A.NTFS 使用事务日志自动记录所有文件和文件夹更新，当出现系统损坏引起操作失败后，系统能利用日志文件重做或恢复未成功的操作。
B.NTFS 的分区上，可以为每个文件或文件夹设置单独的许可权限
C.对于大磁盘，NTFS 文件系统比 FAT 有更高的磁盘利用率
D.相比 FAT 文件系统，NTFS 文件系统能有效的兼容 linux 下的 EXT3 文件格式。
答案；D
解析：

299. 以下哪些问题或概念不是公钥密码体制中经常使用到的困难问题?
A.大整数分解
B.离散对数问题
C.背包问题
D.伪随机数发生器
答案；D
解析：伪随机数发生器是序列密码算法加密过程中遇到的问题，而序列密码算法属于对称密码算法的一种。

300. 以下哪种公钥密码算法既可以用于数据加密又可以用于密钥交换?
A.DSS
B.Diffie-Hellman
C.RSA
D.AES
答案；C
解析：DSS 是一种数字签名标准，严格来说不算加密算法；Diffie-Hellman 并不是加密算法，而是一种密钥建立的算法；AES 算法是一种对称密码算法，可以用于数据加密。

练习题第四卷

301. 在 Windows 系统中，管理权限最高的组是：
A.everyone
B.administrator
C.powerusers
D.users
答案；B
解析：超级管理员组 administrator

302. 下列关于 kerckhof 准则的说法正确的是：
A.保持算法的秘密性比保持密钥的秘密性要困难的多
B.密钥一旦泄漏，也可以方便的更换
C.在一个密码系统中，密码算法是可以公开的，密钥应保证安全
D.公开的算法能够经过更严格的安全性分析
答案；C
解析：柯克霍夫原则：密码系统的安全性依赖于密钥而不依赖于算法。

303. 在 Windows XP 中用事件查看器查看日志文件，可看到的日志包括？
A.用户访问日志、安全性日志、系统日志和 IE 日志
B.应用程序日志、安全性日志、系统日志和 IE 日志
C.网络攻击日志、安全性日志、记账日志和 IE 日志
D.网络链接日志、安全性日志、服务日志和 IE 日志
答案；B
解析：

304. 操作系统安全的基础是建立在：
A.安全安装
B.安全配置
C.安全管理
D.以上都对
答案；D
解析：

305. 信息发送者使用_____进行数字签名。
A.己方的私钥
B.己方的公钥
C.对方的私钥
D.对方的公钥
答案；A
解析：私钥加密，公钥解密，公钥私钥成对出现。

306. 以下列出了 mac 和散列函数的相似性,哪一项说法是错误的？
A.MAC 和散列函数都是用于提供消息认证
B.MAC 的输出值不是固定长度的，而散列函数的输出值是固定长度的
C.MAC 和散列函数都不需要密钥
D.MAC 和散列函数都不属于非对称加密算法
答案；C
解析：(1)MAC：消息验证、完整性校验、抗重放攻击；输出不固定的；MAC 需密钥；不是非对称。(2)哈希：消息验证、完整性校验；输出是固定的；不需要密钥；不是非对称。

307. 下面哪种方法产生的密码是最难记忆的？
A.将用户的生日倒转或是重排
B.将用户的年薪倒转或是重排
C.将用户配偶的名字倒转或是重排
D.用户随机给出的字母
答案；D
解析：随机的最难记

308. 以下关于 https 协议 http 协议相比的优势说明，那个是正确的
A.Https 协议对传输的数据进行加密，可以避免嗅探等攻击行为
B.Https 使用的端口和 http 不同，让攻击者不容易找到端口，具有较高的安全性

C.Https 协议是 http 协议的补充，不能独立运行，因此需要更高的系统性能
D.Https 协议使用了挑战机制，在会话过程中不传输用户名和密码，因此具有较高的
答案：A
解析：HTTPS 具有数据加密机制，HTTPS 使用 443 端口，HTTP 使用 80 端口，HTTPS 协议完全可以独立运行，传输加密后的用户名和密码。

309．设计信息系统安全保障方案时，以下哪个做法是错误的：
A.要充分切合信息安全需求并且实际可行
B.要充分考虑成本效益，在满足合规性要求和风险处置要求的前提下，尽量控制成本
C.要充分采取新技术，在使用过程中不断完善成熟，精益求精，实现技术投入保值要求
D.要充分考虑用户管理和文化的可接受性，减少系统方案实施障碍
答案；C
解析：安全领域一般选择经过检验的、成熟、安全的技术方案，一般不选最新的。

310．Windows 文件系统权限管理访问控制列表（Access Control List，ACL）机制，以下哪个说法是错误的：
A.安装 Windows 系统时要确保文件格式使用的是 NTFS，因为 Windows 的 ACL 机制需要 NTFS 文件格式的支持
B.由于 Windows 操作系统自身有大量的文件和目录,因此很难对每个文件和目录设置严格的访问权限，为了使用上的便利，Windows 上的 ACL 存在默认设置安全性不高的问题
C.Windows 的 ACL 机制中，文件和文件夹的权限是与主体进行关联的，即文件夹和文件的访问权限信息是写在用户数据库中
D.由于 ACL 具有很好的灵活性，在实际使用中可以为每一个文件设定独立用户的权限
答案；C
解析：C 项，与客体进行关联，用户的权限写在文件夹和文件的数据库中。

311．关于我国信息安全保障的基本原则，下列说法中不正确的是：
A.要与国际接轨，积极吸收国外先进经验并加强合作，遵循国际标准和通行做法，坚持管理与技术并重
B.信息化发展和信息安全不是矛盾的关系，不能牺牲一方以保证另一方
C.在信息安全保障建设的各项工作中，既要统筹规划，又要突出重点
D.在国家信息安全保障工作中，要充分发挥国家、企业和个人的积极性，不能忽视任何一方的作用。
答案；A
解析：我国信息安全保障首先要遵循国家标准。

312．某单位的信息安全主管部门在学习我国有关信息安全的政策和文件后，认识到信息安全风险评估分为自评估和检查评估两种形式。该部门将有关检查评估的特点和要求整理成如下四条报告给单位领导，其中描述错误的是（）
A.检查评估可依据相关标准的要求，实施完整的风险评估过程；也可在自评估的基础上，对关键环节或重点内容实施抽样评估
B.检查评估可以由上级管理部门组织，也可以由本级单位发起，其重点是针对存在的问题进行检查和评测
C.检查评估可以由上级管理部门组织，并委托有资质的第三方技术机构实施

D.检查评估是通过行政手段加强信息安全管理的重要措施，具有强制性的特点
答案；B
解析：自评估由本级单位发起，检查评估由被评估组织的上级管理机关或业务主管机关发起，P247 页。

313．关于信息安全管理，下面理解片面的是（）
A.信息安全管理是组织整体管理的重要、固有组成部分，它是组织实现其业务目标的重要保障
B.信息安全管理是一个不断演进、循环发展的动态过程，不是一成不变的
C.信息安全建设中，技术是基础，管理是拔高，即有效的管理依赖于良好的技术基础
D.坚持管理与技术并重的原则，是我国加强信息安全保障工作的主要原则之一
答案；C
解析：C 是片面的，应为技管并重，P83 页。

314．为了进一步提供信息安全的保障能力和防护水平，保障和促进信息化建设的健康发展，公安部等四部门联合发布《关于信息安全等级保护工作的实施意见》（公通字[2004]66 号），对等级保护工作的开展提供宏观指导和约束，明确了等级保护工作哟的基本内容、工作要求和实施计划，以及各部门工作职责分工等。关于该文件，下面理解正确的是（）
A.该文件是一个由部委发布的政策性文件，不属于法律文件
B.该文件适用于 2004 年的等级保护工作，其内容不能约束到 2005 年及之后的工作
C.该文件是一个总体性指导文件，规定所有信息系统都要纳入等级保护定级范围
D.该文件适用范围为发文的这四个部门，不适用于其他部门和企业等单位
答案；A
解析：

315．下面有关软件安全问题的描述中，哪项应是由于软件设计缺陷引起的（）
A.设计了三层 WEB 架构，但是软件存在 SQL 注入漏洞，导致被黑客攻击后直接访问数据库
B.使用 C 语言开发时，采用了一些存在安全问题的字符串处理函数，导致存在缓冲区溢出漏洞
C.设计了缓存用户隐私数据机制以加快系统处理性能，导致软件在发布运行后，被黑客攻击获取到用户隐私数据
D.使用了符合要求的密码算法，但在使用算法接口时，没有按照要求生成密钥，导致黑客攻击后能破解并得到明文数据
答案；C
解析：

316．通过对称密码算法进行安全消息传输的必要条件是：
A.在安全的传输信道上进行通信
B.通讯双方通过某种方式，安全且秘密地共享密钥
C.通讯双方使用不公开的加密算法
D.通讯双方将传输的信息夹杂在无用信息中传输并提取
答案；B
解析：

317. Windows 系统下，哪项不是有效进行共享安全的防护措施？
A.使用 netshare\\127.0.0.1\c$/delete 命令，删除系统中的 c$等管理共享，并重启系统
B.确保所有的共享都有高强度的密码防护
C.禁止通过“空会话”连接以匿名的方式列举用户、群组、系统配置和注册表键值
D.安装软件防火墙阻止外面对共享目录的连接
答案：A
解析：

318. 以下对 Windows 账号的描述，正确的是：
A.Windows 系统是采用 SID（安全标识符）来标识用户对文件或文件夹的权限
B.Windows 系统是采用用户名来标识用户对文件或文件夹的权限
C.Windows 系统默认会生成 administrator 和 guest 两个账号，两个账号都不允许改名和删除
D.Windows 系统默认生成 administrator 和 guest 两个账号，两个账号都可以改名和删除
答案：A
解析：guest 可以改名和删除，administrator 不可以。

319. 以下关于代替密码的说法正确的是：
A.明文根据密钥被不同的密文字母代替
B.明文字母不变，仅仅是位置根据密钥发生改变
C.明文和密钥的每个 bit 异或
D.明文根据密钥作移位
答案：A
解析：

320. AES 在抵抗差分密码分析及线性密码分析的能力比 DES 更有效，已经替代 DES 成为新的据加密标准。其算法的信息块长度和加密密钥是可变的，以下哪一种不是其可能的密钥长度？
A.64bit
B.128bit
C.192bit
D.256bit
答案：A
解析：AES 密钥长度由 128 位、192 位、256 位三种。

321. 以下对 Windows 系统的服务描述，正确的是：
A.Windows 服务必须是一个独立的可执行程序
B.Windows 服务的运行不需要用户的交互登陆
C.Windows 服务都是随系统启动而启动，无需用户进行干预
D.Windows 服务都需要用户进行登陆后，以登录用户的权限进行启动
答案：B
解析：

322. Alice 有一个消息 M 通过密钥 K2 生成一个密文 E（K2，M）然后用 K1 生成一个 MAC 为 C（K1，E（K2，M）），Alice 将密文和 MAC 发送给 Bob，Bob 用密钥 K1 和密文生成一个 MAC 并和 Alice 的 MAC 比较，假如相同再用 K2 解密 Alice 发送的密文，这个过程可以提供什么安全服务？

A.仅提供数字签名

B.仅提供保密性

C.仅提供不可否认性

D.保密性和消息完整性

答案；D

解析：密文 E（K2，M）保障保密性，消息验证码 MAC 为 C（K1，E（K2，M））保障完整性。

323. 以下关于 windowsSAM(安全账号管理器)的说法错误的是:

A.安全账号管理器(SAM)具体表现就是%SystemRoot%\system32\config\sam

B.安全账号管理器(SAM)存储的账号信息是存储在注册表中

C.安全账号管理器(SAM)存储的账号信息 administrator 和 system 是可读和可写的

D.安全账号管理器(SAM)是 windows 的用户数据库系统进程通过 Security Accounts Manager 服务进行访问和操作

答案；C

解析：SAM 文件只有 system 可读和可写的

324. 常见密码系统包含的元素是：

A.明文，密文，信道，加密算法，解密算法

B.明文，摘要，信道，加密算法，解密算法

C.明文，密文，密钥，加密算法，解密算法

D.消息，密文，信道，加密算法，解密算法

答案；C

解析：

325. 社会工程学定位在计算机信息安全工作链的一个最脆弱的环节，即“人”这个环节上。这些社会工程黑客在某黑客大会上成功攻入世界五百强公司，其中一名自称是 CSO 杂志做安全调查，半小时内，攻击者选择了在公司工作两个月安全工程部门的合约雇员，在询问关于工作满意度以及食堂食物质量问题后，雇员开始透露其他信息，包括：操作系统、服务包、杀毒软件、电子邮件及浏览器。为对抗此类信息收集和分析，公司需要做的是（）

A.通过信息安全培训，使相关信息发布人员了解信息收集风险，发布信息最小化原则

B.减少系统对外服务的端口数量，修改服务旗标

C.关闭不必要的服务，部署防火墙、IDS 等措施

D.系统安全管理员使用漏洞扫描软件对系统进行安全审计

答案；A

解析：

326. 基于 TCP 的主机在进行一次 TCP 连接时简要进行三次握手，请求通信的主机 A 要与另一台主机 B 建立连接时，A 需要先发一个 SYN 数据包向 B 主机提出连接请示，B 收到后，回复一个 ACK/SYN 确认请示给 A 主机，然后 A 再次回应 ACK 数据包，确认连接请求。攻击通过伪造带有虚假源地址的 SYN 包给目标主机，使目标主机发送的 ACK/SYN 包得不到确认。一般

情况下，目标主机会等一段时间后才会放弃这个连接等待。因此大量虚假 SYN 包同时发送到目标主机时，目标主机上就会有大量的连接请示等待确认，当这些未释放的连接请示数量超过目标主机的资源限制时。正常的连接请示就不能被目标主机接受，这种 SYN Flood 攻击属于（）

A.拒绝服务攻击

B.分布式拒绝服务攻击

C.缓冲区溢出攻击

D.SQL 注入攻击

答案；A

解析：SYN Flood 属于拒绝服务攻击的一种，并未体现出来分布式。

327. 信息安全是国家安全的重要组成部分，综合研究当前世界各国信息安全保障工作，总结错误的是（）

A.各国普遍将与国家安全、社会稳定和民生密切相关的关键基础设施作为信息安全保障的重点

B.各国普遍重视战略规划工作，逐步发布网络安全战略、政策评估报告、推进计划等文件

C.各国普遍加强国际交流与对话，均同意建立一致的安全保障系统，强化各国安全系统互通

D.各国普遍积极推动信息安全立法和标准规范建设，重视应急响应、安全监管和安全测评

答案；C

解析：“均同意建立一致的安全保障系统”错误

328. 公钥密码的应用不包括:

A.数字签名

B.非安全信道的密钥交换

C.消息认证码

D.身份认证

答案；C

解析：ABD 都是是公钥密码应用的范畴。

329. Hash 算法的碰撞是指:

A.两个不同的消息，得到相同的消息摘要

B.两个相同的消息，得到不同的消息摘要

C.消息摘要和消息的长度相同

D.消息摘要比消息长度更长

答案；A

解析：P282 页

330. 实施灾难恢复计划之后，组织的灾难前和灾难后运营成本将：

A.降低

B.不变（保持相同）

C.提高

D.提高或降低（取决于业务的性质）

答案；C

解析：

331. 自主访问控制模型（DAC）的访问控制关系可以用访问控制表（ACL）来表示，该 ACL 利用在客体上附加一个主体明细表的方法来表示访问控制矩阵，通常使用由客体指向的链表来存储相关数据。下面选项中说法正确的是（ ）。

A.ACL 是 Bell-LaPadula 模型的一种具体实现

B.ACL 在删除用户时，去除该用户所有的访问权限比较方便

C.ACL 对于统计某个主体能访问哪些客体比较方便

D.ACL 管理或增加客体比较方便

答案；D

解析：P307 页

332. 在入侵检测（IDS）的运行中，最常见的问题是：（）

A.误报检测

B.接收陷阱消息

C.误拒绝率

D.拒绝服务攻击

答案；A

解析：P354

333. 什么是系统变更控制中最重要的内容？

A.所有的变更都必须文字化，并被批准

B.变更应通过自动化工具来实施

C.应维护系统的备份

D.通过测试和批准来确保质量

答案；A

解析：

334.IPv4 协议在设计之初并没有过多地考虑安全问题，为了能够使网络方便地进行互联、互通，仅仅依靠 IP 头部的校验和字段来保证 IP 包的安全，因此 IP 包很容易被篡改，并重新计算校验和。IETF 于 1994 年开始制定 IPSec 协议标准，其设计目标是在 IPv4 和 IPv6 环境中为网络层流量提供灵活、透明的安全服务，保护 TCP/IP 通信免遭窃听和篡改，保证数据的完整性和机密性，有效抵御网络攻击，同时保持易用性。下列选项中说法错误的是（ ）

A.对于 IPv4，IPSec 是可选的，对于 IPv6，IPSec 是强制实施的。

B.IPSec 协议提供对 IP 及其上层协议的保护。

C.IPSec 是一个单独的协议

D.IPSec 安全协议给出了封装安全载荷和鉴别头两种通信保护机制。

答案；C

解析：IPSec 不是一个单独的协议，它还包括 AH（网络认证协议）、ESP（载荷封装协议）、IKE（密钥管理协议）等。

335. 小陈学习了有关信息安全管理体系的内容后，认为组织建立信息安全管理体系并持续运行，比起简单地实施信息安全管理，有更大的作用，他总结了四个方面的作用，其中总结错误的是（ ）

A.可以建立起文档化的信息安全管理规范，实现有“法”可依，有章可循，有据可查
B.可以强化员工的信息安全意识，建立良好的安全作业习惯，培育组织的信息安全企业文化
C.可以增强客户、业务伙伴、投资人对该组织保障其业务平台和数据信息的安全信心
D.可以深化信息安全管理，提高安全防护效果，使组织通过国际标准化组织的 ISO9001 认证
答案：D
解析：ISO9001 是质量认证不是安全管理认证，应通过 ISO27001 认证。

336.随着“互联网”概念的普及，越来越多的新兴住宅小区引入了“智能楼宇”的理念，某物业为提供高档次的服务，防止网络主线路出现故障，保证小区内网络服务的可用，稳定、高效，计划通过网络冗余配置的是（）。
A.接入互联网时，同时采用不同电信运营商线路，相互备份且互不影响。
B.核心层、汇聚层的设备和重要的接入层设备均应双机设备。
C.规划网络 IP 地址，制定网络 IP 地址分配策略
D.保证网络带宽和网络设备的业务处理能力具备冗余空间，满足业务高峰期和业务发展需求
答案：A
解析：“防止网络主线路出现故障”，所以应做线路备份。

337. 在网络信息系统建设中部署防火墙，往往用于提高内部网络的安全防护能力。某公司准备部署一台防火墙来保护内网主机，下列选项中部署位置正确的是（）
A.内网主机——交换机——防火墙——外网
B.防火墙——内网主机——交换机——外网
C.内网主机——防火墙——交换机——外网
D.防火墙——交换机——内网主机——外网
答案：A
解析：防火墙一般部署在内网和外网边界。

338.访问控制是对用户或用户访问本地或网络上的域资源进行法令一种机制。在 Windows2000 以后的操作系统版本中，访问控制是一种双重机制，它对用户的授权基于用户权限和对象许可，通常使用 ACL、访问令牌和授权管理器来实现访问控制功能。以下选项中，对 windows 操作系统访问控制实现方法的理解错误的是（）
A.ACL 只能由管理员进行管理
B.ACL 是对象安全描述的基本组成部分，它包括有权访问对象的用户和级的 SID
C.访问令牌存储着用户的 SID，组信息和分配给用户的权限
D.通过授权管理器，可以实现基于角色的访问控制
答案：A
解析：

339. 某黑客通过分析和整理某报社记者小张的博客，找到一些有用的信息，通过伪装的新闻线索，诱使其执行木马程序，从而控制了小张的电脑，并以她的电脑为攻击的端口，使报社的局域网全部感染木马病毒，为防范此类社会工程学攻击，报社不需要做的是（）
A.加强信息安全意识培训，提高安全防范能力，了解各种社会工程学攻击方法，防止受到此类攻击
B.建立相应的安全相应应对措施，当员工受到社会工程学的攻击，应当及时报告
C.教育员工注重个人隐私保护

D.减少系统对外服务的端口数量，修改服务旗标
答案：D
解析：D 和社工无关。

340. 2016 年 9 月，一位安全研究人员在 Google Cloud IP 上通过扫描，发现了完整的美国路易斯安邦州 290 万选民数据库。这套数据库中囊括了诸如完整姓名、电子邮箱地址、性别与种族、选民状态、注册日期与编号、正党代名和密码，以防止攻击者利用以上信息进行（）攻击。
A.默认口令
B.字典
C.暴力
D.XSS
答案：B
解析：

341. 模糊测试，也称 Fuzz 测试，是一种通过提供非预期的输入并监视异常结果来发现软件故障的方法。下面描述正确的是（）
A.模糊测试本质上属于黑盒测试
B.模糊测试本质上属于白盒测试
C.模糊测试有时属于黑盒测试，有时属于白盒测试，取决于其使用的测试方法
D.模糊测试既不属于黑盒测试，也不属于白盒测试
答案：A
解析：

342. 若一个组织声称自己的 ISMS 符合 ISO/IEC 27001 或 GB/T22080 标准要求，其信息安全控制措施通常需要在人力资源安全方面实施常规控制，人力资源安全划分为 3 个控制阶段，不包括哪一项（）
A.任用之前
B.任用中
C.任用终止或变化
D.任用后
答案：D
解析：P106

343. 若一个组织声称自己的 ISMS 符合 ISO/IEC 27001 或 GB/T22080 标准要求。其信息安全控制措施通常需要在物理和环境安全方面实施常规控制。物理和环境安全领域包括安全区域和设备安全两个控制目标。安全区域的控制目标是防止对组织场所和信息的未授权物理访问、损坏和干扰。关键或敏感的信息及信息处理设施应放在安全区域内并受到相应保护。该目标可以通过以下控制措施来实现，不包括哪一项
A.物理安全边界、物理入口控制
B.办公室、房间和设施的安全保护。外部和环境威胁的安全防护
C. 在安全区域工作。公共访问、交接区安全
D.人力资源安全
答案：D

解析：D 和物理环境安全无关。

344. 关于补丁安装时应注意的问题，以下说法正确的是

A.在补丁安装部署之前不需要进行测试，因为补丁发布之前厂商已经经过了测试

B.补丁的获取有严格的标准,必须在厂商的官网上获取

C.信息系统打补丁时需要做好备份和相应的应急措施

D.补丁安装部署时关闭和重启系统不会产生影响

答案；C

解析：

345. 某电子商务网站架构设计时，为了避免数据误操作，在管理员进行订单删除时，需要由审核员进行审核后该删除操作才能生效，这种设计是遵循了发下哪个原则

A.权限分离原则

B.最小的特权原则

C.保护最薄弱环节的原则

D.纵深防御的原则

答案；A

解析：

346. 关于 Kerberos 认证协议，以下说法错误的是：

A.只要用户拿到了认证服务器（AS）发送的票据许可票据（TGT）并且该 TGT 没有过期，就可以使用该 TGT 通过票据授权服务器（TGS）完成到任一个服务器的认证而不必重新输入密码

B.认证服务器（AS）和票据授权服务器（TGS）是集中式管理，容易形成瓶颈，系统的性能和安全也严重依赖于 AS 和 TGS 的性能和安全

C.该协议通过用户获得票据许可票据、用户获得服务许可票据、用户获得服务三个阶段，仅支持服务器对用户的单向认证

D.该协议是一种基于对称密码算法的网络认证协议，随用户数量增加，密钥管理较复杂

答案；C

解析：Kerberos 由 MIT 于 1988 年开发，用于分布式环境中，完成服务器与用户之间的相互认证。

347. 某单位系统管理员对组织内核心资源的访问制定访问策略，针对每个用户指明能够访问的资源，对于不在指定资源列表中的对象不允许访问。该访问控制策略属于以下哪一种：

A.强制访问控制

B.基于角色的访问控制

C.自主访问控制

D.基于任务的访问控制

答案；C

解析：“针对每个用户指明”

348. 防火墙是网络信息系统建设中常采用的一类产品，它在内外网隔离方面的作用是（）

A.既能物理隔离，又能逻辑隔离

B.能物理隔离，但不能逻辑隔离

C.不能物理隔离，但是能逻辑隔离
D.不能物理隔离，也不能逻辑隔离
答案：C
解析：

349. 以下关于 Windows 系统的账号存储管理机制（Security Accounts Manager）的说法哪个是正确的：
A.存储在注册表中的账号数据是管理员组用户都可以访问，具有较高的安全性
B.存储在注册表中的账号数据只有 administrator 账户才有权访问，具有较高的安全性
C.存储在注册表中的账号数据任何用户都可以直接访问，灵活方便
D.存储在注册表中的账号数据有只有 System 账户才能访问，具有较高的安全性
答案：D
解析：Security Accounts Manager 只有 system 账号才能访问。

350. 强制访问控制是指主体和客体都有一个固定的安全属性，系统用该安全属性来决定一个主体是否可以访问某个客体，具有较高的安全性，适用于专用或对安全性较高的系统。强制访问控制模型有多种类型，如 BLP、Biba、Clark-Willson 和 ChineseWall 等。小李自学了 BLP 模型，并对该模型的特点进行了总结。以下 4 钟对 BLP 模型的描述中，正确的是（ ）：
A.BLP 模型用于保证系统信息的机密性，规则是“向上读，向下写”
B.BLP 模型用于保证系统信息的机密性，规则是“向下读，向上写”
C.BLP 模型用于保证系统信息的完整性，规则是“向上读，向下写”
D.BLP 模型用于保证系统信息的完整性，规则是“向下读，向上写”
答案：B
解析：BLP 模型保证机密性，向下读，向上写；Biba 保障完整性，向上读向下写。

351. 信息安全风险等级的最终因素是：
A.威胁和脆弱性
B.影响和可能性
C.资产重要性
D.以上都不对
答案：我们给出的答案是 B，有的题库给出答案是 D
解析：简析：在常见的方法（ISO/IEC 27005、NIST SP 800-30）中，风险等级通常由
风险 = 影响(Impact) × 可能性(Likelihood) 来判定。

352. 对系统工程（Systems Engineering，SE）的理解，以下错误的是：
A.系统工程偏重于对工程的组织与经营管理进行研究
B.系统工程不属于技术实现，而是一种方法论
C.系统工程不是一种对所有系统都具有普遍意义的科学方法
D.系统工程是组织管理系统规划、研究、制造、试验、使用的科学方法
答案：c)
解析：系统工程是一种对所有系统都具有普遍意义的科学方法。

353. 2005 年，RFC4301（Request for Comments 4301:Security Architecture for the Internet Protocol）发布，用以取代原先的 RFC2401，该标准建议规定了 IPsec 系统基础架

构，描述如何在 IP 层（IPv4/IPv6）位流量提供安全业务。请问此类 RFC 系列标准建议是由下面哪个组织发布的（）。

A.国际标准化组织（International Organization for Standardization，ISO）

B.国际电工委员会（International Electrotechnical Commission，IEC）

C.国际电信联盟远程通信标准化组织（ITU Telecommunication Standardization Secctor，ITU-T）

D.Internet 工程任务组（Internet Engineering Task Force，IETF）

答案：D

解析：

354. GB/T 18336《信息技术安全性评估准则》是测评标准类中的重要标准，该标准定义了保护轮廓（Protection Profile，PP）和安全目标（Security Target，ST）的评估准则，提出了评估保证级（Evaluation Assurance Level，EAL），其评估保证级共分为（）个递增的评估保证等级。

A.4

B.5

C.6

D.7

答案：D

解析：

355.在网络信息系统中对用户进行认证识别时，口令是一种传统但仍然使用广泛的方法，口令认证过程中常常使用静态口令和动态口令。下面描述中错误的是（ ）

A.所谓静态口令方案，是指用户登录验证身份的过程中，每次输入的口令都是固定、静止不变的

B.使用静态口令方案时，即使对口令进行简单加密或哈希后进行传输，攻击者依然可能通过重放攻击来欺骗信息系统的身份认证模块

C.动态口令方案中通常需要使用密码算法产生较长的口令序列，攻击者如果连续地收集到足够多的历史口令，则有可能预测出下次要使用的口令

D.通常，动态口令实现方式分为口令序列、时间同步以及挑战/应答等几种类型

答案：C

解析：动态口令方案要求其口令不能被收集和预测。

356.“统一威胁管理”是将防病毒，入侵检测和防火墙等安全需求统一管理，目前市场上已经出现了多种此类安全设备，这里“统一威胁管理”常常被简称为（ ）

A.UTM

B.FW

C. IDS

D.SOC

答案：A

解析：

357. 以下哪一项不是常见威胁对应的消减措施：

A.假冒攻击可以采用身份认证机制来防范

B.为了防止传输的信息被篡改，收发双方可以使用单向 Hash 函数来验证数据的完整性
C.为了防止发送方否认曾经发送过的消息，收发双方可以使用消息验证码来防止抵赖
D.为了防止发送方否认曾经发送过的消息，收发双方可以使用消息验证码来防止抵赖
答案：C
解析：消息验证码不能防止抵赖，而是提供消息鉴别、完整性校验和抗重放攻击。

358. 国务院信息化工作办公室于 2004 年 7 月份下发了《关于做好重要信息系统灾难备份工作的通知》，该文件中指出了我国在灾备工作原则，下面哪项不属于该工作原则（ ）
A.统筹规划
B.分组建设
C.资源共享
D.平战结合
答案：B
解析：灾备工作原则包括统筹规划、资源共享、平战结合。

359. 关于信息安全事件和应急响应的描述不正确的是（）
A.信息安全事件，是指由于自然或人为以及软、硬件本身缺陷或故障的原因，对信息系统造成危害，或在信息系统内发生对社会造成负面影响事件
B.至今已有一种信息安全策略或防护措施，能够对信息及信息系统提供绝对的保护，这就使得信息安全事件的发生是不可能的
C.应急响应是指组织为了应对突发/重大信息安全事件的发生所做的准备，以及在事件发生后所采取的措施
D.应急响应工作与其他信息安全管理工作将比有其鲜明的特点:具有高技术复杂性志专业性、强突发性、对知识经验的高依赖性，以及需要广泛的协调与合作
答案：B
解析：目前不存在一种信息安全策略或防护措施，能够对信息及信息系统提供绝对的保护。

360. 信息安全事件和分类方法有多种，依据 GB/Z 20986-2007《信息安全技术自信安全事件分类分级指南》，信息安全事件分为 7 个基本类别，描述正确的是（）
A.有害程序事件、网络攻击事件、信息破坏事件、信息内容安全事件、设备设施故障、灾害性事件和其他信息安全事件
B.网络贡献事件、拒绝服务攻击事件、信息破坏事件、信息内容安全事件、设备设施故障、灾害性事件和其他信息安全事件
C.网络攻击事件、网络钓鱼事件、信息破坏事件、信息内容安全事件、设备设施故障、灾害性事件和其他信息安全事件
D.网络攻击事件、网络扫描窃听事件、信息破坏事件、信息内容安全事件、设备设施故障、灾害性事件和其他信息安全事件
答案：A
解析：根据标准知识点，安全事件分为：有害程序事件、网络攻击事件、信息破坏事件、信息内容安全事件、设备设施故障、灾害性事件和其他信息安全事件。

361. 王工是某单位的系统管理员，他在某次参加了单位组织的风险管理工作时，根据任务安排，他使用了 Nessus 工具来扫描和发现数据库服务器的漏洞，根据风险管理的相关理论，他这个是扫描活动属于下面哪一个阶段的工作（）

A.风险分析
B.风险要素识别
C.风险结果判定
D.风险处理
答案：B
解析：漏洞扫描属于风险要素的脆弱性要素识别，风险要素包括资产、威胁、脆弱性、安全措施。

362．某市环卫局网络建设是当地政府投资的重点项目。总体目标就是用于交换式千兆以太网为主干，超五类双绞线作水平布线，由大型交换机和路由器连通几个主要的工作区域，在各区域建立一个闭路电视监控系统，再把信号通过网络传输到各监控中心，其中对交换机和路由器进行配置是网络安全中的一个不可缺少的步骤，下面对于交换机和路由器的安全配置，操作错误的是(　)
A.保持当前版本的操作系统，不定期更新交换机操作系统补丁
B.控制交换机的物理访问端口，关闭空闲的物理端口
C.带外管理交换机，如果不能实现的话，可以利用单独的 VLAN 号进行带内管理
D.安全配置必要的网络服务，关闭不必要的网络服务
答案：A
解析：交换机和路由器的管理包括了版本更新，也包括了补丁管理。

363．组织第一次建立业务连续性计划时，最为重要的活动是：
A.制定业务连续性策略
B.进行业务影响分析
C.进行灾难恢复演练
D.构建灾备系统
答案：B
解析：

364．防止非法授权访问数据文件的控制措施，哪项是最佳的方式：
A.自动文件条目
B.磁带库管理程序
C.访问控制软件
D.锁定库
答案：C
解析：

365．白盒测试的具体优点是：
A.其检查程序是否可与系统的其他部分一起正常运行
B.在不知程序内部结构下确保程序的功能性操作有效
C.其确定程序准确性成某程序的特定逻辑路径的状态
D.其通过严格限制访问主机系统的受控或虚拟环境中执行对程序功能的检查
答案：C
解析：

366. 为某航空公司的订票系统设计业务连续性计划时，最适用于异地数据转移/备份的方法是：

A. 文件映像处理

B. 电子链接

C. 硬盘镜像

D. 热备中心配置

答案：D

解析：

367. 组织内人力资源部门开发了一套系统，用于管理所有员工的各种工资、绩效、考核、奖励等事宜。所有员工都可以登录系统完成相关需要员工配合的工作，以下哪项技术可以保证数据的保密性：

A. SSL 加密

B. 双因子认证

C. 加密会话 cookie

D. IP 地址校验

答案：A

解析：

368. 以下哪一项不是我国信息安全保障的原则：

A. 立足国情，以我为主，坚持以技术为主

B. 正确处理安全与发展的关系，以安全保发展，在发展中求安全

C. 统筹规划，突出重点，强化基础性工作

D. 明确国家、企业、个人的责任和义务，充分发挥各方面的积极性，共同构筑国家信息安全保障体系

答案：A

解析：A 的正确描述为立足国情，以我为主，坚持以技术和管理并重。

369. 下列选项中，哪个不是我国信息安全保障工作的主要内容：

A. 加强信息安全标准化工作，积极采用“等同采用、修改采用、制定”等多种方式，尽快建立和完善我国信息安全标准体系

B. 建立国家信息安全研究中心，加快建立国家急需的信息安全技术体系，实现国家信息安全自主可控目标

C. 建设和完善信息安全基础设施，提供国家信息安全保障能力支撑

D. 加快信息安全学科建设和信息安全人才培养

答案：B

解析：建立国家信息安全研究中心不是我国信息安全保障工作的主要内容。

370. 关于信息安全管理，说法错误的是：

A. 信息安全管理是管理者为实现信息安全目标（信息资产的 CIA 等特性，以及业务运作的持续）而进行的计划、组织、指挥、协调和控制的一系列活动。

B. 信息安全管理是一个多层面、多因素的过程，依赖于建立信息安全组织、明确信息安全角色及职责、制定信息安全方针策略标准规范、建立有效的监督审计机制等多方面非技术性的努力。

C.实现信息安全，技术和产品是基础，管理是关键。
D.信息安全管理是人员、技术、操作三者紧密结合的系统工程，是一个静态过程。
答案：D
解析：信息安全管理是人员、技术、操作三者紧密结合的系统工程，是一个动态过程。

371．根据信息安全风险要素之间的关系，下图中空白处应该填写（）



A. 资产
B. 安全事件
C. 脆弱性
D. 安全措施
答案：C
解析：风险的原理是威胁利用脆弱性，造成对资产的风险。

372．以下哪个选项不是信息安全需求的来源?
A.法律法规与合同条约的要求
B.组织的原则、目标和规定
C.风险评估的结果
D.安全架构和安全厂商发布的病毒、漏洞预警
答案：D
解析：安全需求来源于内部驱动，D是外部参考要素，不属于信息安全需求的主要来源。

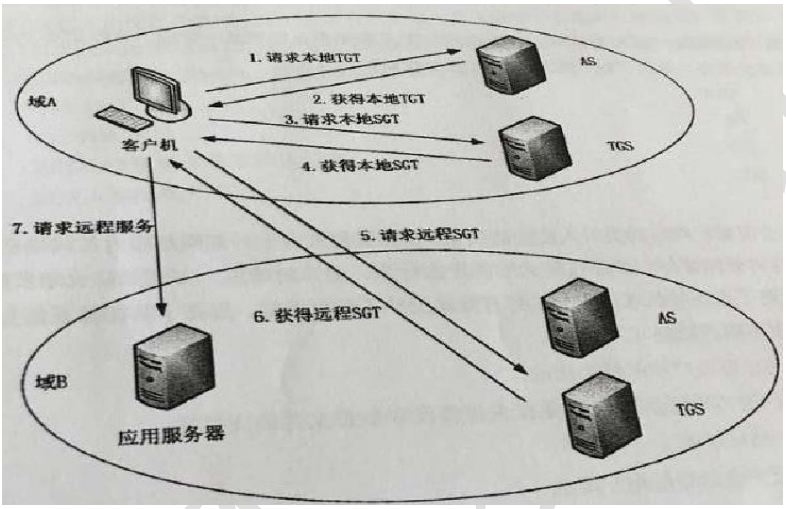
373．下列关于信息系统生命周期中实施阶段所涉及主要安全需求描述错误的是：
A.确保采购定制的设备、软件和其他系统组件满足已定义的安全要求
B.确保整个系统已按照领导要求进行了部署和配置
C.确保系统使用人员已具备使用系统安全功能和安全特性的能力
D.确保信息系统的使用已得到授权
答案：B
解析：B是错误的，不是按照领导要求进行了部署和配置。

374．下列关于信息系统生命周期中安全需求说法不准确的是：
A.明确安全总体方针，确保安全总体方针源自业务期望
B.描述所涉及系统的安全现状，提交明确的安全需求文档
C.向相关组织和领导人宣贯风险评估准则
D.对系统规划中安全实现的可能性进行充分分析和论证
答案：C
解析：C属于风险评估阶段，不属于题干中的安全需求阶段。

375．小张在某单位是负责事信息安全风险管理方面工作的部门领导，主要负责对所在行业的新人进行基本业务素质培训。一次培训的时候，小张主要负责讲解风险评估工作形式，小张认为：1．风险评估工作形式包括：自评估和检查评估；2．自评估是指信息系统拥有、运营或使用单位发起的对本单位信息系统进行风险评估；3．检查评估是信息系统上级管理部门组织或者国家有关职能部门依法开展的风险评估；4．对信息系统的风险评估方式只能是“自评估”和“检查评估”中的一个，非此即彼.请问小张的所述论点中错误的是哪项：

A.第一个观点
B.第二个观点
C.第三个观点
D.第四个观点
答案：D
解析：正确的做法为“自评估”和“检查评估”相互结合和互为补充。

376. 在现实的异构网络环境中，越来越多的信息需要实现安全的互操作。即进行跨域信息交换和处理。Kerberos 协议不仅能在域内进行认证，也支持跨域认证，下图显示的是 Kerberos 协议实现跨域认证的 7 个步骤，其中有几个步骤出现错误，图中错误的描述正确的是：（）



A.步骤 1 和步骤 2 发生错误，应该向本地 AS 请求并获得远程 TGT
B.步骤 3 和步骤 4 发生错误，应该向本地 TGS 请求并获得远程 TGT
C.步骤 5 和步骤 6 发生错误，应该向远程 AS 请求并获得远程 TGT
D.步骤 5 和步骤 6 发生错误，应该向远程 TGS 请求并获得远程 SGT
答案：B
解析：

377. 下图中描述网络动态安全的 P2DR 模型，这个模型经常使用图形的形式来表达，下图空白处应填（）



A.策略
B.方针

C.人员
D.项目
答案：A
解析：

378．风险评估工具的使用在一定程度上解决了手动评估的局限性，最主要的是它能够将专家知识进行集中，使专家的经验知识被广泛使用，根据在风险评估过程中的主要任务和作用愿理，风险评估工具可以为以下几类，其中错误的是：
A.风险评估与管理工具
B.系统基础平台风险评估工具
C.风险评估辅助工具
D.环境风险评估工具
答案：D
解析：通常情况下信息安全风险评估工具不包括环境评估工具。

379．为了解风险和控制风险，应当及时进行风险评估活动，我国有关文件指出：风险评估的工作形式可分为自评估和检查评估两种，关于自评估，下面选项中描述错误的是()。
A.自评估是由信息系统拥有、运营或使用单位发起的对本单位信息系统进行的风险评估
B.自评估应参照相应标准、依据制定的评估方案和准则，结合系统特定的安全要求实施
C.自评估应当是由发起单位自行组织力量完成，而不应委托社会风险评估服务机构来实施
D.周期性的自评估可以在评估流程上适当简化，如重点针对上次评估后系统变化部分进行
答案：C
解析：自评估也可以委托社会风险评估服务机构来实施。
380．信息安全风险评估是信息安全风险管理工作中的重要环节，在国家网络与信息安全协调小组发布的《关于开展信息安全风险评估工作的意见》(国信办(2006)5号)中，风险评估分为自评估和检查评估两种形式，并对两种工作形式提出了有关工作原则和要求，下面选项中描述正确的是( )。
A.信息安全风险评估应以自评估为主，自评估和检查评估相互结合、互为补充
B.信息安全风险评估应以检查评估为主，自评估和检查评估相互结合、互为补充
C.自评估和检查评估是相互排斥的，单位应慎重地从两种工作形式选择一个，并长期使用
D.自评估和检查评估是相互排斥的，无特殊理由单位均应选择检查评估，以保证安全效果
答案：A
解析：信息安全风险评估应以自评估为主，自评估和检查评估相互结合、互为补充。

381．规范的实施流程和文档管理，是信息安全风险评估结能否取得成果的重要基础，某单位在实施风险评估时，形成了《风险评估方案》并得到了管理决策层的认可，在风险评估实施的各个阶段中，该《风险评估方案》应是如下(　　)中的输出结果。
A.风险评估准备阶段
B.风险要素识别阶段
C.风险分析阶段
D.风险结果判定阶段
答案：A
解析：《风险评估方案》属于风险评估准备阶段的结果。

382. 风险要素识别是风险评估实施过程中的一个重要步骤，有关安全要素，请选择一个最合适的选项()。

A.识别面临的风险并赋值

B.识别存在的脆弱性并赋值

C.制定安全措施实施计划

D.检查安全措施有效性

答案：B

解析：风险要素包括资产、威胁、脆弱性、安全措施。

383. 文档体系建设是信息安全管理体系(ISMS)建设的直接体现，下列说法不正确的是：

A.组织内的信息安全方针文件、信息安全规章制度文件、信息安全相关操作规范文件等文档是组织的工作标准，也是 ISMS 审核的依据

B.组织内的业务系统日志文件、风险评估报告等文档是对上一级文件的执行和记录，对这些记录不需要保护和控制

C.组织在每份文件的首页，加上文件修订跟踪表，以显示每一版本的版本号、发布日期、编写人、审批人、主要修订等内容

D.层次化的文档是 ISMS 建设的直接体现，文档体系应当依据风险评估的结果建立

答案：B

解析：信息安全管理体系运行记录需要保护和控制。

384. 以下系统工程说法错误的是：

A.系统工程是基本理论的技术实现

B.系统工程是一种对所有系统都具有普遍意义的科学方法

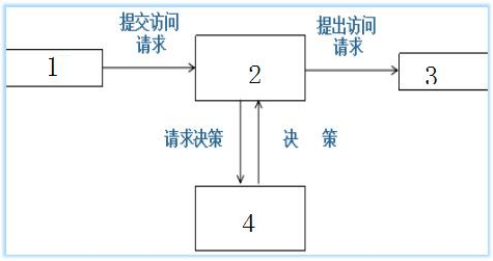
C.系统工程是组织管理系统规划、研究、制造、试验、使用的科学方法

D.系统工程是一种方法论

答案：A

解析：系统工程是方法论，不是技术实现。

385. 访问控制的实施一般包括两个步骤，首先要鉴别主体的合法身份，接着根据当前系统的访问控制规则授予相应用户的访问权限。在此过程中，涉及主体、客体、访问控制实施部件和访问控制决策部件之间的交互。下图所示的访问控制实施步骤中，你认为那个是正确的：（）



A. 1 是主体，2 是客体,3 是实施，4 是决策

B.1 是客体，2 是主体 3 是决策，4 是实施

C.1 实施，2 是客体 3 是主题，4 是决策

D.1 是主体，2 是实施 3 是客体，4 是决策

答案：D

解析：P306

386. 组织建立业务连续性计划（BCP)的作用包括：
A.在遭遇灾难事件时，能够最大限度地保护组织数据的实时性，完整性和一致性；
B.提供各种恢复策略选择，尽量减小数据损失和恢复时间，快速恢复操作系统、应用和数据；
C.保证发生各种不可预料的故障、破坏性事故或灾难情况时，能够持续服务，确保业务系统的不间断运行，降低损失；
D.以上都是。
答案：D
解析：

387. 业务系统运行中异常错误处理合理的方法是：
A.让系统自己处理异常
B.调试方便，应该让更多的错误更详细的显示出来
C.捕获错误，并抛出前台显示
D.捕获错误，只显示简单的提示信息，或不显示任何信息
答案：D
解析：D 为正确的处理方法，符合最小化反馈原则。

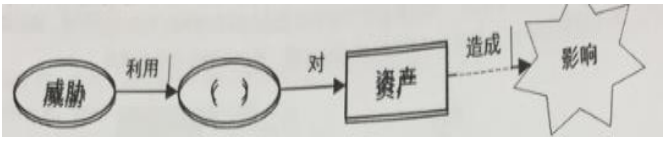
388. 以下哪项不是应急响应准备阶段应该做的？
A.确定重要资产和风险，实施针对风险的防护措施
B.编制和管理应急响应计划
C.建立和训练应急响应组织和准备相关的资源
D.评估事件的影响范围，增强审计功能、备份完整系统
答案：D
解析：D 描述的是安全事件发生以后，不是应急响应的准备。

389. 以下属于哪一种认证实现方式：用户登录时，认证服务器（Authentication Server，AS)产生一个随机数发送给用户，用户用某种单向算法将自己的口令、种子密钥和随机数混合计算后作为一次性口令，并发送给 AS，AS 用同样的方法计算后，验证比较两个口令即可验证用户身份
A.口令序列
B.时间同步
C.挑战/应答
D.静态口令
答案：C
解析：题干描述的是 C 的解释。

390. 在对某面向互联网提供服务的某应用服务器的安全检测中发现，服务器上开放了以下几个应用，除了一个应用外其他应用都存在明文传输信息的安全问题，作为一名检测人员，你需要告诉用户对应用进行安全整改以外解决明文传输数据的问题，以下哪个应用已经解决了明文传输数据问题：
A.SSH
B.HTTP
C.FTP
D.SMTP

答案：A
解析：SSH 具备数据加密保护的功能。

391. 陈工学习了信息安全风险的有关知识，了解到信息安全风险的构成过程，有五个方面：起源、方式、途径、受体和后果，他画了下面这张图来描述信息安全风险的构成过程，图中空白处应填写？（）



A.信息载体
B.措施
C.脆弱性
D.风险评估
答案：C
解析：

392. 以下哪个属性不会出现在防火墙的访问控制策略配置中？
A.本局域网内地址
B.百度服务器地址
C.HTTP 协议
D.病毒类型
答案：D
解析：病毒类型不会出现在防火墙的访问控制策略中

393. 某 linux 系统由于 root 口令过于简单，被攻击者猜解后获得了 root 口令，发现被攻击后，管理员更改了 root 口令，并请安全专家对系统进行检测，在系统中发现有一个文件的权限如下 -r-s--x--x 1 test tdst 10704 apr 15 2002/home/test/sh 请问以下描述哪个是正确的：
A.该文件是一个正常文件，test 用户使用的 shell,test 不能读该文件，只能执行
B.该文件是一个正常文件，是 test 用户使用的 shell,但 test 用户无权执行该文件
C.该文件是一个后门程序，该文件被执行时，运行身份是 root ,test 用户间接获得了 root 权限
D.该文件是一个后门程序，由于所有者是 test，因此运行这个文件时文件执行权限为 test
答案：D
解析：根据题干则答案为 D。

394. 某网站为了更好向用户提供服务，在新版本设计时提供了用户快捷登录功能，用户如果使用上次的 IP 地址进行访问，就可以无需验证直接登录，该功能推出后，导致大量用户账号被盗用，关于以上问题的说法正确的是:
A.网站问题是由于开发人员不熟悉安全编码，编写了不安全的代码，导致攻击面增大，产生此安全问题
B.网站问题是由于用户缺乏安全意识导致，使用了不安全的功能，导致网站攻击面增大，产生此问题
C.网站问题是由于使用便利性提高，带来网站用户数增加，导致网站攻击面增大，产生此安全问题

D.网站问题是设计人员不了解安全设计关键要素，设计了不安全的功能，导致网站攻击面增大，产生此问题

答案：D

解析：网站问题是设计人员不了解安全设计关键要素，设计了不安全的功能，导致网站攻击面增大，产生此问题。

395. 风险分析师风险评估工作的一个重要内容，GB/T 20984-2007 在资料性附录中给出了一种矩阵法来计算信息安全风险大小，如下图所示，图中括号应填那个？（）

（）	安全事件发生可能性				
	1	2	3	4	5
1	3	6	9	12	16
2	5	8	11	15	18
3	6	9	13	17	21
4	7	11	16	20	23
5	9	14	20	23	25

A.安全资产价值大小等级

B.脆弱性严重程度等级

C.安全风险隐患严重等级

D.安全事件造成损失大小

答案：D

解析：

396. 提高 Apache 系统(Apache HTTP Server)系统安全性时，下面哪项措施不属于安全配置()?

A.不在 Windows 下安装 Apache，只在 Linux 和 Unix 下安装

B.安装 Apache 时，只安装需要的组件模块

C.不使用操作系统管理员用户身份运行 Apache，而是采用权限受限的专用用户账号来运行

D.积极了解 Apache 的安全通告，并及时下载和更新

答案：A

解析：A 不属于安全配置，而属于部署环境选择。

397. 某公司开发了一个游戏网站，但是由于网站软件存在漏洞，在网络中传输大数据包时总是会丢失一些数据，如一次性传输大于 2000 个字节数据时，总是会有 3 到 5 个字节不能传送到对方，关于此案例，可以推断的是（）

A.该网站软件存在保密性方面安全问题

B.该网站软件存在完整性方面安全问题

C.该网站软件存在可用性方面安全问题

D.该网站软件存在不可否认性方面安全问题

答案：B

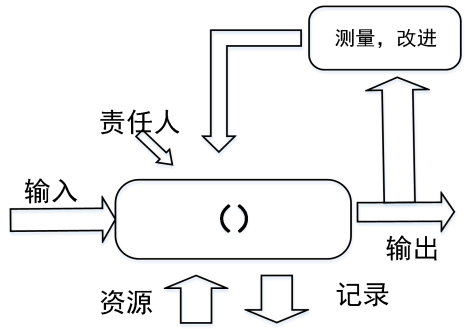
解析：题干描述的是完整性。

398. 我国党和政府一直重视信息安全工作，我国信息安全保障工作也取得了明显成效，关于我国信息安全实践工作，下面说法错误的是（）

A.加强信息安全标准化建设,成立了“全国信息安全标准化技术委员会”制订和发布了大批信息安全技术，管理等方面的标准。

B.重视信息安全应急处理工作，确定由国家密码管理局牵头成立“国家网络应急中心”推动了应急处理和信息通报技术合作工作进展
C.推进信息安全等级保护工作，研究制定了多个有关信息安全等级保护的规范和标准，重点保障了关系国定安全，经济命脉和社会稳定等方面重要信息系统的安全性
D.实施了信息安全风险评估工作，探索了风险评估工作的基本规律和方法，检验并修改完善了有关标准，培养和锻炼了人才队伍
答案：B
解析：工业和信息化部牵头成立“国家网络应急中心”。

399. ISO9001-2000 标准在制定、实施质量管理体系以及改进其有效性时采用过程方法，通过满足顾客要求增进顾客满意。下图是关于过程方法的示意图，图中括号空白处应填写（）



A.策略
B.管理者
C.组织
D.活动
答案：D
解析：该题为 PDCA 的变形。

400. 关于风险要素识别阶段工作内容叙述错误的是：
A.资产识别是指对需求保护的资产和系统等进行识别和分类
B.威胁识别是指识别与每项资产相关的可能威胁和漏洞及其发生的可能性
C.脆弱性识别以资产为核心，针对每一项需求保护的资产，识别可能被威胁利用的弱点，并对脆弱性的严重程度进行评估
D.确认已有的安全措施仅属于技术层面的工作，牵涉到具体方面包括：物理平台、系统平台、网络平台和应用平台
答案：D
解析：安全措施既包括技术层面，也包括管理层面。

练习题第五卷

401. 信息安全保障是网络时代各国维护国家安全和利益的首要任务，以下哪个国家最早将网络安全上长升为国家安全战略，并制定相关战略计划。
A.中国
B.俄罗斯
C.美国
D.英国
答案：C

解析：

402. 信息安全标准化工作是我国信息安全保障工作的重要组成部分之一，也是政府进行宏观管理的重要依据，同时也是保护国家利益，促进产业发展的重要手段之一，关于我国标准化工作，下面选项中描述错误的是（）

A.我国是在国家质量监督检验疫总局管理下，由国家标准化管理委员会统一管理全国标准化工作，下设有专业技术委员会

B.事关国家安全利益，信息安全因此不能和国际标准相同，而是要通过本国组织和专家制定标准，切实有效地保护国家利益和安全

C.我国归口信息安全方面标准是“全国信息安全标准化技术委员会”，为加强有关工作，2016 在其下设立“大数据安全特别工作组”

D.信息安全标准化工作是解决信息安全问题的重要技术支撑，其主要作业突出体现在能够确保有关产品、设施的技术先进性、可靠性和一致性

答案：B

解析：信息安全的标准可以和国际标准相同，也可以不相同。包括同等采用方式和等效采用方式等。

403. 最小特权是软件安全设计的基本原则，某应用程序在设计时，设计人员给出了以下四种策略，其中有一个违反了最小特权的原则，作为评审专家，请指出是哪一个?

A.软件在 Linux 下按照时，设定运行时使用 nobody 用户运行实例

B.软件的日志备份模块由于需要备份所有数据库数据，在备份模块运行时，以数据库备份操作员账号连接数据库

C.软件的日志模块由于要向数据库中的日志表中写入日志信息，使用了一个日志用户账号连接数据库，该账号仅对日志表拥有权限

D.为了保证软件在 Windows 下能稳定的运行，设定运行权限为 system，确保系统运行正常，不会因为权限不足产生运行错误

答案：D

解析：SYSTEM 权限是最大权限，违反了最小特权的原则。

404. 某电子商务网站最近发生了一起安全事件，出现了一个价值 1000 元的商品用 1 元被买走的情况，经分析是由于设计时出于性能考虑，在浏览时使用 Http 协议，攻击者通过伪造数据包使得向购物车添加商品的价格被修改. 利用此漏洞，攻击者将价值 1000 元的商品以 1 元添加到购物车中，而付款时又没有验证的环节，导致以上问题，对于网站的这个问题原因分析及解决措施。最正确的说法应该是?

A.该问题的产生是由于使用了不安全的协议导致的，为了避免再发生类似的闯题，应对全网站进行安全改造，所有的访问都强制要求使用 https

B.该问题的产生是由于网站开发前没有进行如威胁建模等相关工作或工作不到位，没有找到该威胁并采取相应的消减措施

C.该问题产生是由于编码缺陷，通过对网站进行修改，在进行订单付款时进行商品价格验证就可以解决

D.该问题的产生不是网站的问题，应报警要求寻求警察介入，严惩攻击者即可

答案：A

解析：根据题干是采用 HTTP 的协议（明文传输）导致的，则答案为 A。

405. 以下哪个选项不是防火墙提供的安全功能?
A.IP 地址欺骗防护
B.NAT
C.访问控制
D.SQL 注入攻击防护
答案：D
解析：题干中针对的是传统防火墙或者说网络防火墙，ABC 都是传统防火墙能提供的服务，而 SQL 注入防护是 WAF 的主要功能。

406. 以下关于可信计算说法错误的是：
A.可信的主要目的是要建立起主动防御的信息安全保障体系
B.可信计算机安全评价标准(TCSEC)中第一次提出了可信计算机和可信计算基的概念
C.可信的整体框架包含终端可信、终端应用可信、操作系统可信、网络互联可信、互联网交易等应用系统可信
D.可信计算平台出现后会取代传统的安全防护体系和方法
答案：D
解析：可信计算平台出现后不会取代传统的安全防护体系和方法。

407. Linux 系统对文件的权限是以模式位的形式来表示，对于文件名为 test 的一个文件，属于 admin 组中 user 用户，以下哪个是该文件正确的模式表示?
A. - rwx r-x r-x 3 user admin 1024 Sep 13 11：58 test
B. d rwx r-x r-x 3 user admin 1024 Sep 13 11：58 test
C.- rwx r-x r-x 3 admin user 1024 Sep 13 11：58 test
D.d rwx r-x r-x 3 admin user1024 Sep 13 11：58 test
答案：A
解析：题目考核的是 linux 系统的权限表达格式。

408. Apache Web 服务器的配置文件一般位于/usr / local / apache / conf 目录，其中用来控制用户访问 Apache 目录的配置文件是：
A. httpd.conf
B.srl conf
C.access. conf
D.Inet.conf
答案：A
解析：根据题干本题选择 A。

409. 应用软件的数据存储在数据库中，为了保证数据安全，应设置良好的数据库防护策略，以下不属于数据库防护策略的是?
A.安装最新的数据库软件安全补丁
B.对存储的敏感数据进行安全加密
C.不使用管理员权限直接连接数据库系统
D.定期对数据库服务器进行重启以确保数据库运行良好
答案：D
解析：D 项属于运维但不属于防护策略。

410. 下列哪项内容描述的是缓冲区溢出漏洞?

A.通过把 SQL 命令插入到 web 表单递交或输入域名或页面请求的查询字符串,最终达到欺骗服务器执行恶意的 SQL 命令

B.攻击者在远程 WEB 页面的 HTML 代码中插入具有恶意目的的数据，用户认为该页面是可信赖的，但是当浏览器下载该页面，嵌入其中的脚本将被解释执行。

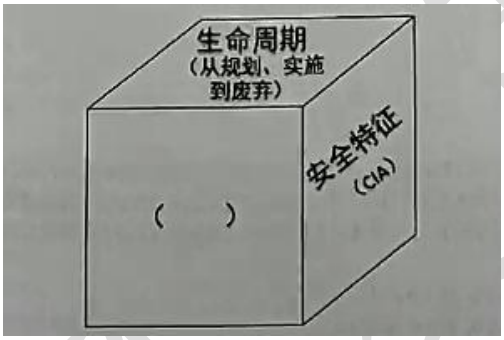
C.当计算机向缓冲区内填充数据位数时超过了缓冲区本身的容量溢出的数据覆盖在合法数据上

D.信息技术、信息产品、信息系统在设计、实现、配置、运行等过程中，有意或无意产生的缺陷

答案：C

解析：C 为缓冲区溢出的正确解释。

411. 某学员在学习国家标准《信息系统安全保障评估框架第一部分：简介和一般模型》（GB/T 20274.1-2006）后，绘制了一张简化的信息系统安全保障模型图，如下所示。请为图中括号空白处选择合适的选项（）



A.安全保障（方针和组织）

B.安全防护（技术和管理）

C.深度防御（策略、防护、检测、响应）

D.保障要素（管理、工程、技术、人员）

答案：D

解析：

412. 安全专家在对某网站进行安全部署时，调整了 Apache 的运行权限，从 root 权限降低为 nobody 用户，以下操作的主要目的是：

A.为了提高 Apache 软件运行效率

B.为了提高 Apache 软件的可靠性

C.为了避免攻击者通过 Apache 获得 root 权限

D.为了减少 Apache 上存在的漏洞

答案：C

解析：避免攻击者通过 Apache 获得 root 权限。

413. 下列关于计算机病毒感染能力的说法不正确的是：

A.能将自身代码注入到引导区

B.能将自身代码注入到扇区中的文件镜像

C.能将自身代码注入文本文件中并执行

D.能将自身代码注入到文档或模板的宏中代码

答案：C

解析：代码注入文本文件中不能执行。

414. 以下哪个是恶意代码采用的隐藏技术：
A.文件隐藏
B.进程隐藏
C.网络连接隐藏
D.以上都是
答案：D
解析：恶意代码采用的隐藏技术包括：文件隐藏、进程隐藏、网络连接隐藏等。

415. 通过向被攻击者发送大量的 ICMP 回应请求，消耗被攻击者的资源来进行响应，直至被攻击者再也无法处理有效的网络信息流时，这种攻击称之为：
A.Land 攻击
B.Smurf 攻击
C.Ping of Death 攻击
D.ICMP Flood
答案：D
解析：发送大量的 ICMP 回应请求为 ICMP Flood。

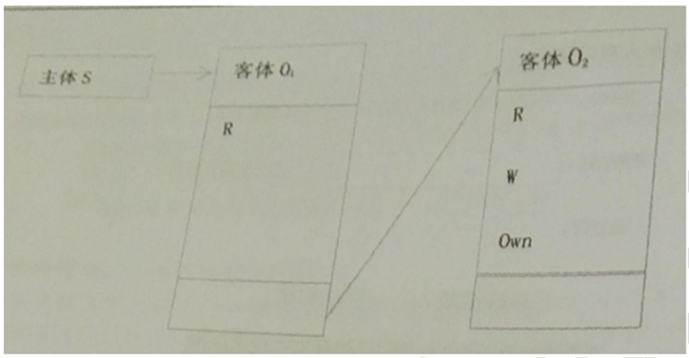
416. 以下哪个拒绝服务攻击方式不是流量型拒绝服务攻击
A.Land
B.UDP Flood
C.Smurf
D.Teardrop
答案：D
解析：Teardrop 属于碎片攻击，不属于流量型拒绝服务攻击。

417. 传输控制协议(TCP)是传输层协议，以下关于 TCP 协议的说法，哪个是正确的?
A.相比传输层的另外一个协议 UDP，TCP 既提供传输可靠性，还同时具有更高的效率，因此具有广泛的用途
B.TCP 协议包头中包含了源 IP 地址和目的 IP 地址，因此 TCP 协议负责将数据传送到正确的主机
C.TCP 协议具有流量控制、数据校验、超时重发、接收确认等机制，因此 TCP 协议能完全替代 IP 协议
D.TCP 协议虽然高可靠，但是相比 UDP 协议机制过于复杂，传输效率要比 UDP 低
答案：D
解析：TCP 协议高可靠，相比 UDP 协议机制过于复杂，传输效率要比 UDP 低。

418. 以下关于 UDP 协议的说法，哪个是错误的?
A.UDP 具有简单高效的特点，常被攻击者用来实施流量型拒绝服务攻击
B.UDP 协议包头中包含了源端口号和目的端口号，因此 UDP 可通过端口号将数据包送达正确的程序
C.相比 TCP 协议，UDP 协议的系统开销更小，因此常用来传送如视频这一类高流量需求的应用数据

D.UDP 协议不仅具有流量控制，超时重发等机制，还能提供加密等服务，因此常用来传输如视频会话这类需要隐私保护的数据
答案：D
解析：UDP 协议无流量控制，超时重发等机制。

419. 如图所示，主体 S 对客体 O1 有读（R）权限，对客体 O2 有读（R） 、写（W）权限。该图所示的访问控制实现方法是：（）



A.访问控制表（ACL）
B.访问控制矩阵
C.能力表（CL）
D.前缀表（Profiles）
答案：C
解析：P307

420. 有关项目管理，错误的理解是：
A.项目管理是一门关于项目资金、时间、人力等资源控制的管理科学
B.项目管理是运用系统的观点、方法和理论，对项目涉及的全部工作进行有效地管理，不受项目资源的约束
C.项目管理包括对项目范围、时间、成本、质量、人力资源、沟通、风险、采购、集成的管理
D.项目管理是系统工程思想针对具体项目的实践应用
答案：B
解析：项目管理受项目资源的约束。

421. 近年来利用 DNS 劫持攻击大型网站恶性攻击事件时有发生，防范这种攻击比较有效的方法是?
A.加强网站源代码的安全性
B.对网络客户端进行安全评估
C.协调运营商对域名解析服务器进行加固
D.在网站的网络出口部署应用级防火墙
答案：C
解析：协调运营商对域名解析服务器进行加固是 DNS 防护的主要手段。

422. 关于源代码审核，下列说法正确的是：
A.人工审核源代码审校的效率低，但采用多人并行分析可以完全弥补这个缺点

B.源代码审核通过提供非预期的输入并监视异常结果来发现软件故障，从而定位可能导致安全弱点的薄弱之处
C.使用工具进行源代码审核，速度快，准确率高，已经取代了传统的人工审核
D.源代码审核是对源代码检查分析，检测并报告源代码中可能导致安全弱点的薄弱之处
答案：D
解析：D 为源代码审核工作内容描述。

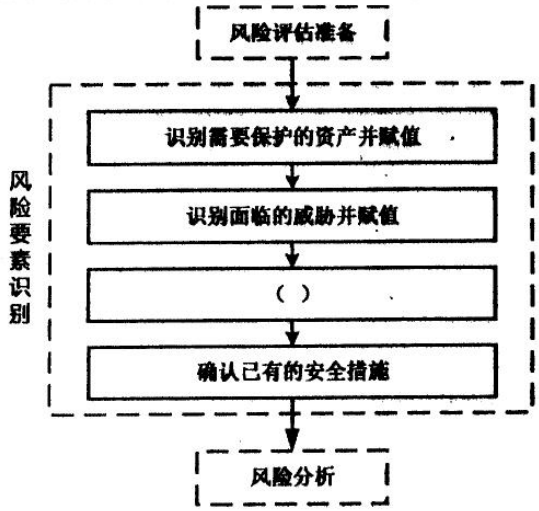
423．在戴明环(PDCA)模型中，处置(ACT)环节的信息安全管理活动是：
A.建立环境
B.实施风险处理计划
C.持续的监视与评审风险
D.持续改进信息安全管理过程
答案：D
解析：持续改进信息安全管理过程属于处置(ACT)阶段。

424．信息系统的业务特性应该从哪里获取?
A.机构的使命
B.机构的战略背景和战略目标
C.机构的业务内容和业务流程
D.机构的组织结构和管理制度
答案：C
解析：业务特性从机构的业务内容和业务流程获取。

425．在信息系统设计阶段，“安全产品选择”处于风险管理过程的哪个阶段?
A.背景建立
B.风险评估
C.风险处理
D.批准监督
答案：C
解析：“安全产品选择”是为了进行风险处理。

426．以下关于“最小特权”安全管理原则理解正确的是：
A.组织机构内的敏感岗位不能由一个人长期负责
B.对重要的工作进行分解，分配给不同人员完成
C.一个人有且仅有其执行岗位所足够的许可和权限
D.防止员工由一个岗位变动到另一个岗位，累积越来越多的权限
答案：C
解析：C 是“最小特权”的解释；A 描述的是轮岗；B 描述的是权限分离；D 描述的是防止权限蔓延。

427．风险要素识别是风险评估实施过程中的一个重要步骤，小李将风险要素识别的主要过程使用图形来表示，如下图所示，请为图中空白框处选择一个最合适的选项()。



A．识别面临的风险并赋值
B．识别存在的脆弱性并赋值
C．制定安全措施实施计划
D．检查安全措施有效性
答案：B
解析：

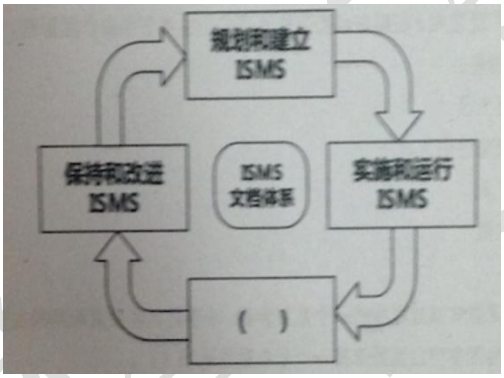
428．以下哪一项不属于常见的风险评估与管理工具（）：
A.基于信息安全标准的风险评估与管理工具
B.基于知识的风险评估与管理工具
C.基于模型的风险评估与管理工具
D.基于经验的风险评估与管理工具
答案：D
解析：D 基于经验的风险评估工具不存在。

429．信息系统安全保护等级为 3 级的系统，应当（）年进行一次等级测评?
A.0.5
B.1
C.2
D.3
答案：B
解析：等级保护三级系统一年测评一次，四级系统每半年测评一次。

430．关于我国加强信息安全保障工作的总体要求，以下说法错误的是：（）
A.坚持积极防御、综合防范的方针
B.重点保障基础信息网络和重要信息系统安全
C.创建安全健康的网络环境
D.提高个人隐私保护意识
答案：D
解析：提高个人隐私保护意识不属于（2003 年）我国加强信息安全保障工作的总体要求。

431. 根据《关于加强国家电子政务工程建设项目信息安全风险评估工作的通知》的规定，以下正确的是：
A.涉密信息系统的风险评估应按照《信息安全等级保护管理办法》等国家有关保密规定和标准进行
B.非涉密信息系统的风险评估应按照《非涉及国家秘密的信息系统分级保护管理办法》等要求进行
C.可委托同一专业测评机构完成等级测评和风险评估工作，并形成等级测评报告和风险评估报告
D.此通知不要求将“信息安全风险评估”作为电子政务项目验收的重要内容
答案：C
解析：根据《关于加强国家电子政务工程建设项目信息安全风险评估工作的通知》的规定，可委托同一专业测评机构完成等级测评和风险评估工作，并形成等级测评报告和风险评估报告。

432. 小李去参加单位组织的信息安全培训后，他把自己对管理信息管理体系 ISMS 的理解画了一张图，但是他还存在一个空白处未填写，请帮他选择一个合适的选项（）



A. 监控和反馈 ISMS
B. 批准和监督 ISMS
C. 监视和评审 ISMS
D. 沟通和咨询 ISMS
答案：C
解析：

433. 软件安全保障的思想是在软件的全生命周期中贯彻风险管理的思想，在有限资源前提下实现软件安全最优防护，避免防范不足带来的直接损失，也需要关注过度防范造成的间接损失。在以下软件安全开发策略中，不符合软件安全保障思想的是：
A.在软件立项时考虑到软件安全相关费用，经费中预留了安全测试、安全评审相关费用，确保安全经费得到落实
B.在软件安全设计时，邀请软件安全开发专家对软件架构设计进行评审，及时发现架构设计中存在的安全不足
C.确保对软编码人员进行安全培训，使开发人员了解安全编码基本原则和方法，确保开发人员编写出安全的代码
D.在软件上线前对软件进行全面安全性测试，包括源代码分析、模糊测试、渗透测试，未经以上测试的软件不允许上线运行
答案：D
解析：软件的安全测试根据实际情况进行测试措施的选择和组合。

434．某单位人员管理系统在人员离职时进行账号删除，需要离职员工所在部门主管经理和人事部门人员同时进行确认才能在系统上执行，该设计是遵循了软件安全哪项原则
A.最小权限
B.权限分离
C.不信任
D.纵深防御
答案：B
解析：权限分离是将一个较大的权限分离为多个子权限组合操作来实现。

435．为防范网络欺诈确保交易安全，网银系统首先要求用户安全登录，然后使用“智能卡+短信认证”模式进行网上转账等交易，在此场景中用到下列哪些鉴别方法?
A.实体“所知”以及实体“所有”的鉴别方法
B.实体“所有”以及实体“特征”的鉴别方法
C.实体“所知”以及实体“特征”的鉴别方法
D.实体“所有”以及实体“行为”的鉴别方法
答案：A
解析：题目中安全登录会涉及到账号密码为实体所知，智能卡和短信是实体所有。

436．某单位开发了一个面向互联网提供服务的应用网站，该单位委托软件测评机构对软件进行了源代码分析、模糊测试等软件安全性测试，在应用上线前，项目经理提出了还需要对应用网站进行一次渗透性测试,作为安全主管,你需要提出渗透性测试相比源代码测试、模糊测试的优势给领导做决策，以下哪条是渗透性测试的优势?
A.渗透测试以攻击者的思维模拟真实攻击，能发现如配置错误等运行维护期产生的漏洞
B.渗透测试是用软件代替人工的一种测试方法，因此测试效率更高
C.渗透测试使用人工进行测试，不依赖软件，因此测试更准确
D.渗透测试中必须要查看软件源代码，因此测试中发现的漏洞更多
答案：A
解析：a 是渗透测试的优点，渗透测试是模拟攻击的黑盒测试，有利于发现系统明显的问题。

437.信息系统安全工程(ISSE)的一个重要目标就是在 IT 项目的各个阶段充分考虑安全因素，在 IT 项目的立项阶段，以下哪一项不是必须进行的工作：
A.明确业务对信息安全的要求
B.识别来自法律法规的安全要求
C.论证安全要求是否正确完整
D.通过测试证明系统的功能和性能可以满足安全要求
答案：D
解析：D 属于项目的验收阶段，不属于 IT 项目的立项阶段，题干属于立项阶段。

438．以下关于软件安全测试说法正确的是（）
A.软件安全测试就是黑盒测试
B.FUZZ 测试是经常采用的安全测试方法之一
C.软件安全测试关注的是软件的功能
D.软件安全测试可以发现软件中产生的所有安全问题

答案：B
解析：FUZZ 测试是经常采用的安全测试方法之一，软件安全测试包括模糊测试、渗透测试、静态代码安全测试，只关注安全问题。

439. 信息安全工程作为信息安全保障的重要组成部门，主要是为了解决:
A.信息系统的技术架构安全问题
B.信息系统组成部门的组件安全问题
C.信息系统生命周期的过程安全问题
D.信息系统运行维护的安全管理问题
答案：C
解析：信息安全工程作为信息安全保障的重要组成部门，主要是为了解决信息系统生命周期的过程安全问题。

440. 实体身份鉴别的方法多种多样，且随着技术的进步，鉴别方法的强度不断提高，常见的方法有指令鉴别、令牌鉴别、指纹鉴别等。如图，小王作为合法用户使用自己的账户进行支付、转账等操作。这说法属于下列选项中的（）



A.实体所知的鉴别方法
B.实体所有的鉴别方法
C.实体特征的鉴别方法
D.实体所见的鉴别方法
答案：C
解析：

441. 有关系统安全工程-能力成熟度模型（SSE-CMM)中基本实施（Base Practice）正确的理解是：
A.BP 不限定于特定的方法工具，不同业务背景中可以使用不同的方法
B.BP 不是根据广泛的现有资料，实施和专家意见综合得出的
C.BP 不代表信息安全工程领域的最佳实践
D.BP 不是过程区域（Process Areas，PA)的强制项
答案：A
解析：BP 属于安全工程的最小单元，其不限定于特定的方法工具，不同业务背景中可以使用不同的方法；是根据广泛的现有资料，实施和专家意见综合得出的；代表着信息安全工程领域的最佳实践；并且是过程区域（Process Areas，PA)的强制项。

442. 层次化的文档是信息安全管理体系《Information Security Management System.ISMS》建设的直接体系，也 ISMS 建设的成果之一，通常将 ISMS 的文档结构规划为 4 层金字塔结构，那么，以下选项（）应放入到一级文件中.
A.《风险评估报告》
B.《人力资源安全管理规定》
C.《ISMS 内部审核计划》
D.《单位信息安全方针》
答案：D

解析：一级文件中一般为安全方针、策略文件；二级文件中一般为管理规范制度；三级文件一般为操作手册和流程；四级文件一般表单和管理记录。

443. 信息安全管理体系（information Security Management System.简称 ISMS）的实施和运行 ISMS 阶段，是 ISMS 过程模型的实施阶段（Do），下面给出了一些活动①制定风险处理计划②实施风险处理计划③开发有效性测量程序④实施培训和意识教育计划⑤管理 ISMS 的运行⑥管理 ISMS 的资源⑦执行检测事态和响应事件的程序⑧实施内部审核⑨实施风险再评估选的活动，选项（）描述了在此阶段组织应进行的活动。
A.①②③④⑤⑥
B.①②③④⑤⑥⑦
C.①②③④⑤⑥⑦⑧
D.①②③④⑤⑥⑦⑧⑨
答案：B
解析：管理体系包括 PDCA（Plan-Do-Check-Act）四个阶段，题干中 1-7 的工作都属于管理体系的实施阶段（D-Do），而 8 和 9 属于检查阶段（C-Check）。

444. 在实施信息安全风险评估时，需要对资产的价值进行识别、分类和赋值，关于资产价值的评估，以下选项中正确的是（）
A.资产的价值指采购费用
B.资产的价值指维护费用
C.资产的价值与其重要性密切相关
D.资产的价值无法估计
答案：C
解析：

445. 某网站在设计对经过了威胁建模和攻击面分析，在开发时要求程序员编写安全的代码，但是在部署时由于管理员将备份存放在 WEB 目录下导致了攻击者可直接下载备份，为了发现系统中是否存在其他类似问题，以下哪种测试方式是最佳的测试方法。
A.模糊测试
B.源代码测试
C.渗透测试
D.软件功能测试
答案：C
解析：渗透测试是通过攻击者的角度进行安全测试，对系统进行安全评估的一种测试方法。

446. 下面哪项属于软件开发安全方面的问题（）
A.软件部署时所需选用服务性能不高，导致软件执行效率低。
B.应用软件来考虑多线程技术，在对用户服务时按序排队提供服务
C.应用软件存在 SQL 注入漏洞，若被黑客利用能窃取数据库所用数据
D.软件受许可证（license）限制，不能在多台电脑上安装。
答案：C
解析：ABD 与安全无关。

447. Linux 系统的安全设置中，对文件的权限操作是一项关键操作。通过对文件权限的设置,能够保障不同用户的个人隐私和系统安全。文件 fib.c 的文件属性信息如下图所示，小张想要修改其文件权限，为文件主增加执行权限，并删除组外其他用户的写权限，那么以下操作中正确的是（）



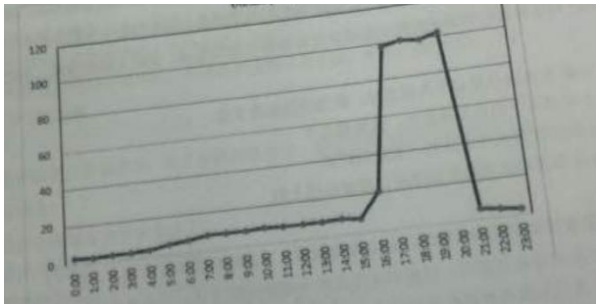
A.#chmod u+x, a-w fib.c
B.#chmod ug+x, o-w fib.c
C.#chmod 764 fib.c
D.#chmod 467 fib.c
答案：C
解析：读权限 r=4,写权限 w=2，执行 x=1,7=4+2+1;

448. 关于软件安全开发生命周期(SDL)，下面说法错误的是：
A.在软件开发的各个周期都要考虑安全因素
B.软件安全开发生命周期要综合采用技术、管理和工程等手段
C.测试阶段是发现并改正软件安全漏洞的最佳环节,过早或过晚检测修改漏洞都将增大软件开发成本
D.在设计阶段就尽可能发现并改正安全隐患，将极大减少整个软件开发成本
答案：C
解析：设计阶段是发现和改正问题的最佳阶段。

449. 从系统工程的角度来处理信息安全问题，以下说法错误的是：
A.系统安全工程旨在了解企业存在的安全风险，建立一组平衡的安全需求，融合各种工程学科的努力将此安全需求转换为贯穿系统整个生存期的工程实施指南。
B.系统安全工程需对安全机制的正确性和有效性做出诠释,证明安全系统的信任度能够达到企业的要求，或系统遗留的安全薄弱性在可容许范围之内。
C.系统安全工程能力成熟度模型(SSE-CMM)是一种衡量安全工程实践能力的方法，是一种使用面向开发的方法。
D.系统安全工程能力成熟度模型(SSE-CMM)是在原有能力成熟度模型(CMM)的基础上,通过对安全工作过程进行管理的途径，将系统安全工程转变为一个完好定义的、成熟的、可测量的先进学科。
答案：C
解析：SSE-CMM 是面向工程过程质量控制的一套方法。

450.有关系统安全工程-能力成熟度模型(SSE-CMM)中的基本实施(Base Practices，BP)，正确的理解是：
A.BP 是基于最新技术而制定的安全参数基本配置
B.大部分 BP 是没有经过测试的
C.一项 BP 适用于组织的生存周期而非仅适用于工程的某一特定阶段
D.一项 BP 可以和其他 BP 有重叠
答案：C
解析：A 错误，BP 是基于最佳的工程过程实践；B 错误，BP 是经过测试的；D 错误，一项 BP 和其他的 BP 是不重复。

451. 下图是某单位对其主网站一天流量的监测图，如果该网站当天 17：00 到 20：00 之间受到攻击，则从图中数据分析，这种攻击可能属于下面什么攻击。（）



A.跨站脚本攻击
B.TCP 会话劫持
C.IP 欺骗攻击
D.拒绝服务攻击
答案：D
解析：流量突增 5 倍以上，说明是流量性的攻击，最后可能的就是拒绝服务攻击。

452. 以下哪一种判断信息系统是否安全的方式是最合理的?
A.是否已经通过部署安全控制措施消灭了风险
B.是否可以抵抗大部分风险
C.是否建立了具有自适应能力的信息安全模型
D.是否已经将风险控制在可接受的范围内
答案：D
解析：判断风险控制的标准是风险是否控制在接受范围内。

453. 以下关于信息安全法治建设的意义，说法错误的是：
A.信息安全法律环境是信息安全保障体系中的必要环节
B.明确违反信息安全的行为，并对行为进行相应的处罚，以打击信息安全犯罪活动
C.信息安全主要是技术问题，技术漏洞是信息犯罪的根源
D.信息安全产业的逐渐形成，需要成熟的技术标准和完善的技术体系
答案：C
解析：信息安全问题是多方面存在的，不能认为主要为技术问题，同时技术漏洞不是犯罪的根源所在。

454. 小张是信息安全风险管理方面的专家，被某单位邀请过去对其核心机房经受某种灾害的风险进行评估，已知：核心机房的总价价值一百万，灾害将导致资产总价值损失二成四(24%)，历史数据统计告知该灾害发生的可能性为八年发生三次，请问小张最后得到的年度预期损失为多少：
A.24 万
B.0．09 万
C.37．5 万
D.9 万
答案：D
解析：计算公式为 100 万*24%*（3/8）=9 万

455. 2005 年 4 月 1 日正式施行的《电子签名法》，被称为“中国首部真正意义上的信息化法律”，自此电子签名与传统手写签名和盖章具有同等的法律效力。以下关于电子签名说法错误的是：
A.电子签名——是指数据电文中以电子形式所含、所附用于识别签名人身份并表明签名人认可其中内容的数据
B.电子签名适用于民事活动中的合同或者其他文件、单证等文书
C.电子签名需要第三方认证的，由依法设立的电子认证服务提供者提供认证服务
D.电子签名制作数据用于电子签名时，属于电子签名人和电子认证服务提供者共有
答案：D
解析：电子签名不可以与认证服务提供者共有。

456. 风险管理的监控与审查不包含：
A.过程质量管理
B.成本效益管理
C.跟踪系统自身或所处环境的变化
D.沟通咨询各层面的相关人员，提高风险意识、知识和技能，配合实现安全目标。
答案：D
解析：D 答案属于沟通咨询工作，ABC 属于风险管理的监控审查工作。风险管理过程包括背景建立、风险评估、风险处理、批准监督，以及沟通咨询和监控审查。

457. 信息安全等级保护要求中，第三级适用的正确的是：
A.适用于一般的信息和信息系统，其受到破坏后，会对公民、法人和其他组织的权益有一定影响，但不危害国家安全、社会秩序、经济建设和公共利益
B.适用于一定程度上涉及国家安全、社会秩序、经济建设和公共利益的一般信息和信息系统，其受到破坏后，会对国家安全、社会秩序、经济建设和公共利益造成一般损害
C.适用于涉及国家安全、社会秩序、经济建设和公共利益的信息和信息系统，其受到破坏后，会对国家安全、社会秩序、经济建设和公共利益造成严重损害
D.适用于涉及国家安全、社会秩序、经济建设和公共利益的重要信息和信息系统的核心子系统。其受到破坏后，会对国家安全、社会秩序，经济建设和公共利益造成特别严重损害
答案：B
解析：题目中 B 为等级保护三级，该考点为等级保护定级指南。

458. 下面哪一项安全控制措施不是用来检测未经授权的信息处理活动的：
A.设置网络连接时限
B.记录并分析系统错误日志
C.记录并分析用户和管理员操作日志
D.启用时钟同步
答案：A
解析：A 属于防护措施；BCD 属于检测措施，可以用来检测未经授权的信息处理活动。

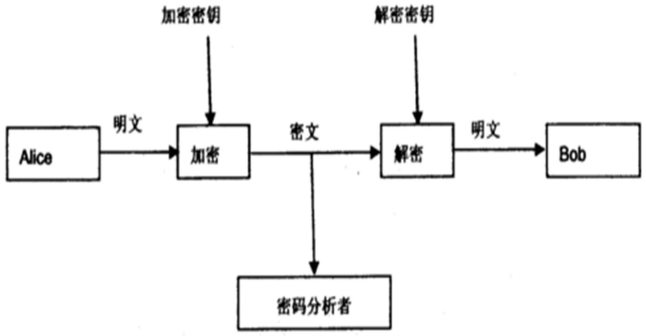
459. 有关危害国家秘密安全的行为的法律责任，正确的是：
A.严重违反保密规定行为只要发生，无论产生泄密实际后果，都要依法追究责任
B.非法获取国家秘密，不会构成刑事犯罪，不需承担刑事责任
C.过失泄露国家秘密，不会构成刑事犯罪，不需承担刑事责任

D.承担了刑事责任，无需再承担行政责任和／或其他处分

答案：A

解析：

460. 如下图所示，Alice 用 Bob 的密钥加密明文，将密文发送给 Bob，Bob 再用自己的私钥解密，恢复出明文以下说法正确的是：（）



A.此密码体制为对称密码体制

B.此密码体制为私钥密码体制

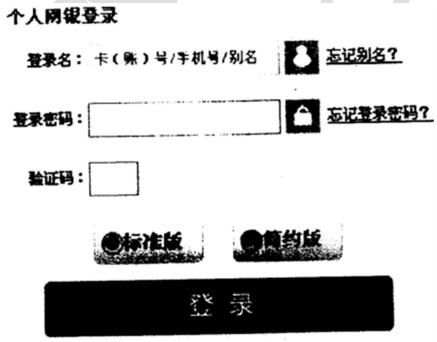
C.此密码体制为单钥密码体制

D.此密码体制为公钥密码体制

答案：D

解析：公钥密码地址：公钥加密私钥解密，私钥加密，公钥解密，公私钥成对出现。

461. 某用户通过账号，密码和验证码成功登陆某银行的个人网银系统，此过程属于以下哪一类：（）



A.个人网银和用户之间的双向鉴别

B.由可信第三方完成的用户身份鉴别

C.个人网银系统对用户身份的单向鉴别

D.用户对个人网银系统 合法性 单向鉴别

答案：C

解析：

462. 以下对于信息安全事件理解错误的是：

A.信息安全事件，是指由于自然或者人为以及软硬件本身缺陷或故障的原因，对信息系统造成危害，或在信息系统内发生对社会造成负面影响的事件

B.对信息安全事件进行有效管理和响应，最小化事件所造成的损失和负面影响，是组织信息安全战略的一部分

C.应急响应是信息安全事件管理的重要内容

D.通过部署信息安全策略并配合部署防护措施，能够对信息及信息系统提供保护，杜绝信息安全事件的发生
答案：D
解析：安全事件无法杜绝。

463．假设一个系统已经包含了充分的预防控制措施，那么安装监测控制设备：
A.是多余的，因为它们完成了同样的功能，但要求更多的开销
B.是必须的，可以为预防控制的功效提供检测
C.是可选的，可以实现深度防御
D.在一个人工系统中是需要的，但在一个计算机系统中则是不需要的，因为预防控制功能已经足够
答案：C
解析：

464．以下哪一项不是信息安全管理工作必须遵循的原则?
A.风险管理在系统开发之初就应该予以充分考虑，并要贯穿于整个系统开发过程之中
B.风险管理活动应成为系统开发、运行、维护、直至废弃的整个生命周期内的持续性工作
C.由于在系统投入使用后部署和应用风险控制措施针对性会更强，实施成本会相对较低
D.在系统正式运行后，应注重残余风险的管理，以提高快速反应能力
答案：C
解析：安全措施投入应越早则成本越低，C 答案则成本会上升。

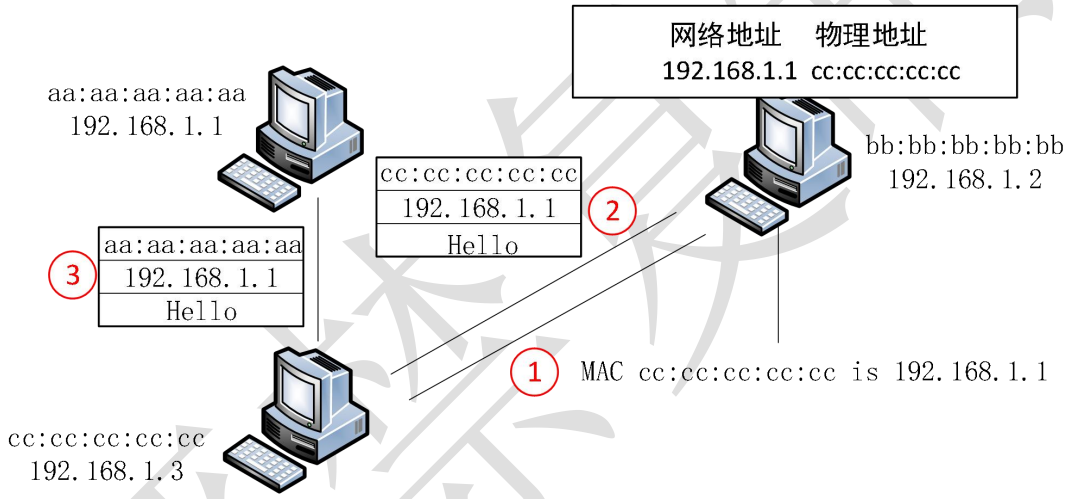
465．《信息安全技术 信息安全风险评估规范》（GB／T 20984-2007）中关于信息系统生命周期各阶段的风险评估描述不正确的是：
A.规划阶段风险评估的目的是识别系统的业务战略，以支撑系统安全需求及安全战略等
B.设计阶段的风险评估需要根据规划阶段所明确的系统运行环境、资产重要性，提出安全功能需求
C.实施阶段风险评估的目的是根据系统安全需求和运行环境对系统开发、实施过程进行风险识别，并对系统建成后的安全功能进行验证
D.运行维护阶段风险评估的目的是了解和控制运行过程中的安全风险，是一种全面的风险评估。评估内容包括对真实运行的信息系统、资产、脆弱性等各方面
答案：D
解析：该题目来源于《信息安全技术 信息安全风险评估规范》（GB／T 20984-2007），评估内容包括威胁、脆弱性和影响。

466．对信息安全风险评估要素理解正确的是：
A.资产识别的粒度随着评估范围、评估目的的不同而不同，既可以是硬件设备，也可以是业务系统，也可以是组织机构
B.应针对构成信息系统的每个资产做风险评价
C.脆弱性识别是将信息系统安全现状与国家或行业的安全要求做符合性比对而找出的差距项
D.信息系统面临的安全威胁仅包括人为故意威胁、人为非故意威胁
答案：A

解析：B 错误，应该是抽样评估；C 错误，应该其描述的是差距分析；D 错误，应该是威胁包括人为威胁和环境威胁。

467. 以下哪些是需要在信息安全策略中进行描述的：
A. 组织信息系统安全架构
B. 信息安全工作的基本原则
C. 组织信息安全技术参数
D. 组织信息安全实施手段
答案：B
解析：安全策略是宏观的原则性要求，不包括具体的架构、参数和实施手段。

468. 攻击者通过向网络或目标主机发送伪造的 ARP 应答报文，修改目标计算机上 ARP 缓存，形成一个错误的 IP 地址<->MAC 地址映射，这个错误的映射在目标主机在需要发送数据时封装错误的 MAC 地址。欺骗攻击过程如下图所示，其属于欺骗攻击中的哪一种欺骗攻击的过程（）



A. ARP;
B. IP;
C. DNS;
D. SN;
答案：A
解析：P347

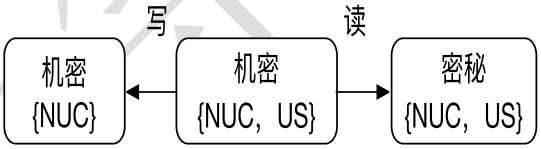
469. 下面的角色对应的信息安全职责不合理的是：
A. 高级管理层——最终责任
B. 信息安全部门主管——提供各种信息安全工作必须的资源
C. 系统的普通使用者——遵守日常操作规范
D. 审计人员——检查安全策略是否被遵从
答案：B
解析：通常由管理层提供各种信息安全工作必须的资源。

470. 自 2004 年 1 月起，国内各有关部门在申报信息安全国家标准计划项目时，必须经由以下哪个组织提出工作意见，协调一致后由该组织申报。
A. 全国通信标准化技术委员会(TC485)
B. 全国信息安全标准化技术委员会(TC260)
C. 中国通信标准化协会(CCSA)
D. 网络与信息安全技术工作委员会
答案：B
解析：

471. 风险计算原理可以用下面的范式形式化地加以说明：风险值=R（A，T，V)=R(L(T，V)，F(Ia，Va))以下关于上式各项说明错误的是：
A. R 表示安全风险计算函数，A 表示资产，T 表示威胁，V 表示脆弱性
B. L 表示威胁利资产脆弱性导致安全事件的可能性
C. F 表示安全事件发生后造成的损失
D. Ia，Va 分别表示安全事件作用全部资产的价值与其对应资产的严重程度
答案：D
解析：Ia 资产 A 的价值；Va 资产 A 的脆弱性。

472. OSI 模型把网络通信工作分为七层,其中 IP 协议对应 OSI 模型中的那一层(　)
A. 应用层
B. 传输层
C. 应用层
D. 网络层
答案：D
解析：

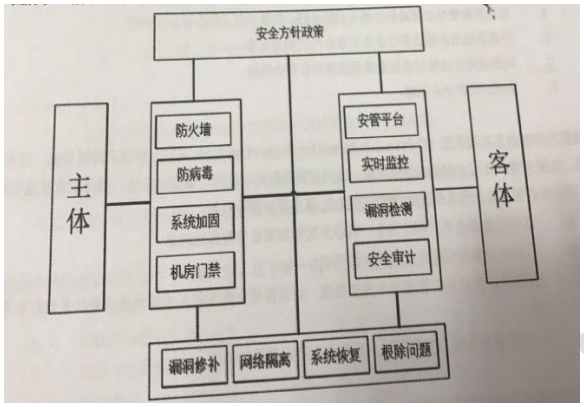
473. 根据 Bell-LaPedula 模型安全策略，下图中写和读操作正确的是（ ）



A. 可读可写
B. 可读不可写
C. 可写不可读
D. 不可读不可写
答案：B
解析：

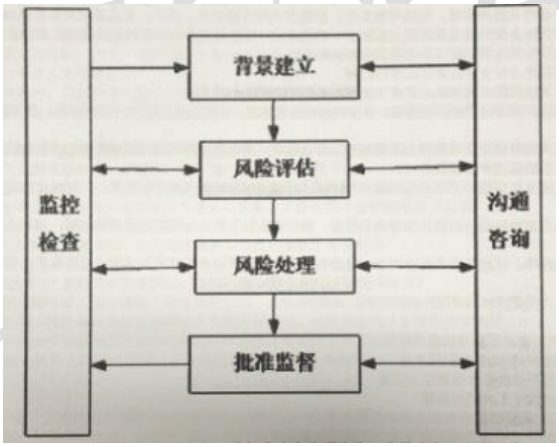
474. 以下哪一项在防止数据介质被滥用时是不推荐使用的方法：
A. 禁用主机的 CD 驱动、USB 接口等 I／O 设备
B. 对不再使用的硬盘进行严格的数据清除
C. 将不再使用的纸质文件用碎纸机粉碎
D. 用快速格式化删除存储介质中的保密文件
答案：D
解析：快速格式化删除存储介质中的保密文件不能防止信息泄露。快速格式化只是删除了文件索引，并没有真正的删除文件，可以通过工具进行恢复。

475. 小李是某公司系统规划师，某天他针对公司信息系统的现状，绘制了一张系统安全建设规划图，如下图所示。请问这个图形是依据下面哪个模型来绘制的（ ）



A.PDR
B. PPDR
C. PDCA
D. IATF
答案：B
解析：

476. 信息安全风险管理过程的模型如图所示。按照流程，请问，信息安全风险管理包括（）六个方面的内容 。（ ） 是信息安全风险管理的四个基本步骤，（）则贯穿于这四个基本步骤中.



;

A. 背景建立、风险评估、风险外理、批准监督、监控审查和沟通咨询；背景建立、风险评估、风险处理和批准监督；监控审查和沟通咨询；
B. 背景建立、风险评估、风险外理、批准监督、监控审查和沟通咨询；背景建立、风险评估、风险处理和监控审查；批准监督和沟通咨询；
C. 背景建立、风险评估、风险外理、批准监督、监控审查和沟通咨询；背景建立、风险评估、风险处理和沟通咨询；监控审查和批准监督；
D. 背景建立、风险评估、风险外理、批准监督、监控审查和沟通咨询；背景建立、风险评估、监控审查和批准监督；风险处理和沟通咨询。
答案：A
解析：背景建立、风险评估、风险外理、批准监督、监控审查和沟通咨询。

477. 在进行应用系统的测试时，应尽可能避免使用包含个人隐私和其它敏感信息的实际生产系统中的数据，如果需要使用时，以下哪一项不是必须做的：

A.测试系统应使用不低于生产系统的访问控制措施
B.为测试系统中的数据部署完善的备份与恢复措施
C.在测试完成后立即清除测试系统中的所有敏感数据
D.部署审计措施，记录生产数据的拷贝和使用
答案：B
解析：A、C、D 为测试系统必须要执行的，B 用于测试的包含个人隐私和其它敏感信息的实际生产系统中的数据不具备备份和恢复的价值。

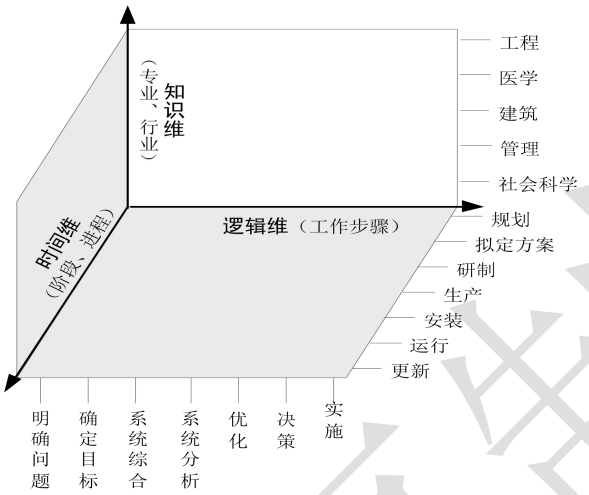
478. 为了保证系统日志可靠有效，以下哪一项不是日志必需具备的特征。
A.统一而精确地的时间
B.全面覆盖系统资产
C.包括访问源、访问目标和访问活动等重要信息
D.可以让系统的所有用户方便的读取
答案：D
解析：日志只有授权用户可以读取。

479. 以下哪一项不属于信息安全工程监理模型的组成部分：
A.监理咨询支撑要素
B.控制和管理手段
C.监理咨询阶段过程
D.监理组织安全实施
答案：D
解析：监理模型组成包括监理咨询支撑要素、监理咨询阶段过程、控制和管理手段。

480. 某公司拟建设面向内部员工的办公自动化系统和面向外部客户的营销系统，通过公开招标选择 M 公司为承建单位，并选择了 H 监理公司承担该项目的全程监理工作，目前，各个应用系统均已完成开发，M 公司已经提交了验收申请，监理公司需要对 A 公司提交的软件配置文件进行审查，在以下所提交的文档中，哪一项属于开发类文档：
A.项目计划书
B.质量控制计划
C.评审报告
D.需求说明书
答案：D
解析：ABC 其均属于项目管理文档。需求说明书、设计说明书、测试方案、测试用例等属于开发类文档。

481. 在某网络机房建设项目中，在施工前，以下哪一项不属于监理需要审核的内容：
A.审核实施投资计划
B.审核实施进度计划
C.审核工程实施人员
D.企业资质
答案：A
解析：监理从项目招标开始到项目的验收结束，在投资计划阶段没有监理。

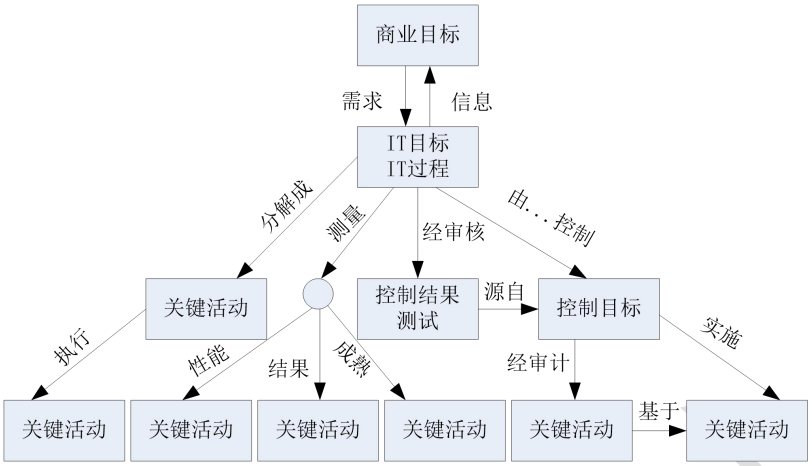
482. 美国系统工程专家霍尔（A.D.Hall）在 1969 年利用机构分析法提出著名的霍尔三维结构，使系统工程的工作阶段和步骤更为清晰明了，如图所示，霍尔三维结构是将系统工程整个活动过程分为前后紧密衔接的（）阶段和（）步骤，同时还考虑了为完全这些阶段和步骤所需要的各种（）。这样，就形成了由（）、（）、和知识维所组成的三维空间结构。



A. 五个；七个；专业知识和技能；时间维；逻辑维
B. 七个；七个；专业知识和技能；时间维；逻辑维
C. 七个；六个；专业知识和技能；时间维；逻辑维
D. 七个；六个；专业知识和技能；时间维；空间维
答案：B
解析：

483. 某公司在执行灾难恢复测试时. 信息安全专业人员注意到灾难恢复站点的服务器的运行速度缓慢，为了找到根本愿因，他应该首先检查：
A.灾难恢复站点的错误事件报告
B.灾难恢复测试计划
C.灾难恢复计划(DRP)
D.主站点和灾难恢复站点的配置文件
答案：A
解析：按照灾难恢复流程，首先检查错误事件报告。

484. COBIT（信息和相关技术的控制目标）是国际专业协会 ISACA 为信息技术（IT）管理和 IT 治理创建的良好实践框架。COBIT 提供了一套可实施的“信息技术控制”并围绕 IT 相关流程和推动因素的逻辑框架进行组织。COBIT 模型如图所示，按照流程，请问，COBIT 组件包括（）、()、（）、（）、（）、等部分。



A. 流程描述、框架、控制目标、管理指南、成熟度模型
B. 框架、流程描述、管理目标、控制目标、成熟度模型
C. 框架、流程描述、控制目标、管理指南、成熟度模型
D. 框架、管理指南、流程描述、控制目标、成熟度模型
答案：C
解析：

485. 以下对异地备份中心的理解最准确的是：
A.与生产中心不在同一城市
B.与生产中心距离 100 公里以上
C.与生产中心距离 200 公里以上
D.与生产中心面临相同区域性风险的机率很小
答案：D
解析：答案为 D，建立异地备份中心的核心思想是减少相同区域性风险。

486. 作为业务持续性计划的一部分，在进行业务影响分析(BIA)时的步骤是：1. 标识关键的业务过程;2. 开发恢复优先级;3. 标识关键的 IT 资源;4. 表示中断影响和允许的中断时间
A.1-3-4-2
B.1-3-2-4
C.1-2-3-4
D.1-4-3-2
答案：A
解析：根据 BCM 的分析过程顺序为 A。

487. 依据国家 GB/T 20274《信息系统安全保障评估框架》，信息系统安全目标(ISST)中，安全保障目的指的是：
A.信息系统安全保障目的
B.环境安全保障目的
C.信息系统安全保障目的和环境安全保障目的
D.信息系统整体安全保障目的、管理安全保障目的、技术安全保障目的和工程安全保障目的
答案：D
解析：GB/T 20274 信息系统保障评估框架从管理、技术、工程和总体方面进行评估。

488. 以下哪一项是数据完整性得到保护的例子?
A.某网站在访问量突然增加时对用户连接数量进行了限制,保证已登录的用户可以完成操作
B.在提款过程中 ATM 终端发生故障,银行业务系统及时对该用户的账户余额进行了冲正操作
C.某网管系统具有严格的审计功能,可以确定哪个管理员在何时对核心交换机进行了什么操作
D.李先生在每天下班前将重要文件锁在档案室的保密柜中,使伪装成清洁工的商业间谍无法查看。
答案:B
解析:冲正是为系统认为可能交易失败时采取的补救手法。即一笔交易在终端已经置为成功标志,但是发送到主机的账务交易包没有得到响应,即终端交易超时,所以不确定该笔交易是否在主机端也成功完成,为了确保用户的利益,终端重新向主机发送请求,请求取消该笔交易的流水,如果主机端已经交易成功,则回滚交易,否则不处理,然后将处理结果返回给终端。本题中 A 为可用性,B 为完整性,C 是抗抵赖,D 是保密性。冲正是完整性纠正措施,是 Clark-Wilson 模型的应用,解决数据变化过程的完整性。

489. 进入 21 世纪以来,信息安全成为世界各国安全战略关注的重点,纷纷制定并颁布网络空间安全战略,但各国历史、国情和文化不同,网络空间安全战略的内容也各不相同,以下说法不正确的是:
A.与国家安全、社会稳定和民生密切相关的关键基础设施是各国安全保障的重点
B.美国尚未设立中央政府级的专门机构处理网络信息安全问题,信息安全管理职能由不同政府部门的多个机构共同承担
C.各国普遍重视信息安全事件的应急响应和处理
D.在网络安全战略中,各国均强调加强政府管理力度,充分利用社会资源,发挥政府与企业之间的合作关系
答案:B
解析:美国已经设立中央政府级的专门机构。

490. 下列对于信息安全保障深度防御模型的说法错误的是:
A.信息安全外部环境:信息安全保障是组织机构安全、国家安全的一个重要组成部分,因此对信息安全的讨论必须放在国家政策、法律法规和标准的外部环境制约下。
B.信息安全管理和工程:信息安全保障需要在整个组织机构内建立和完善信息安全管理体系,将信息安全管理综合至信息系统的整个生命周期,在这个过程中,我们需要采用信息系统工程的方法来建设信息系统。
C.信息安全人才体系:在组织机构中应建立完善的安全意识,培训体系也是信息安全保障的重要组成部分。
D.信息安全技术方案:“从外而内、自下而上、形成边界到端的防护能力”。
答案:D
解析:正确描述是从内而外,自上而下,从端到边界的防护能力。

491. 为推动和规范我国信息安全等级保护工作,我国制定和发布了信息安全等级保护工作所需要的一系列标准,这些标准可以按照等级保护工作的工作阶段大致分类。下面四个标准中,()规定了等级保护定级阶段的依据、对象、流程、方法及等级变更等内容。
A.GB/T 20271-2006《信息系统通用安全技术要求》

B.GB / T 22240-2008《信息系统安全保护等级定级指南》
C.GB / T 25070-2010《信息系统等级保护安全设计技术要求》
D.GB / T 20269-2006《信息系统安全管理要求》
答案：B
解析：

492. Alice 用 Bob 的密钥加密明文，将密文发送给 Bob。Bob 再用自己的私钥解密，恢复出明文。以下说法正确的是：
A.此密码体制为对称密码体制
B.此密码体制为私钥密码体制
C.此密码体制为单钥密码体制
D.此密码体制为公钥密码体制
答案：D
解析：题干中使用到了私钥解密，私钥是公钥密码体制中用户持有的密钥，相对于公钥而言，则为非对称密码体制，非对称密码体制又称为公钥密码体制。

493. 下列哪一种方法属于基于实体“所有”鉴别方法：
A.用户通过自己设置的口令登录系统，完成身份鉴别
B.用户使用个人指纹，通过指纹识别系统的身份鉴别
C.用户利用和系统协商的秘密函数，对系统发送挑战进行正确应答，通过身份鉴别
D.用户使用集成电路卡(如智能卡)完成身份鉴别
答案：D
解析：实体所有鉴别包括身份证、IC 卡、钥匙、USB-Key 等。

494. 主体 S 对客体 O1 有读(R)权限，对客体 O2 有读(R)、写(W)、拥有(Own)权限，该访问控制实现方法是：
A.访问控制表(ACL)
B.访问控制矩阵
C.能力表(CL)
D.前缀表(Profiles)
答案：C
解析：定义主体访问客体的权限叫作 CL。定义客体被主体访问的权限叫 ACL。

495. 以下场景描述了基于角色的访问控制模型(Role-based Access Control. RBAC)：根据组织的业务要求或管理要求，在业务系统中设置若干岗位、职位或分工，管理员负责将权限(不同类别和级别的)分别赋予承担不同工作职责的用户。关于 RBAC 模型，下列说法错误的是：
A.当用户请求访问某资源时，如果其操作权限不在用户当前被激活角色的授权范围内，访问请求将被拒绝
B.业务系统中的岗位、职位或者分工，可对应 RBAC 模型中的角色
C.通过角色，可实现对信息资源访问的控制
D.RBAC 模型不能实现多级安全中的访问控制
答案：D
解析：RBAC 模型能实现多级安全中的访问控制。

496. 下面哪一项不是虚拟专用网络(VPN)协议标准：
A.第二层隧道协议(L2TP)
B.Internet 安全性(IPSEC)
C.终端访问控制器访问控制系统(TACACS+)
D.点对点隧道协议(PPTP)
答案：C
解析：TACACS+是 AAA 权限控制系统，不属于 VPN。

497. 下列对网络认证协议 Kerberos 描述正确的是：
A.该协议使用非对称密钥加密机制
B.密钥分发中心由认证服务器、票据授权服务器和客户机三个部分组成
C.该协议完成身份鉴别后将获取用户票据许可票据
D.使用该协议不需要时钟基本同步的环境
答案：C
解析：A 错误，因为使用对称密码；B 错误，因为密钥分发中心不包括客户机；D 错误，因为协议需要时钟同步。三个步骤：1）身份认证后获得票据许可票据；2）获得服务许可票据；3）获得服务。

498. 鉴别的基本途径有三种：所知、所有和个人特征，以下哪一项不是基于你所知道的：
A.口令
B.令牌
C.知识
D.密码
答案：B
解析：令牌是基于实体所有的鉴别方式。

499. 某公司已有漏洞扫描和入侵检测系统(Intrusion Detection System，IDS)产品，需要购买防火墙，以下做法应当优先考虑的是：
A.选购当前技术最先进的防火墙即可
B.选购任意一款品牌防火墙
C.任意选购一款价格合适的防火墙产品
D.选购一款同已有安全产品联动的防火墙
答案：D
解析：在技术条件允许情况下，可以实现 IDS 和 FW 的联动。

500. 入侵防御系统(IPS)是继入侵检测系统(IDS)后发展期出来的一项新的安全技术，它与 IDS 有着许多不同点，请指出下列哪一项描述不符合 IPS 的特点?
A.串接到网络线路中
B.对异常的进出流量可以直接进行阻断
C.有可能造成单点故障
D.不会影响网络性能
答案：D

解析：IPS 在串联情况下，会影响网络性能。

练习题第六卷

501. 在 OSI 参考模型中有 7 个层次，提供了相应的安全服务来加强信息系统的安全性，以下哪一层提供了保密性、身份鉴别、数据完整性服务?

A.网络层

B.表示层

C.会话层

D.物理层

答案：A

解析：网络层和应用层可以提供保密性、身份鉴别、完整性、抗抵赖、访问控制服务。

502. 某公司系统管理员最近正在部署一台 Web 服务器，使用的操作系统是 windows，在进行日志安全管理设置时，系统管理员拟定四条日志安全策略给领导进行参考，其中能有效应对攻击者获得系统权限后对日志进行修改的策略是：

A.网络中单独部署 syslog 服务器，将 Web 服务器的日志自动发送并存储到该 syslog 日志服务器中

B.严格设置 Web 日志权限，只有系统权限才能进行读和写等操作

C.对日志属性进行调整，加大日志文件大小、延长覆盖时间、设置记录更多信息等

D.使用独立的分区用于存储日志，并且保留足够大的日志空间

答案：A

解析：在多重备份存储情况下，可以防护日志被篡改的攻击（前提非实时同步）。

503. 安全的运行环境是软件安全的基础，操作系统安全配置是确保运行环境安全必不可少的工作，某管理员对即将上线的 Windows 操作系统进行了以下四项安全部署工作，其中哪项设置不利于提高运行环境安全?

A.操作系统安装完成后安装最新的安全补丁，确保操作系统不存在可被利用的安全漏洞

B.为了方便进行数据备份，安装 Windows 操作系统时只使用一个分区 C，所有数据和操作系统都存放在 C 盘

C.操作系统上部署防病毒软件，以对抗病毒的威胁

D.将默认的管理员账号 Administrator 改名，降低口令暴力破解攻击的发生可能

答案：B

解析：操作系统和应用安全装应分开不同磁盘部署。

504. 下列哪一些对信息安全漏洞的描述是错误的?

A.漏洞是存在于信息系统的某种缺陷。

B.漏洞存在于一定的环境中，寄生在一定的客体上(如 TOE 中、过程中等)。

C.具有可利用性和违规性，它本身的存在虽不会造成破坏，但是可以被攻击者利用，从而给信息系统安全带来威胁和损失。

D.漏洞都是人为故意引入的一种信息系统的弱点

答案：D

解析：漏洞是“人为故意或非故意引入的弱点”，漏洞可能是无意的有些甚至就是设计缺陷引起的。

505. 为增强 Web 应用程序的安全性，某软件开发经理决定加强 Web 软件安全开发培训，下面哪项内容不在考虑范围内

A.关于网站身份鉴别技术方面安全知识的培训

B.针对 OpenSSL 心脏出血漏洞方面安全知识的培训

C.针对 SQL 注入漏洞的安全编程培训

D.关于 ARM 系统漏洞挖掘方面安全知识的培训

答案：D

解析：D 属于 ARM 系统，不属于 WEB 安全领域。

506. 关于源代码审核，描述正确的是

A.源代码审核过程遵循信息安全保障技术框架模型(IATF)，在执行时应一步一步严格执行

B.源代码审核有利于发现软件编码中存在的安全问题，相关的审核工具既有商业工具又有开源工具

C.源代码审核如果想要有效率高，则主要依赖人工审核而不是工具审核，因为人工智能的，需要人的脑袋来判断

D.源代码审核能起到很好的安全保证作用，如果执行了源代码审核，则不需要安全测试

答案：B

解析：A 错误，因为 IATF 不用于代码审核；C 错误，因为人工和攻击相结合；D 错误，安全测试由需求确定。

507. 微软提出了 STRIDE 模型，其中 R 是 Repudiation(抵赖)的缩写，此项错误的是

A.某用户在登录系统并下载数据后，却声称“我没有下载过数据”软件 R 威胁

B.某用户在网络通信中传输完数据后，却声称“这些数据不是我传输的”威胁也属于 R 威胁。

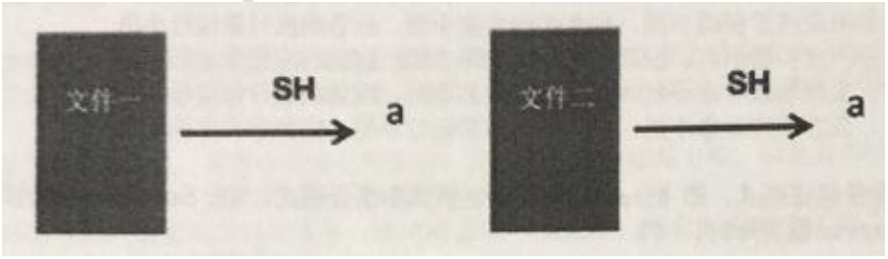
C.对于 R 威胁，可以选择使用如强认证、数字签名、安全审计等技术

D.对于 R 威胁，可以选择使用如隐私保护、过滤、流量控制等技术

答案：D

解析：R-抵赖是无法通过过滤、流控和隐私保护实现的，R-抵赖的实现方式包括数字签名、安全审计、第三方公证。

508. 如下图所示，两份文件包含了不同的内容，却拥有相同的 SHA- 1 数字签名 a,这违背了安全的哈希函数（）性质。



A. 单向性;

B. 弱抗碰撞性;

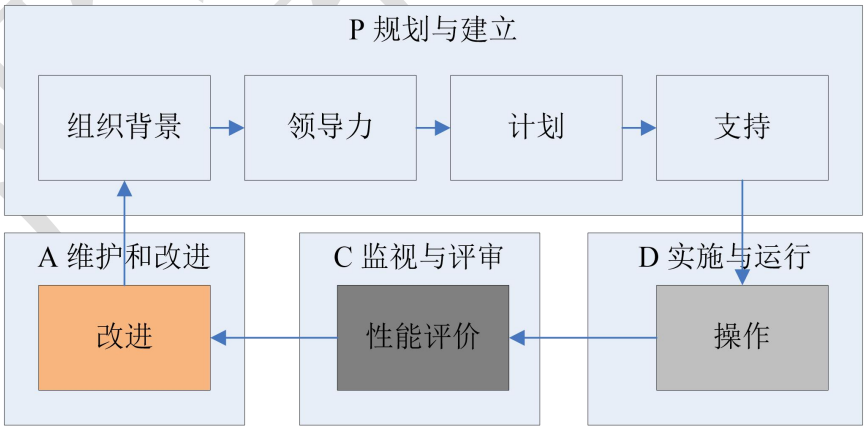
C. 强抗碰撞性;

D. 机密性;

答案：C
解析：该题目是违背了强抗碰撞性，P282 页。

509.在 PDR 模型的基础上，发展成为了(Policy-Protection-Detection-Response,PPDR)模型，即策略-保护-检测-响应。模型的核心是：所有的防护、检测、响应都是依据安全策略实施的。在 PPDR 模型中，策略指的是信息系统的安全策略，包括访问控制策略、加密通信策略、身份认证测录、备份恢复策略等。策略体系的建立包括安全策略的制定、（）等；防护指的是通过部署和采用安全技术来提高网络的防护能力，如（）、防火墙、入侵检测、加密技术、身份认证等技术；检测指的是利用信息安全检测工具，监视、分析、审计网络活动，了解判断网络系统的（）。检测这一环节，使安全防护从被动防护演进到主动防御，是整个模型动态性的体现，主要方法包括；实时监控、检测、报警等；响应指的是在检测到安全漏洞和安全事件，通过及时的响应措施将网络系统的（）调整到风险最低的状态，包括恢复系统功能和数据，启动备份系统等。启动备份系统等。其主要方法包括：关闭服务、跟踪、反击、消除影响等。
A. 评估与执行；访问控制；安全状态；安全性
B. 评估与执行；安全状态；访问控制；安全性
C. 访问控制；评估与执行；安全状态；安全性
D. 安全状态，评估与执行；访问控制；安全性
答案：A
解析

510. 下图描绘了信息安全管理体系的 PDCA 模型其中，建立 ISMS 中，组织应根据业务、组织、位置、资产和技术等方面的特性，确定 ISMS 的范围和边界，包括对范围任何删减的详细说明和正当性理由。组织应根据业务、组织、位置、资产和技术等方面的特性，监视和评审 ISMS（）。实施和运行 ISMS 中，组织应为管理信息安全风险识别适当的（）、资源、职责和优选顺序，监视和评审 ISMS 中，组织应执行监视与评审规程和其他（）。以迅速检测过程运行结果中的错误，迅速识别图的和得逞的安全违规和事件，使管理者能够确定分配给人员的安全活动或通过信息技术实施的安全活动是否按期望执行，通过使用指示器帮助检测安全事态并预防安全事件，确定解决安全违规的措施是否有效，保持和改进 ISMS 中，组织应经常进行 ISMS 改进，采取合适的纠正和（），从其他组织和组织自身的安全经验中（）。



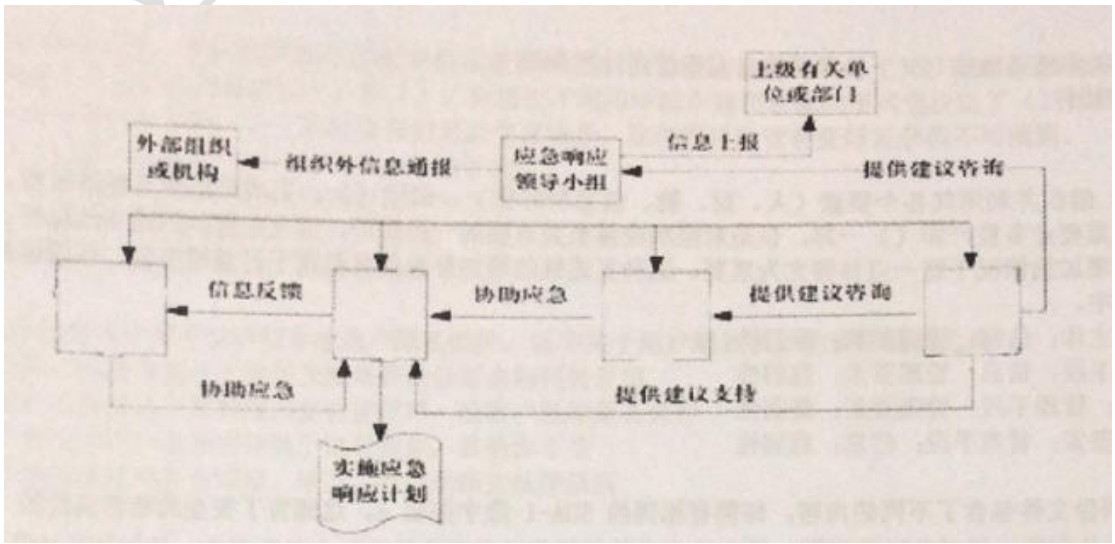
A.方针；管理措施；控制措施；预防措施；吸取措施
B. 方针；控制措施；管理措施；预防措施；吸取措施
C. 方针；预防措施；管理措施；控制措施；吸取措施
D. 方针；吸取措施；管理措施；控制措施；预防措施
答案：A
解析：

511. 下图显示了 SSAM 的四个阶段和每个阶段工作内容。与之对应，（）的目的是建立评估框架，并为现场阶段准备后勤方面的工作。（）的目的是准备评估团队进行现场活动，并通过问卷进行数据的初步收集和分析。（）主要是探索初步数据分析结果，以及为被评组织的专业人员提供与数据采集和证实过程的机会，小组对在此就三个阶段中采集到的所有数据进行（）。并将调查结果呈送个发起者。



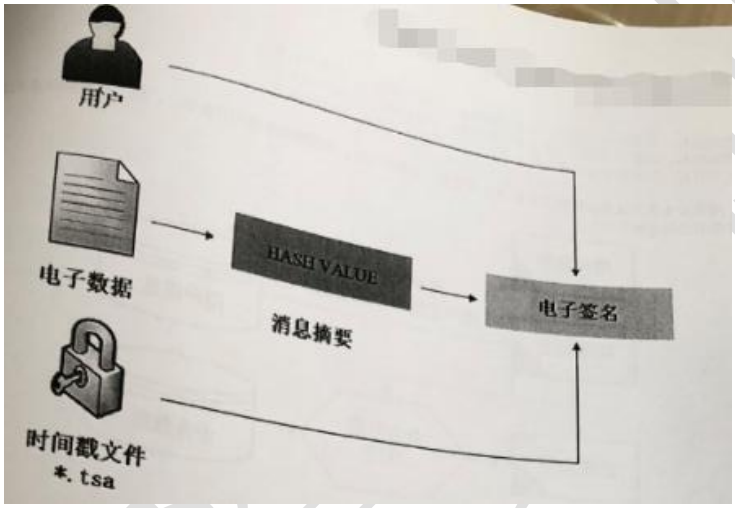
A. 现场阶段；规划阶段；准备阶段；最终分析
B. 准备阶段；规划阶段；现场阶段；最终分析
C. 规划阶段；现场阶段；准备阶段；最终分析
D. 规划阶段；准备阶段；现场阶段；最终分析
答案： D
解析：

512. 网络与信息安全应急预案是在分析网络与信息系统突发事件后果和应急能力的基础上，针对可能发生的重大网络与信息系统突发事件，预先制定的行动计划或应急对策。应急预案的实施需要各子系统相互与协调，下面应急响应工作流程图中，空白方框中从右到左依次填入的是（）。



A. 应急响应专家小组、应急响应技术保障小组、应急响应实施小组、应急响应日常运行小组；
B. 应急响应专家小组、应急响应实施小组、应急响应技术保障小组、应急响应日常运行小组；
C. 应急响应技术保障小组、应急响应专家小组、应急响应实施小组、应急响应日常运行小组 ；
D. 应急响应技术保障小组、应急响应专家小组、应急响应日常运行小组、应急响应实施小组；
答案：A
解析：P154 图 4-1

513. 网络交易发达的今天，贸易双方可以通过签署电子合同来保障自己的合法权益。某中心推出电子签名服务，按照如图方式提供电子签名，不属于电子签名的基本特性的是（）。



A. 不可伪造性
B.不可否认性
C.保证消息完整性
D.机密性
答案：D
解析：

514. 2008 年 1 月 2 日，美国发布第 54 号总统令，建立国家网络安全综合计划（Comprehensive National Cyber security Initiative，CNCI）。CNCI 计划建立三道防线：第一道防线，减少漏洞和隐患，预防入侵；第二道防线，全面应对各类威胁；第三道防线，强化未来安全环境. 从以上内容，我们可以看出以下哪种分析是正确的：
A.CNCI 是以风险为核心，三道防线首要的任务是降低其网络所面临的风险
B.从 CNCI 可以看出，威胁主要是来自外部的，而漏洞和隐患主要是存在于内部的
C.CNCI 的目的是尽快研发并部署新技术彻底改变其糟糕的网络安全现状，而不是在现在的网络基础上修修补补
D.CNCI 彻底改变了以往的美国信息安全战略，不再把关键基础设施视为信息安全保障重点，而是追求所有网络和系统的全面安全保障
答案：A
解析：CNCI 第一个防线针对漏洞进行风险控制，第二个防线针对威胁进行风险控制，总体的目标是降低网络风险。B、C、D 答案均无法从题干反应。

515. Windows NT 提供的分布式安全环境又被称为:
A.域（Domain）
B.工作组
C.对等网
D.安全网
答案；A
解析：

516. 视窗操作系统（Windows）从哪个版本开始引入安全中心的概念？
A.WinNT SP6
B.Win2000 SP4
C.WinXP SP2
D.Win2003 SP1
答案；C
解析：

517. Windows 系统下，可通过运行（ ）命令打开 Windows 管理控制台。
A.regedit
B.cmd
C.mmc
D.mfc
答案；C
解析：

518. 在 window 系统中用于显示本机各网络端口详细情况的命令是:
A.netshow
B.netstat
C.ipconfig
D.Netview
答案；B
解析：

519. Windows 操作系统的注册表运行命令是：
A.Regsvr32
B.Regedit
C.Regedit.msc
D.Regedit.mmc
答案；B
解析：

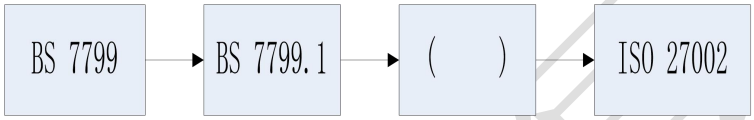
520. 下图是安全测试人员连接某远程主机时的操作界面，请您仔细分析该图，下面分析推理正确的是（）

```
C:\WINDOWS\system32\cmd.exe
220 Serv-U FTP Server V6.0 for WinSock ready…
Quit
221 Goodbye!


失去了跟主机的连接
C:\Documents and Settings\lvxiaowei>
```

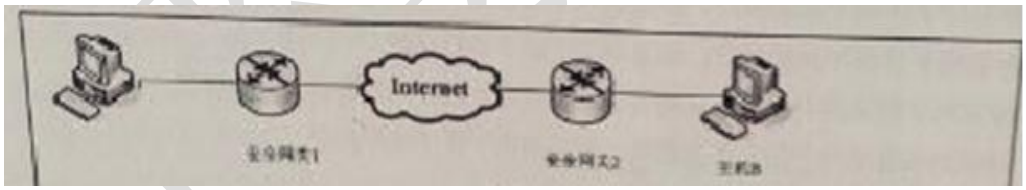
A.安全测试人员链接了远程服务器的 220 端口
B.安全测试人员的本地操作系统是 Linux
C.远程服务器开启了 FTP 服务，使用的服务器软件名 FTP Server
D.远程服务器的操作系统是 windows 系统
答案：D
解析：

521. ISO27002（Information technology-Security techniques0Codeofpratice for inforeation security managcacnt）是重要的信息安全管理标准之一，下图是关于其演进变化示意图，图中括号空白处应填写（）



A.BS 7799.1.3
B.ISO 17799
C.AS/NZS 4630
D.NIST SP 800-37
答案：B
解析：

522. 如图一所示:主机 A 和主机 B 需要通过 IPSec 隧道模式保护二者之间的通信流量，这种情况下 IPSec 的处理通常发生在哪二个设备中?（）



A.主机 A 和安全网关 1;
B.主机 B 和安全网关 2;
C.主机 A 和主机 B 中;
D.安全网关 1 和安全网关 2 中;
答案：D
解析：